

TECNOLOGIA DA INFORMAÇÃO

Segurança da Informação



Presidente: Gabriel Granjeiro

Vice-Presidente: Rodrigo Calado

Diretor Pedagógico: Erico Teixeira

Diretora de Produção Educacional: Vivian Higashi

Gerente de Produção Digital: Bárbara Guerra

Todo o material desta apostila (incluindo textos e imagens) está protegido por direitos autorais do Gran. Será proibida toda forma de plágio, cópia, reprodução ou qualquer outra forma de uso, não autorizada expressamente, seja ela onerosa ou não, sujeitando-se o transgressor às penalidades previstas civil e criminalmente.

CÓDIGO:

250610189445



PATRÍCIA QUINTÃO

Mestre em Engenharia de Sistemas e computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV. Atualmente é professora no Gran Cursos Online; Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG; Escritora e Personal & Professional Coach. Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008. É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação. Autora dos livros: Informática FCC - Questões comentadas e organizadas por assunto, 3ª. edição e 1001 questões comentadas de informática (Cespe/UnB), 2ª. edição, pela Editora Gen/Método. Foi aprovada nos seguintes concursos: Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG; Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia; Professora substituta do DCC da UFJF; Analista de TI/Suporte, PRODABEL; Analista do Ministério Público MG; Analista de Sistemas, DATAPREV, Segurança da Informação; Analista de Sistemas, INFRAERO; Analista - TIC, PRODEMGE; Analista de Sistemas, Prefeitura de Juiz de Fora; Analista de Sistemas, SERPRO; Analista Judiciário (Informática), TRF 2ª Região RJ/ES, etc.

GRAN
CONCURSOS

SUMÁRIO

Apresentação	5
Segurança da Informação	7
Conceitos Gerais de Segurança da Informação	7
O que é Segurança?	7
Ativos de Segurança.....	7
Vulnerabilidades de Segurança.....	8
Ameaças à Segurança	8
Riscos.....	10
Cibersegurança.....	11
Controles Lógicos x Controles Físicos	12
Ciclo da Segurança.....	12
Princípios ou Atributos Básicos da Segurança da Informação	13
Malwares (Softwares Maliciosos)	18
Vírus.....	19
Worms	21
Bots (“Robôs”).....	22
Trojan Horse (Cavalo de Troia)	23
Exploits	23
Spyware	23
Ransomware (Pede Resgate!)	26
Backdoors (Abre Portas!).....	27
Scareware (Software de Engano, Software de Verificação Desonesto ou Fraudware)	28
Doxware (Ameaça Divulgar Informações Se Não For Pago o Resgate)	29
Bolware (Vírus de Boletão)	29
Rootkit (Busca Alterar a Ação do Sistema Operacional!).....	30
Crack (Quebra Senhas e Licenças de Softwares)	31
Sniffers (Farejadores ou Capturadores de Pacotes)	32

APT (Advanced Persistent Threat – Ameaça Persistente Avançada)	32
Principais Golpes Aplicados na Internet	36
Hoaxes (Boatos)	36
Engenharia Social	36
Phishing, Scam ou Phishing Scam.	36
Spear Phishing	37
Pharming	37
Golpe de Sextorsão	38
Ataques na Internet	38
Interceptação de Tráfego (Sniffing)	38
Denial of Service (DoS)	39
Distributed Denial of Service (DDoS) – São os Ataques Coordenados!	40
Smurf	40
Ataques de Amplificação	41
Ataques Fileless, ou “Sem Arquivo”	41
Ataque de Força Bruta (Brute Force)	41
Pichação ou Desfiguração de Página (Defacement)	42
Spoofing	42
Varredura em Redes, ou Scan	42
Session Hijacking (Sequestro de Sessão)	42
Cross Site Request Forgery (XSRF)	43
Resumo	44
Questões Comentadas em Aula	50
Exercícios	51
Gabarito	65
Gabarito Comentado	66
Referências	104
Anexo	106

APRESENTAÇÃO

À luta, guerreiro(a)! É um prazer revê-lo(a).

Confiança é um dos grandes segredos do **sucesso**. Estude com dedicação, trabalhe duro (quem disse que seria moleza!), faça com direção, foco, siga as dicas que fornecemos durante o curso e, com certeza, terá mais soldados a seu favor e **sucesso total nesta batalha** que se aproxima!

Rumo então à aula sobre **Segurança da Informação**.

Que Deus o(a) abençoe e sucesso nos estudos!

APRESENTAÇÃO DA PROFESSORA

Patrícia Quintão é Mestra em Engenharia de Sistemas e Computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV (Universidade Federal de Viçosa).

Atualmente é professora no Gran, e leciona também na pós-graduação e na graduação da Gran Faculdade. Ainda é Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG, e escritora e *Personal & Professional Coach*.

Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008.

É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação.

Autora dos livros:

- Informática FCC – Questões comentadas e organizadas por assunto, 3ª Edição; e
- 1001 questões comentadas de informática (Cespe/UnB), 2ª edição, pela Editora Gen/Método.

Foi aprovada nos seguintes concursos:

- Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG;
- Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia;
- Professora substituta do DCC da UFJF;
- Analista de TI/Suporte, PRODABEL;
- Analista do Ministério Público MG;
- Analista de Sistemas, DATAPREV, Segurança da Informação;
- Analista de Sistemas, INFRAERO;
- Analista – TIC, PRODEMGE;

- Analista de Sistemas, Prefeitura de Juiz de Fora;
- Analista de Sistemas, SERPRO;
- Analista Judiciário (Informática), TRF 2ª Região RJ/ES etc.

Feliz em estar aqui com você!

Profª Patrícia Lima Quintão

SEGURANÇA DA INFORMAÇÃO

CONCEITOS GERAIS DE SEGURANÇA DA INFORMAÇÃO

O QUE É SEGURANÇA?

A **segurança** é um conceito fundamental em nosso dia a dia, representando um estado de proteção em que nos sentimos “livres” de **ameaças** e **incertezas**.

Trata-se de um conjunto de medidas e práticas projetadas para **proteger informações, dados e sistemas computacionais contra ameaças, vulnerabilidades e ataques maliciosos**.

Ela se aplica a uma **ampla variedade de ambientes**, incluindo empresas, organizações governamentais, redes sociais e dispositivos pessoais.

Obs.: A **segurança da informação** envolve proteger dados contra **ameaças externas e internas**, visando garantir a continuidade das operações, minimizar danos e maximizar o retorno sobre investimentos e oportunidades comerciais.

ATIVOS DE SEGURANÇA

Dentro de uma organização, a segurança abrange tudo aquilo que manipula direta ou indiretamente informações, incluindo as próprias informações e os usuários que as utilizam. Esses componentes são chamados de **ATIVOS** e podem ser classificados em:

ATIVOS DE SEGURANÇA	
Tangíveis	Itens físicos como informações impressas, móveis, hardware (por exemplo, impressoras, scanners).
Intangíveis	Ativos como a marca de um produto, nome da empresa, ou a confiabilidade de uma instituição
Lógicos	Dados armazenados em redes, sistemas ERP (Sistema de Gestão Integrada), etc.
Físicos	Estruturas como galpões, sistemas elétricos, estações de trabalho.
Humanos	Colaboradores e funcionários.

Vejamos a definição de ativos conforme Beal (2005) e Moreira (2001).

Autor	Conceituação
Beal (2005)	Um ativo de informação é qualquer dado ou informação que possui valor para a organização . Essas informações valiosas podem estar na mente dos tomadores de decisão, em bancos de dados, arquivos digitais, documentos impressos, entre outros.
Moreira (2001)	Um ativo é tudo que lida direta ou indiretamente com a informação dentro de uma organização, e precisa de proteção contra ameaças para assegurar o correto funcionamento dos negócios . A alteração, destruição, erro ou falta de disponibilidade de qualquer ativo pode comprometer os sistemas e, conseqüentemente, as atividades da empresa.

Conforme a norma NBR ISO/IEC 27002:2005, **a informação é um ativo** que, assim como qualquer recurso importante, é essencial para as operações de uma organização e precisa ser protegida adequadamente.

Soluções isoladas não solucionam completamente os desafios associados à segurança da informação. **A segurança é construída em partes, mas todas devem estar integradas como os elos de uma corrente.** Proteger a segurança significa **proteger cada elo, ou seja, todos os ativos da organização.** Afinal, a força de proteção da corrente está diretamente ligada ao seu elo mais fraco.

VULNERABILIDADES DE SEGURANÇA

Fragilidade que poderia ser explorada por uma ameaça para concretizar um ataque.

Ex.: notebook sem as atualizações de segurança do sistema operacional.



O PULO DO GATO

A **vulnerabilidade** está no ativo. As **ameaças** estão **FORA** do ativo. Sempre se deve ter em mente o que precisa ser protegido e de quem precisa ser protegido de acordo com as **ameaças** existentes.

Outros exemplos de **vulnerabilidades** incluem:

- ambientes com informações confidenciais sem controle de acesso adequado;
- falta de mecanismos de monitoramento e auditoria;
- falta de recursos para combate a incêndios;
- ausência de políticas de segurança estabelecidas;
- software e hardware desatualizados;
- falta de pessoal qualificado para segurança;
- infraestrutura fora dos padrões recomendados etc.

AMEAÇAS À SEGURANÇA

A **ameaça** representa qualquer fator que possa causar **danos** à segurança da informação, comprometendo a continuidade dos negócios ao explorar vulnerabilidades.

Em outras palavras, **uma AMEAÇA é algo que pode comprometer a segurança de um sistema**, podendo ser:

Acidentais	Falhas de hardware, erros de programação, desastres naturais, erros do usuário, bugs de software etc.
Deliberadas	Ex.: roubo, espionagem, fraude, sabotagem, invasões por hackers etc.

A ameaça pode ser uma pessoa, evento ou ideia que pode causar prejuízo a um recurso em termos de confidencialidade, integridade e disponibilidade.

Outra classificação divide as ameaças em dois **tipos**:

TIPOS DE AMEAÇAS	
Externas	Incluem tentativas de ataque e roubo de informações vindo de fora da organização, geralmente conduzidas por indivíduos com intenção de causar dano ou explorar recursos da empresa para atacar outras.
Internas	Ocorrem independentemente de conexões com a internet e podem variar de incidentes menores a graves, como a paralisação das operações.

Os ativos são os elementos que sustentam a operação do negócio e estes sempre trarão consigo **VULNERABILIDADES** que, por sua vez, submetem os ativos a **AMEAÇAS**.



Fonte: *Trusted Computer System Evaluation Criteria*

Exemplos de ameaças incluem concorrentes, *crackers*, erro humano (como a exclusão acidental de arquivos), desastres naturais (como inundações), funcionários insatisfeitos, métodos como engenharia social, e ferramentas de software maliciosas como *sniffers* ou cavalos de Troia.

Incidente de segurança da informação: um simples ou uma série de eventos de segurança da informação indesejados ou inesperados, que tenham uma grande probabilidade de comprometer as operações do negócio e ameaçar a segurança.

RESUMO DA ÓPERA: ativos são os **elementos que garantem a operação do negócio**, mas inevitavelmente trazem consigo **vulnerabilidades, que os expõem a ameaças**. A gestão eficaz da segurança da informação envolve identificar e mitigar essas vulnerabilidades para proteger os ativos contra possíveis ameaças.

RISCOS

Risco é a **medida de quanto um sistema computacional está exposto a potenciais ameaças**. Ele é determinado pela **probabilidade de uma ameaça atacar o sistema e pelo impacto que esse ataque pode causar**.

De acordo com Sêmola (2003, p. 50), risco é a “**probabilidade de ameaças explorarem vulnerabilidades, provocando perdas de confidencialidade, integridade e disponibilidade, causando, possivelmente, impactos nos negócios**”.

EXEMPLO

Imagine um funcionário insatisfeito com um martelo ao alcance; ele poderia danificar um ativo de informação, ilustrando um risco potencial.

Há várias maneiras de classificar o grau de risco no setor de segurança, mas uma abordagem simples é categorizá-lo como **alto, médio ou baixo**. No caso da sala dos servidores, considerando a vulnerabilidade identificada, a ameaça correspondente poderia ser classificada como de alto risco.

No caso do nosso exemplo da sala dos servidores, poderíamos dizer que, baseado na vulnerabilidade encontrada, a ameaça associada é de alto risco.

Exemplo de riscos relacionados a cookies: **cookies** não são vírus, e sim arquivos lícitos instalados no computador durante a navegação que permitem a identificação da máquina no acesso a uma página. Podem ser utilizados para guardar preferências do usuário, bem como informações técnicas como o nome e a versão de seu browser.

Alguns dos **riscos relacionados ao uso de cookies:**

- **informações coletadas pelos cookies** podem ser indevidamente compartilhadas com outros *sites* e afetar a sua privacidade;
- **exploração de vulnerabilidades existentes no computador;**

- **autenticação automática:** quando utilizamos as opções como
- “Lembre-se de mim” e “continuar conectado” nos *sites* visitados, os *cookies* guardam essas informações para autenticações futuras. Em caso de uma máquina contaminada, essa prática pode permitir que outras pessoas se autenticuem como você;
- **coleta de informações pessoais:** dados preenchidos em formulários Web também podem ser gravados em *cookies*, coletados por atacantes ou códigos maliciosos e indevidamente acessados, caso não estejam criptografados;
- **coleta de hábitos de navegação** e, assim, comprometer a privacidade.

CIBERSEGURANÇA

Também conhecida como **segurança informática** – **faz parte de uma segmentação específica dentro do campo da Segurança da Informação**. É responsável por definir as metodologias e tecnologias que serão usadas para a proteção de dados dentro do **ciberespaço** (SIEMENS, 2020).

O setor de **Cibersegurança** é responsável por proteger todos os ativos digitais da corporação transmitidos por rede ou armazenados em nuvem, por exemplo. Além disso, essa é a área que faz todo os testes de prevenção de potenciais ataques externos.

Os protocolos estabelecidos para as melhores práticas de **Cibersegurança** também fazem parte da norma internacional ISO 27001, que considera dados cibernéticos ou ativos de informação, qualquer conjunto de dados que tenha valor para os negócios da corporação (SIEMENS, 2020).

A **pandemia acelerou a digitalização** trazendo novidades para as organizações, tanto do ponto de vista da realização de atividades quanto da gestão de informações. No entanto, também trouxe novos **riscos**, relacionados à **cibersegurança**.

Além do **trabalho remoto**, que levou muitos colaboradores a precisarem acessar online as redes da empresa, **TODAS as informações necessárias para a tomada de decisão também passaram a ser armazenadas em nuvem**. E isso acabou resultando, em grande parte dos casos, em maior **vulnerabilidade**.

Hoje, **as empresas estão mais distribuídas**, justamente por causa do **trabalho híbrido**, o que representa um verdadeiro **desafio** para seus gestores.

As novas ameaças se sofisticaram, fazendo com que a **segurança cibernética seja mais importante do que nunca**.

As avaliações de desempenho dos executivos estarão cada vez mais vinculadas à capacidade de **gerenciar riscos cibernéticos**.

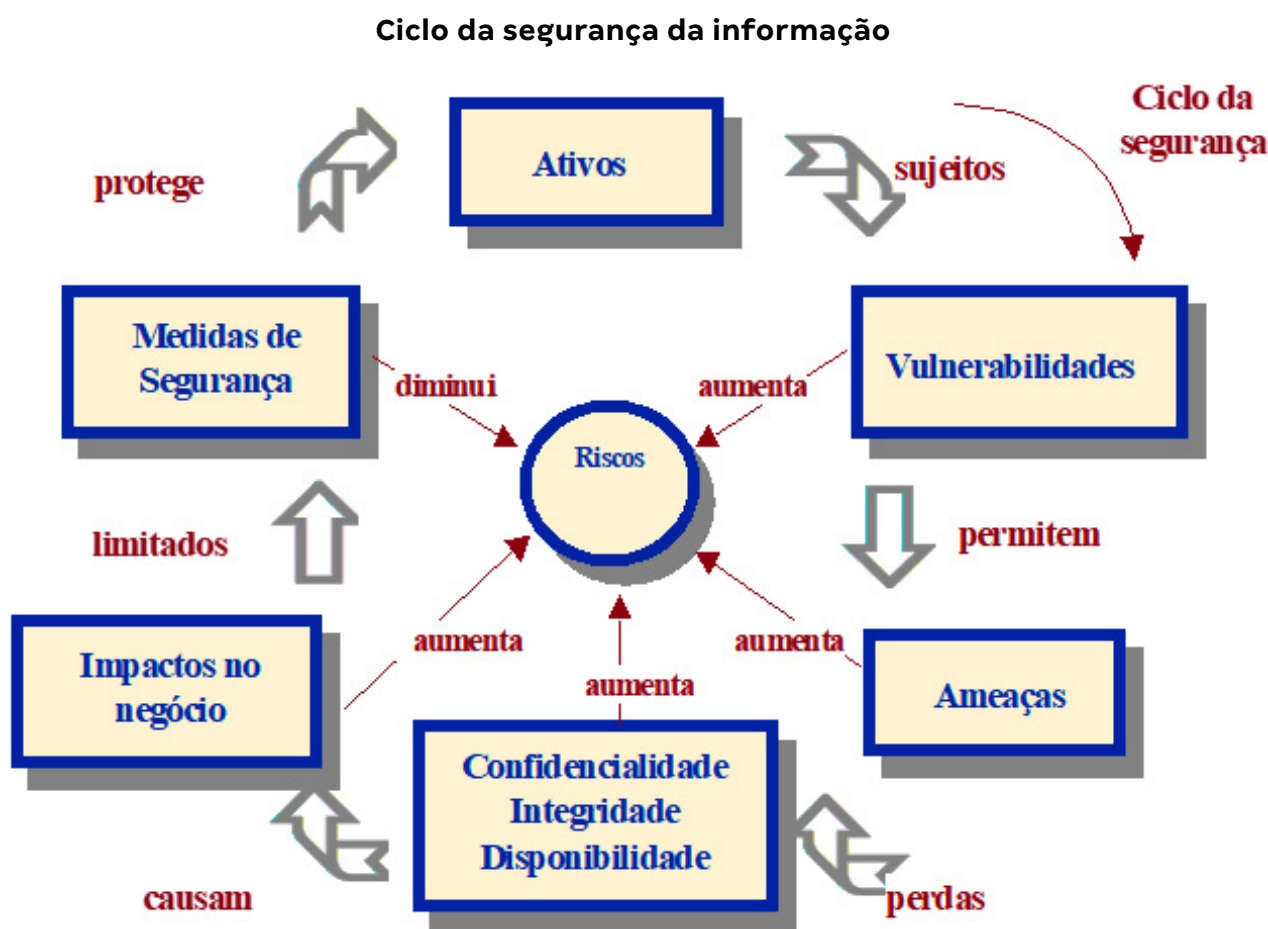
CONTROLES LÓGICOS X CONTROLES FÍSICOS

Controles lógicos: barreiras que impedem ou limitam o acesso à informação, que está em ambiente computacional, exposto a cópia, alteração ou apagamento não autorizado por elemento mal intencionado, que pode estar distante da origem dos dados. Por exemplo: antivírus, firewalls, filtros anti-spam, analisadores de código, sistemas biométricos, *hashing*, criptografia, assinatura digital, certificação digital, protocolos seguros.

Controles físicos: barreiras que limitam o contato ou acesso direto à informação ou à infraestrutura (que garante a existência da informação) que a suporta. Por exemplo: portas, trancas, paredes, blindagem, guardas, câmeras, cercas elétricas, cães etc.

CICLO DA SEGURANÇA

Os **ATIVOS** de uma organização precisam ser protegidos, pois estão sujeitos a **VULNERABILIDADES**.



Fonte: MOREIRA, 2001.

Se as vulnerabilidades aumentam, aumentam-se os riscos permitindo a exploração por uma ameaça e a concretização de um ataque. Se estas ameaças crescem, aumentam-se ainda mais os riscos de perda da integridade, disponibilidade e confidencialidade da informação, podendo causar impacto nos negócios.

Nesse caso, **MEDIDAS DE SEGURANÇA** devem ser tomadas, os riscos devem ser analisados e diminuídos para que se estabeleça a segurança dos ativos da informação.

As **ameaças** são causas em potencial de um incidente indesejado (por exemplo, um ataque de um *hacker* é uma ameaça). As ameaças e as vulnerabilidades aumentam os riscos relativos à segurança por parte de uma organização.

Assim, pode-se dizer que os **riscos** são medidos pela **combinação** entre:

- **número de vulnerabilidades** dos ativos;
- a **probabilidade** de vulnerabilidades serem exploradas por uma ameaça; e
- o **impacto** decorrente dos incidentes de segurança na organização.

PRINCÍPIOS OU ATRIBUTOS BÁSICOS DA SEGURANÇA DA INFORMAÇÃO

A **segurança da informação** tem como objetivo proteger os ativos de uma empresa ou indivíduo com base em princípios fundamentais. Os três princípios mais importantes são:

- **Confidencialidade (ou Sigilo):** a **confidencialidade** assegura que a informação não seja acessada por indivíduos não autorizados. Somente pessoas explicitamente autorizadas podem ter acesso às informações. A perda de confidencialidade significa a revelação de segredos. Informações confidenciais são mantidas em segredo e protegidas contra acesso não autorizado.

CONFIDENCIALIDADE busca

proteção contra **exposição** não autorizada.

acesso somente por pessoas autorizadas.

- **Integridade:** a **integridade** garante que a informação permanece na sua forma original e é protegida contra alterações intencionais, não autorizadas ou acidentais. Isso significa que a informação armazenada é a mesma que será recuperada.

INTEGRIDADE busca

proteção contra **codificação** não autorizada.

modificação somente pelas partes devidamente autorizadas.

- **Disponibilidade:** a **disponibilidade** garante que a informação esteja acessível sempre que necessária por usuários autorizados. Em outras palavras, é a garantia que a informação sempre poderá ser acessada!

DISPONIBILIDADE busca

acesso disponível às **entidades autorizadas** sempre que **necessário**.

Tais princípios formam a chamada **tríade da Segurança da Informação**, conhecida como **CID**. Esses princípios são aplicados através de controles como criptografia, autenticação de usuários e equipamentos redundantes, garantindo que a informação correta chegue à pessoa certa quando necessário.

Essência da Segurança

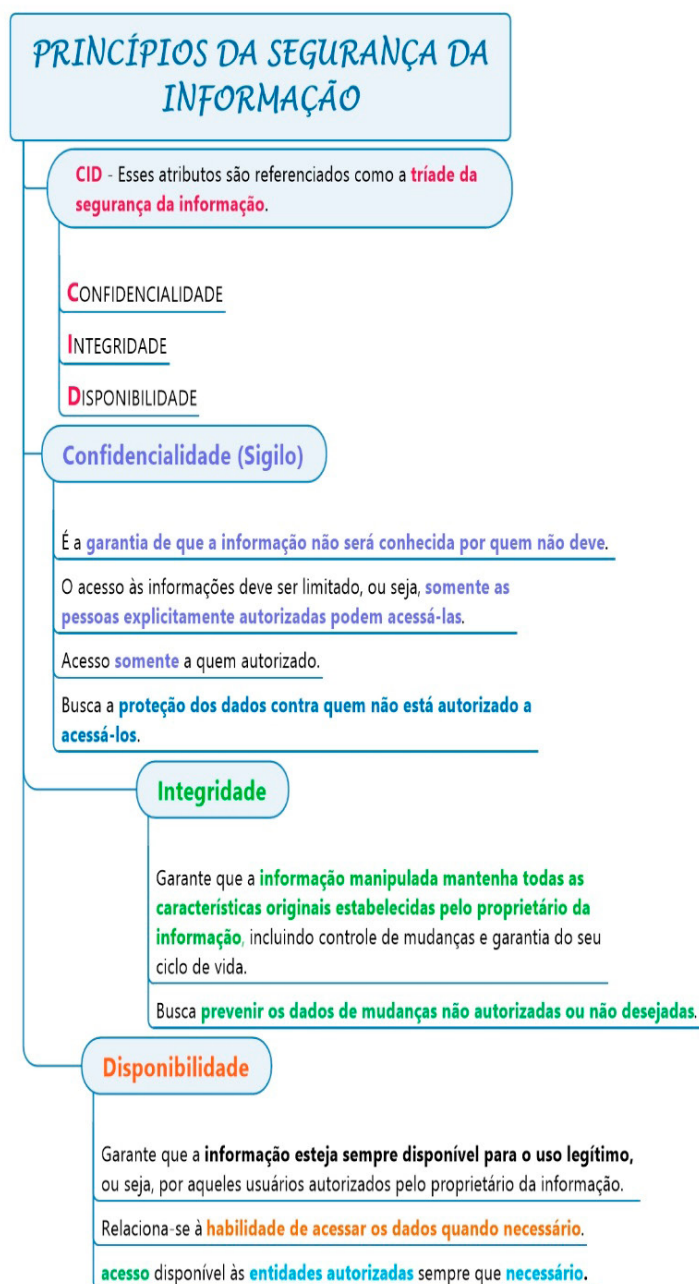
O objetivo da segurança da informação é fornecer a informação certa, para a pessoa certa, no momento correto. A violação de qualquer um desses princípios pode resultar em **incidentes de segurança** que afetam o negócio.

Obs.: Quando falamos em segurança da informação, estamos nos referindo a **medidas para manter a confidencialidade, integridade, disponibilidade e demais aspectos da segurança das informações dentro das necessidades do cliente!**

Portanto, a segurança da informação possui o objetivo de garantir alguns **princípios ou propriedades básicas**, quais sejam:

Princípio básico	Conceito	Objetivo
Confidencialidade	Propriedade de que a informação não esteja disponível ou revelada a indivíduos, entidades ou processos não autorizados.	Proteger contra o acesso não autorizado, mesmo para dados em trânsito.
Integridade	Propriedade de salvaguarda da exatidão e completeza de ativos	Proteger informação contra modificação sem permissão; garantir a fidedignidade das informações.
Disponibilidade	Propriedade de estar acessível e utilizável sob demanda por uma entidade autorizada	Proteger contra indisponibilidade dos serviços (ou degradação); garantir aos usuários com autorização, o acesso aos dados.

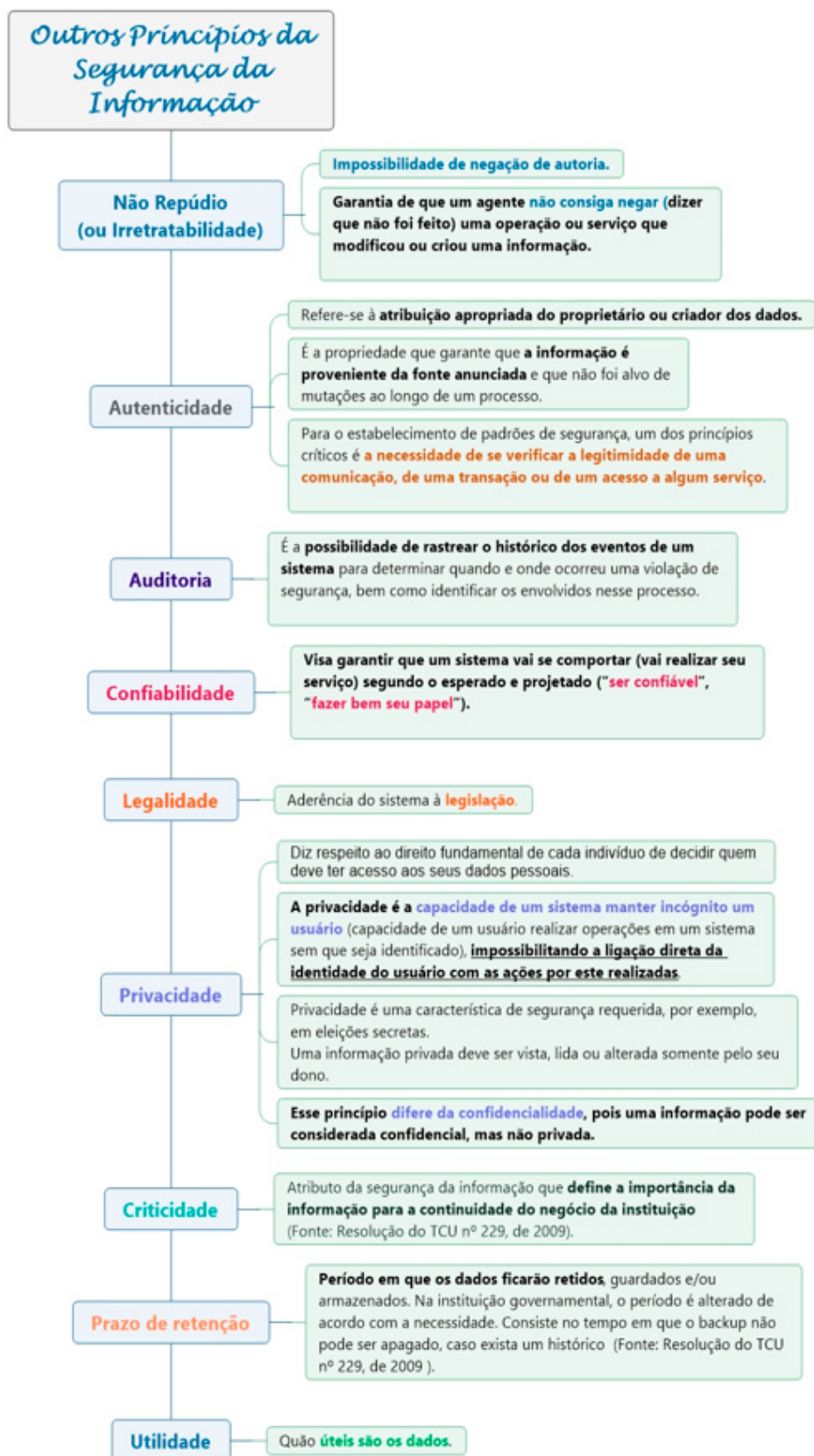
Princípios da segurança da informação



Fonte: Elaboração própria (2024).

Outros **princípios** podem ainda ser também levados em consideração, como:

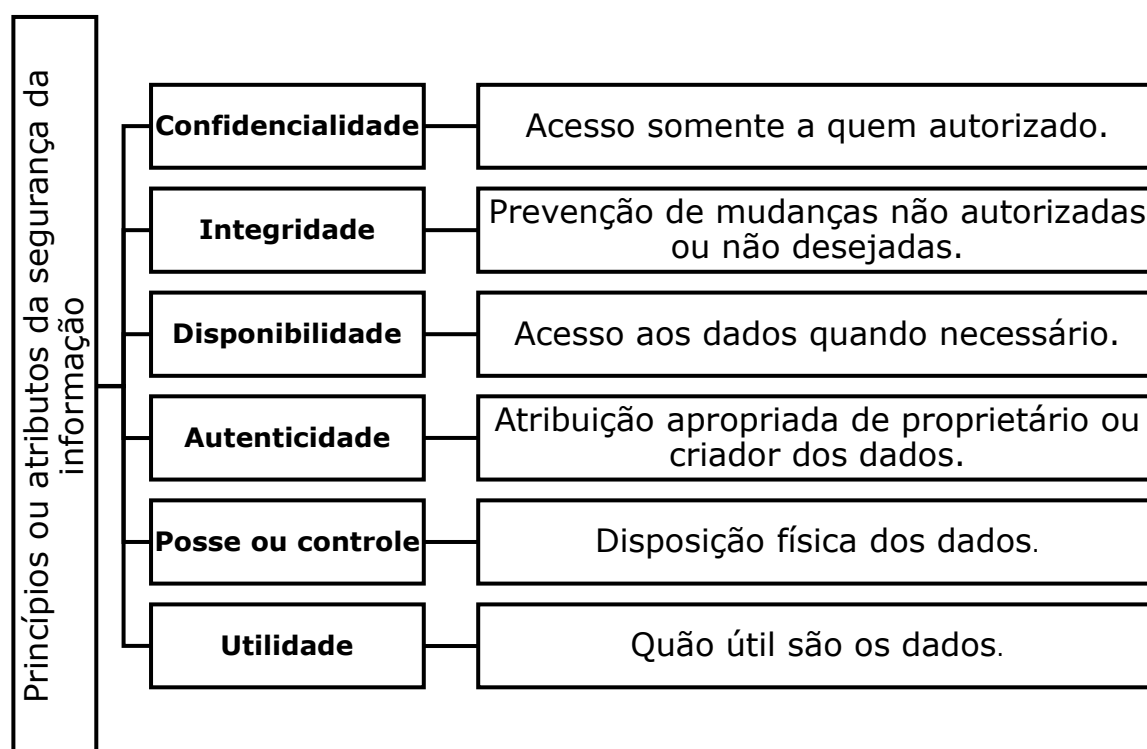
Não repúdio (ou irretratabilidade)	Proteção contra negação de envio (ou recepção) de determinada informação. É a garantia de que um agente não consiga negar (dizer que não foi feito) uma operação ou serviço que modificou ou criou uma informação. Tal garantia é condição necessária para a validade jurídica de documentos e transações digitais. Só se pode garantir o não repúdio quando houver autenticidade e integridade (ou seja, quando for possível determinar quem mandou a mensagem e garantir que a mesma não foi alterada).
Confiabilidade	Visa garantir que um sistema vai se comportar (vai realizar seu serviço) segundo o esperado e projetado ("ser confiável", "fazer bem seu papel"). Condição em que um sistema de informação presta seus serviços de forma eficaz e eficiente, ou melhor, um sistema de informação irá "desempenhar o papel que foi proposto para si".
Posse ou Controle	Relaciona-se com a propriedade ou controle dos dados. A perda de controle sobre os dados pode ser prejudicial mesmo que não sejam confidenciais, tal como um artista deve manter controle sobre sua pintura para reter os direitos sobre ela.
Autenticidade	Garante que a informação é proveniente da fonte anunciada e que não foi alvo de mutações ao longo de um processo. Refere-se à atribuição apropriada do proprietário ou criador dos dados. Verifica a veracidade da origem dos dados, garantindo o que os dados, pessoas ou transações são autênticos, da mesma forma que a autenticidade de uma pintura é verificada por especialistas.
Utilidade	Quão útil são os dados. Garante que os dados sejam úteis e relevantes, e que possam ser facilmente compreendidos e utilizados, semelhante a um mapa atualizado e legível que é necessário para navegar por uma cidade.



O **Hexagrama Parkeriano** é considerado uma evolução do modelo tradicional da Tríade da Segurança da Informação (CIA), proposto por Donn B. Parker, pois inclui mais três atributos aos da tríade CIA. Os **atributos do hexagrama Parkeriano** são os seguintes:

1. Confidencialidade;
2. Integridade;
3. Disponibilidade;
- 4. Posse ou controle;**
- 5. Autenticidade;**
- 6. Utilidade**

Veja uma descrição sobre cada um deles.



MALWARES (SOFTWARES MALICIOSOS)

Malware (combinação de *malicious software* – programa malicioso) é um termo genérico, usado para todo e quaisquer *softwares* maliciosos, programados com o intuito de prejudicar os sistemas de informação, alterar o funcionamento de programas, roubar informações, causar lentidões de redes computacionais etc.

São programas que executam deliberadamente ações mal-intencionadas em um computador.

Veja como *malwares* podem infectar ou comprometer um computador:

- por meio da **exploração de vulnerabilidades** (falhas de segurança), existentes nos programas instalados;
- por meio da **auto-execução de mídias removíveis infectadas**, como *pen-drives*;
- pelo **acesso a páginas da Web maliciosas**, com a utilização de navegadores vulneráveis;
- por meio da **ação direta de atacantes** que, após invadirem o computador, incluem arquivos contendo códigos maliciosos;
- pela **execução de arquivos previamente infectados**, obtidos em anexos de mensagens eletrônicas, via mídias removíveis, em páginas Web ou diretamente de outros computadores (através do compartilhamento de recursos).

Uma vez instalados, os códigos maliciosos passam a ter acesso aos dados armazenados no computador e podem executar ações em nome dos usuários, de acordo com as permissões de cada usuário.

Os tipos mais comuns de *malware*:

- vírus,
- worms,
- bots,
- cavalos de troia (trojans),
- ransomwares,
- spyware,
- keylogger,
- screenlogger,
- backdoors,
- doxware,
- rootkits etc.

VÍRUS

Códigos de programação maliciosos que se “agregam” a arquivos e são transmitidos com eles. Quando o arquivo é aberto na memória RAM, o vírus também é, e, a partir daí se propaga infectando, isto é, inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos de um computador.

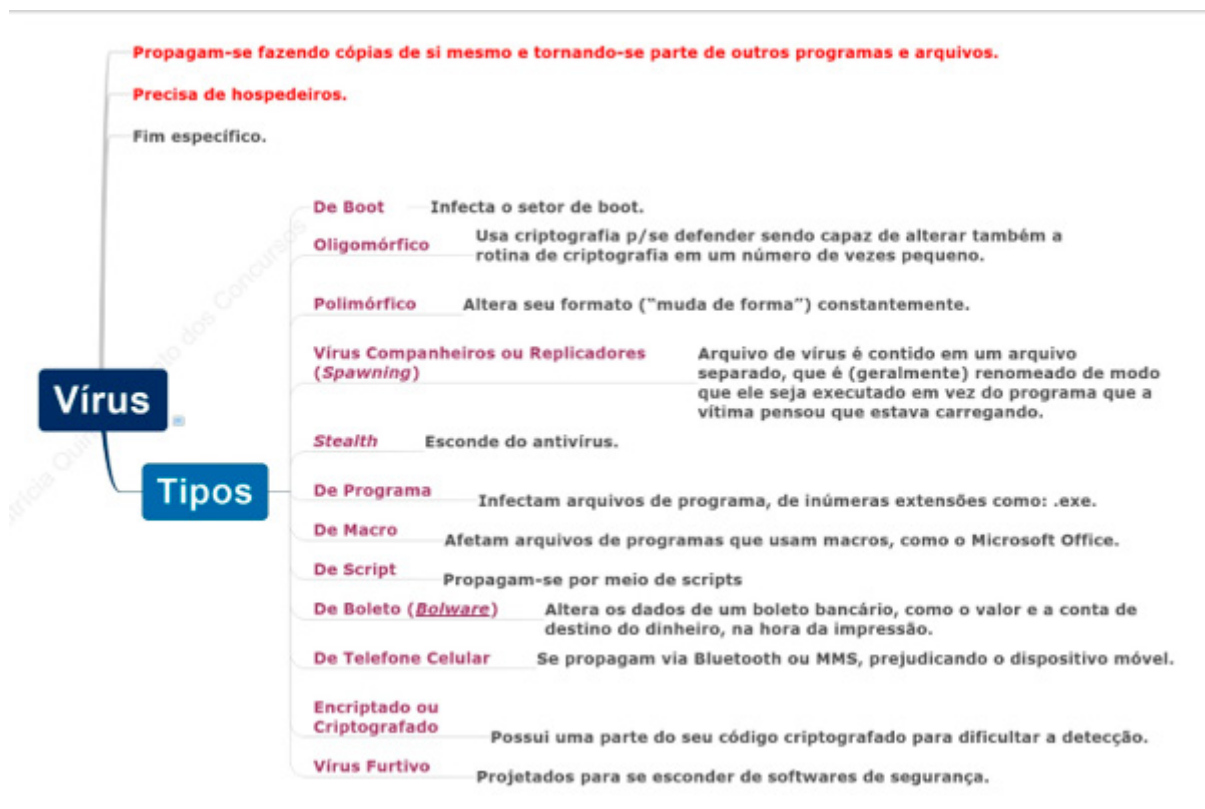
O vírus **depende da execução do programa ou arquivo hospedeiro** para que possa se tornar ativo e dar continuidade ao processo de infecção. Alguns vírus são inofensivos, outros, porém, podem danificar um sistema operacional e os programas de um computador.

Exemplos de arquivos que podem ser **portadores de vírus de computador**:

- **arquivos executáveis:** com extensão.exe ou.com; arquivos de *scripts* (outra forma de executável): extensão.vbs;
- **atalhos:** extensão.lnk ou.pif; **proteção de tela** (animações que aparecem automaticamente quando o computador está ocioso): extensão.scr;
- **documentos do MS-Office:** como os arquivos do Word (extensão.doc,.docx,.dot etc.), arquivos do Excel (.xls,.xlsx,.xlt, etc.), apresentações do Powerpoint (.ppt,.pptx,.pps, etc.), bancos de dados do Access (.mdb etc.). Arquivos multimídia do Windows Media Player: músicas com extensão.WMA, vídeos com extensão.WMV, dentre outros.

Principais **TIPOS de vírus:**

Vírus Polimórficos	Alteram seu formato (“mudam de forma”) constantemente para evitar detecção por antivírus. A cada nova infecção, esses vírus geram uma nova sequência de bytes em seu código, para que o antivírus se confunda na hora de executar a varredura e não reconheça o invasor.
Vírus Oligomórfico	Usa a criptografia para se defender sendo capaz de alterar também a rotina de criptografia em um número de vezes pequeno. Um vírus que possui duas rotinas de criptografia é então classificado como oligomórfico (LUPPI, 2006).
Vírus de Setor de Carga (Boot Setor) ou Vírus de Boot	Infectam o setor de boot (ou MBR – <i>Master Boot Record</i> – Registro Mestre de Inicialização) dos discos rígidos.
Vírus de Macro	Infectam documentos que contém macros (conjunto de comandos que são armazenados em alguns aplicativos e utilizados para automatizar tarefas repetitivas).
Vírus de Programa	Infectam arquivos de programa (de inúmeras extensões, como.exe,.com,.vbs,.pif).
Vírus de Script	Propagam-se por meio de scripts , nome que designa uma sequência de comandos previamente estabelecidos e que são executados automaticamente em um sistema, sem necessidade de intervenção do usuário. Dois tipos de scripts muito usados são os projetados com as linguagens Javascript (JS) e Visual Basic Script (VBS). Tanto um quanto o outro podem ser inseridos em páginas Web e interpretados por navegadores como Internet Explorer e outros. Assim como as macros, os <i>scripts</i> não são necessariamente maléficis.
Vírus Encriptado (Vírus Criptografado)	Possui uma parte do seu código criptografado para dificultar a detecção.
Vírus Furtivos	Projetados para se esconder de softwares de segurança.
Vírus de Boleto (Bolware)	Altera os dados de um boleto bancário.



WORMS

Programas parecidos com vírus, mas que na verdade **são capazes de se propagarem automaticamente através de redes, enviando cópias de si mesmo de computador para computador** (observe que os *worms* APENAS se copiam, **não** infectam outros arquivos, eles mesmos são os arquivos). Além disso, geralmente utilizam as redes de comunicação para infectar outros computadores (via *e-mails*, Web, FTP, redes das empresas etc.).

Diferentemente do vírus, **o worm NÃO embute cópias de si mesmo em outros programas ou arquivos e NÃO necessita ser explicitamente executado para se propagar**. Sua propagação se dá através da exploração de vulnerabilidades existentes ou falhas na configuração de softwares instalados em computadores.

Worms são notadamente responsáveis por consumir muitos recursos. **Degradam sensivelmente o desempenho de redes** e podem lotar o disco rígido de computadores, devido à grande quantidade de cópias de si mesmo que costumam propagar. Além disso, podem gerar grandes transtornos para aqueles que estão recebendo tais cópias.

O PULO DO GATO



Vírus e worms são tipos de malware, mas diferem significativamente em seu comportamento e propagação.

BOTS (“ROBÔS”)

De modo similar ao *worm*, é um programa capaz de se propagar automaticamente, explorando vulnerabilidades existentes ou falhas na configuração de software instalado em um computador.

Adicionalmente ao *worm*, dispõe de mecanismos de comunicação com o invasor, permitindo que o *bot* seja controlado remotamente. Os *bots* esperam por comandos de um *hacker*, podendo manipular os sistemas infectados, sem o conhecimento do usuário.

Bot: tipo de Worm que dispõe de mecanismos de comunicação com o invasor, permitindo que este seja controlado remotamente.

Segundo CertBr (2012), a **comunicação** entre o invasor e o computador pelo *bot* pode ocorrer **via canais de IRC, servidores Web, redes do tipo P2P** etc. Ao se comunicar, o invasor pode enviar instruções para que **ações maliciosas** sejam executadas, **como desferir ataques, furtar dados do computador infectado e enviar spam**.

Nesse ponto, cabe destacar um termo que já foi cobrado várias vezes em prova! Trata-se do significado de **botnet**, junção da contração das palavras **robot (bot) e network (net)**.

Obs.: Uma rede infectada por *bots* é denominada de **botnet** (também conhecida como **REDE ZUMBI**), sendo composta geralmente por milhares desses elementos maliciosos, que ficam residentes nas máquinas, aguardando o comando de um invasor. Podem ser usadas em atividades de negação de serviço, envio de spam etc.

Quanto mais **zumbis** (*Zombie Computers*) participarem da *botnet*, mais potente ela será. Um invasor que tenha controle sobre uma *botnet* pode utilizá-la para:

- **coletar informações** de um grande número de computadores;
- **“clicar” em anúncios** e gerar receitas fraudulentas;
- **enviar spam** em grande escala;
- **hospedar sites de phishing**;
- **iniciar ataques de negação de serviço** que impedem o uso de serviços online etc.

TROJAN HORSE (CAVALO DE TROIA)

Um programa aparentemente inofensivo que entra no computador na forma de cartão virtual, protetor de tela, jogo etc., e que, quando executado (com a autorização do usuário!), parece lhe divertir, mas, por trás abre portas de comunicação na máquina computador para que ela possa ser invadida.

Obs.: Por definição, o Cavalo de Troia distingue-se de um vírus ou de um worm por **NÃO** infectar outros arquivos, **NEM** propagar cópias de si mesmo automaticamente.

Os trojans atuais são divididos em duas partes, que são: o **servidor** e o **cliente**.

Servidor	Normalmente, o servidor encontra-se oculto em algum outro arquivo e, no momento em que o arquivo é executado, o servidor se instala e se oculta no computador da vítima.
Cliente	Nesse momento, o computador já pode ser acessado pelo cliente, que enviará informações para o servidor executar certas operações no computador da vítima.

Uma das características do Cavalo de Troia (*Trojan Horse*) é que ele facilita ação de outros ataques!

Cavalo de Troia de acesso remoto é um programa que permite ao atacante acessar remotamente o equipamento da vítima e executar ações como se fosse o usuário legítimo, **combinando, assim, as características de cavalo de Troia e backdoor**.

Obs.: O cavalo de troia não é um vírus, pois não se duplica e não se dissemina como os vírus. Na maioria das vezes, ele irá instalar programas para possibilitar que um invasor tenha controle total sobre um computador.

EXPLOITS

É um código criado para **explorar uma vulnerabilidade** existente em um programa. Um **exploit kit** reúne e empacota esses códigos para que sejam de uso fácil e até comercializável entre criminosos. Esses kits **são usados na web para criar páginas maliciosas que, uma vez visitadas, conseguem contaminar o computador com algum vírus**.

SPYWARE

Programa espião (spy em inglês = espião) que tem por finalidade monitorar as atividades de um sistema e enviar as informações coletadas para terceiros.

Obs.: Conforme ABNT ISO/IEC 27000, **Spyware** é um software **enganador que coleta informações particulares ou confidenciais de um usuário de computador**. Informações podem incluir assuntos como websites mais visitados ou informações mais sensíveis, como senhas.

Pode ser usado tanto de forma legítima quanto maliciosa, dependendo de como é instalado, das ações realizadas, do tipo de informação monitorada e do uso que é feito por quem recebe as informações coletadas.

Legítimo	Quando instalado em um computador pessoal, pelo próprio dono ou com consentimento deste, com o objetivo de verificar se outras pessoas o estão utilizando de modo abusivo ou não autorizado.
Malicioso	quando executa ações que podem comprometer a privacidade do usuário e a segurança do computador, como monitorar e capturar informações referentes à navegação do usuário ou inseridas em outros programas (por exemplo, conta de usuário e senha).

Alguns tipos específicos de programas *spyware* são:

KEYLOGGER (COPIA AS TECLAS DIGITADAS!)

É capaz de **capturar e armazenar as teclas digitadas pelo usuário no teclado de um computador**.

Dentre as informações capturadas podem estar o texto de um *e-mail*, dados digitados na declaração de Imposto de Renda e outras informações sensíveis, como senhas bancárias e números de cartões de crédito. Em muitos casos, a ativação do *keylogger* é condicionada a uma ação prévia do usuário, como por exemplo, após o acesso a um *site* específico de comércio eletrônico ou Internet Banking. Normalmente, o *keylogger* contém mecanismos que permitem o envio automático das informações capturadas para terceiros (por exemplo, através de *e-mails*).

SCREENLOGGERS (COPIA AS TELAS ACESSADAS!)

As instituições financeiras desenvolveram os teclados virtuais para evitar que os *keyloggers* pudessem capturar informações sensíveis de usuários. Então, foram desenvolvidas formas mais avançadas de *keyloggers*, também conhecidas como ***screenloggers*** capazes de: **armazenar a posição do cursor e a tela apresentada no monitor, nos momentos em que o mouse é clicado, ou armazenar a região que circunda a posição onde o mouse é clicado**.

Normalmente, o *keylogger* vem como parte de um programa *spyware* ou cavalo de troia. Desta forma, é necessário que este programa seja executado para que o *keylogger* se instale em um computador.

Geralmente, tais programas vêm anexados a *e-mails* ou estão disponíveis em *sites* na Internet. Existem ainda programas leitores de *e-mails* que podem estar configurados para executar automaticamente arquivos anexados às mensagens. Neste caso, o simples fato de ler uma mensagem é suficiente para que qualquer arquivo anexado seja executado.

TRACKWARE (RASTREIAM A ATIVIDADE DO SISTEMA)

São programas que **rastreiam a atividade do sistema**, reúnem informações do sistema ou rastreiam os hábitos do usuário, retransmitindo essas informações a organizações de terceiros.

As informações reunidas por esses programas não são confidenciais nem identificáveis. Os programas de *trackware* são instalados com o consentimento do usuário e também podem estar contidos em pacotes de outro software instalado pelo usuário.

ADWARE (ADVERTISING SOFTWARE) (EXIBE PROPAGANDAS!)

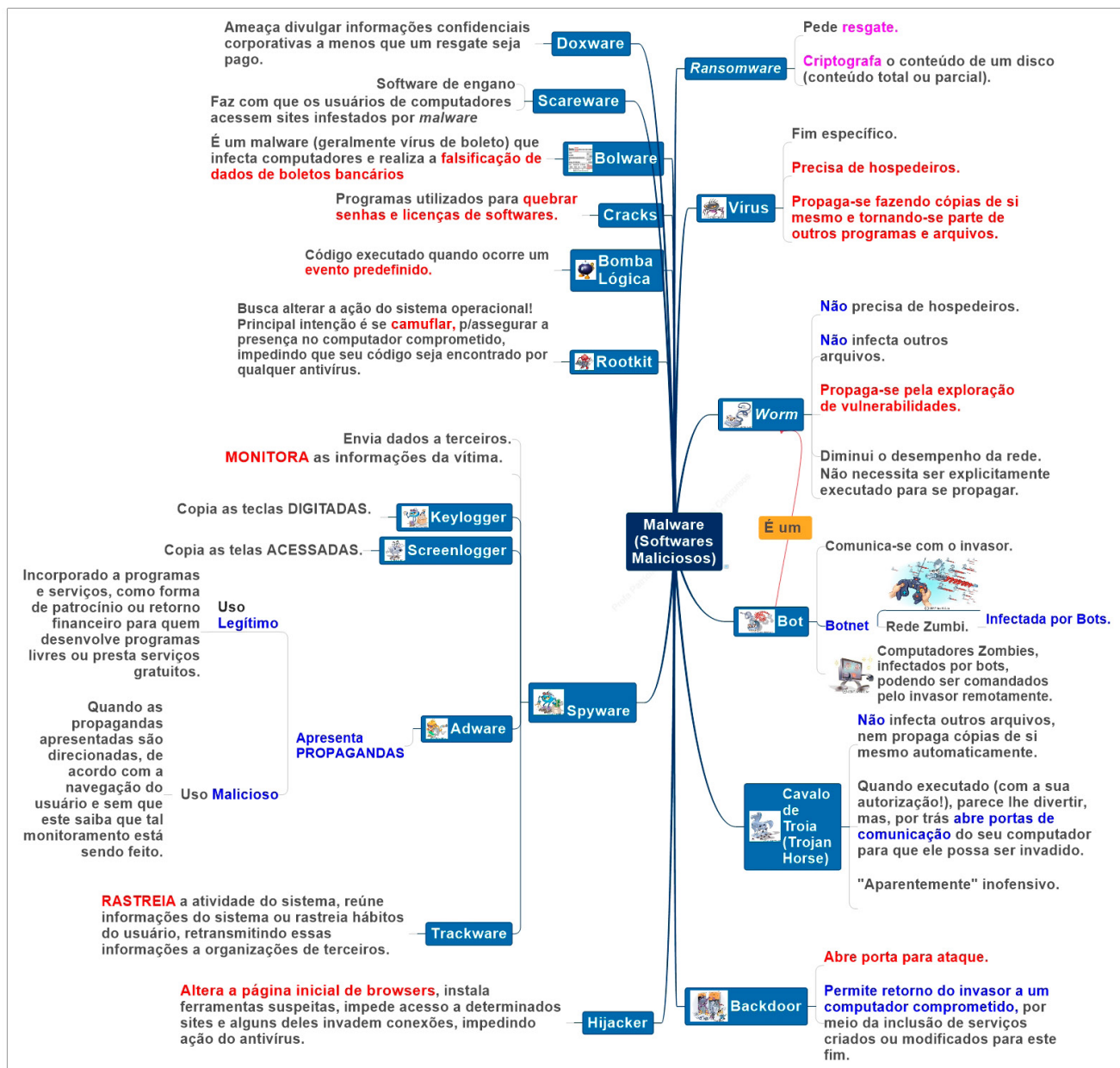
Projetado especificamente para **apresentar propagandas**.

Este tipo de programa geralmente não prejudica o computador. Cert.Br (2103) destaca que ele pode ser usado para fins legítimos, quando incorporado a programas e serviços, como forma de patrocínio ou retorno financeiro para quem desenvolve programas livres ou presta serviços gratuitos.

Quando o seu uso é feito de forma maliciosa, pode abrir uma janela do navegador apontando para páginas de cassinos, vendas de remédios, páginas pornográficas etc. Também as propagandas apresentadas podem ser direcionadas, de acordo com a navegação do usuário e sem que este saiba que tal monitoramento está sendo realizado.

Obs.: Segundo a norma ABNT ISO/IEC 27000, **adware** é um **aplicativo que joga publicidade para os usuários e/ou reúne informações sobre o comportamento *on line* do usuário**. O aplicativo pode ou não ser instalado com o conhecimento ou consentimento do usuário, ou ser forçado para o usuário através de termos de licenciamento para outro software.

Malware



Fonte: Elaboração própria (2024).

RANSOMWARE (PEDE RESGATE!)

O termo vem da palavra "**resgate**" em inglês (*ransom*) unida ao sufixo de **malware**. Cibercriminosos **sequestram** os dados salvos no equipamento e exigem um **resgate** para liberar o acesso a eles. Cifram esses dados usando **alta criptografia** "impossível" de ser quebrada.

São softwares maliciosos que, ao infectarem um computador, **criptografam todo ou parte do conteúdo do disco rígido**. Os responsáveis pelo software exigem da vítima, um pagamento pelo “resgate” dos dados.

- **Crypto Ransomware:** **criptografa** arquivos;
- **Locker Ransomware:** **bloqueia o acesso** ao dispositivo.

O **Pagamento de resgates** é feito via **bitcoin (moeda virtual anônima)**, cartões pré-pagos (Amazon, iTunes etc.), sendo que o preço do resgate pode variar. Exemplo: usuário doméstico (50 a 300 dólares), empresas (de 500 a 4000 dólares). No entanto, **o pagamento do resgate não garante que você conseguirá restabelecer o acesso!**

Alvo dos ransomwares: planilhas, documentos, banco de dados, arquivos de texto, imagens, programas financeiros, projetos (AutoCad), etc. **Além de infectar o equipamento o ransomware também costuma buscar outros dispositivos conectados, locais ou em rede, e criptografá-los também.**

Métodos de infecção por ransomware:

- arquivos maliciosos em *e-mail* (inclui PDF, DOC etc.);
- explorando falhas de sistemas não atualizados;
- *exploit kits* instalados em sites infectados;
- disseminados pela rede, em unidades compartilhadas;
- servidores: acesso remoto (RDP, VNC etc.).

Para se proteger de ransomware você deve tomar os mesmos cuidados que toma para evitar os outros códigos maliciosos, como ter um antivírus instalado e ser cuidadoso ao clicar em *links* ou abrir arquivos. **Fazer backups regularmente** também é essencial para proteger os seus dados pois, se seu equipamento for infectado, a única solução realmente efetiva para acessá-los novamente é buscá-los em seus *backups*.

BACKDOORS (ABRE PORTAS!)

Normalmente, um atacante procura garantir uma forma de retornar a um computador comprometido, sem precisar recorrer aos métodos utilizados na realização da invasão. Na maioria dos casos, também é intenção do atacante poder retornar ao computador comprometido sem ser notado. **A esses programas que permitem o retorno de um invasor a um computador comprometido, utilizando serviços criados ou modificados para este fim, dá-se o nome de *backdoor*.**

A forma usual de inclusão de um *backdoor* consiste na disponibilização de um novo serviço ou substituição de um determinado serviço por uma versão alterada, normalmente possuindo recursos que permitam acesso remoto (através da Internet). Pode ser incluído por um invasor ou através de um cavalo de troia.

Programas de administração remota, como BackOrifice, NetBus, Sub-Seven, VNC e Radmin, se mal configurados ou utilizados sem o consentimento do usuário, também podem ser classificados como *backdoors*.

SCAREWARE (SOFTWARE DE ENGANO, SOFTWARE DE VERIFICAÇÃO DESONESTO OU FRAUDWARE)

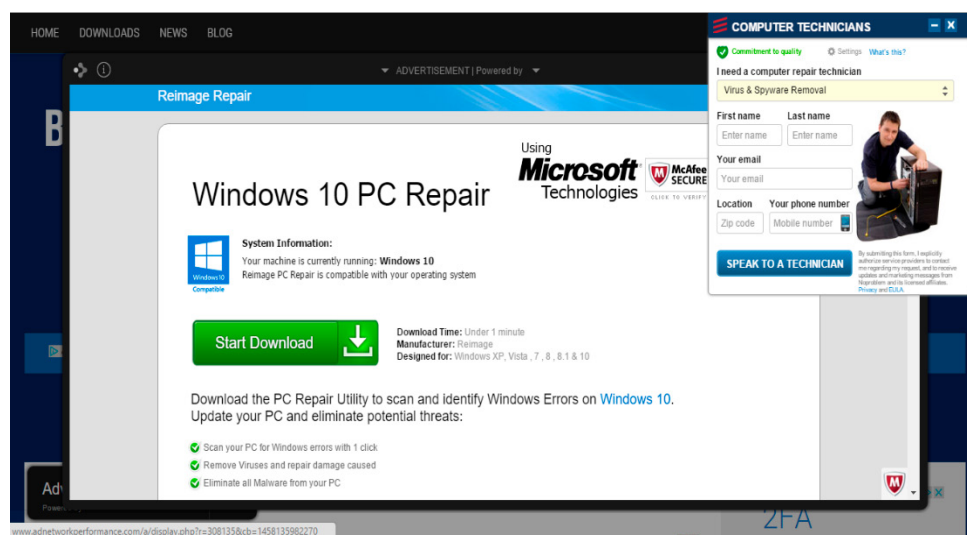
É um **software malicioso que faz com que os usuários de computadores acessem sites infestados por malware**.

Scareware: gera alertas falsos de infecções para persuadir pagamentos.

O *scareware* pode vir na forma de caixas suspensas. Elas aparecem como “avisos legítimos” de empresas de software antivírus, alegando que os arquivos de seu computador foram infectados.

São tão habilmente criados que os usuários ficam assustados e pagam uma taxa para adquirir rapidamente um *software* que irá resolver o suposto problema. Mas o que eles acabam baixando é um falso software antivírus que na verdade é um *malware* destinado a roubar os dados pessoais da vítima.

Exemplo de mensagem suspeita



Fonte: <https://www.windowsteam.com.br/windows-defender-vai-por-um-fim-nos-chatissimos-scarewares/>. Acesso em: jan./2019.

DOXWARE (AMEAÇA DIVULGAR INFORMAÇÕES SE NÃO FOR PAGO O RESGATE)

Ameaça divulgar informações confidenciais corporativas a menos que um resgate seja pago.

BOLWARE (VÍRUS DE BOLETO)

É um **malware (geralmente vírus de boleto)** que infecta computadores e realiza a falsificação de dados de boletos bancários, realizando determinadas mudanças no documento, alterando muitas vezes a conta em que o valor será depositado, criando problemas para o usuário que – sem saber – perde o valor do pagamento realizado, como também para as empresas que iriam receber o pagamento.

Verifique em todo boleto impresso se o número do banco (3 primeiros dígitos da linha digitável) corresponde ao banco emissor do boleto. **A maioria dos vírus costuma trocar o banco, apesar de alguns poucos preservarem o banco original que emitiu o boleto.**

Confira o campo “Nosso número” no boleto, ele deve estar presente na linha digitável, caso contrário é provável que o boleto foi adulterado.

Itaú						34191.09099 14659.820048 50860.890008 5 61820000089769					
Local de Pagamento						Vencimento					
ATÉ O VENCIMENTO PAGUE PREFERENCIALMENTE NO ITAÚ OU ITAÚ VAREJO						10/09/2014					
Beneficiário						Agência / Código Beneficiário					
						0045/08008-0					
Data do Documento	Nº do Documento	Especie Doc.	Acerto	Data de processamento	Nosso Número						
26/08/2014	000021	RC	N		109/09146598-2						
Uso do Banco	Carteira	Especie	Quantidade	Valor	Valor do Documento						
	109	R\$			897,60						

Boleto verdadeiro: campos que devem ser verificados

BANCO DO BRASIL						001-9 34191.75009 01847.110945 63175.340007 1 62130000004469					
Local de Pagamento						Vencimento					
Banco do Brasil S.A						16/09/2014					
Pagável preferencialmente em qualquer Agência Banco do Brasil											
Cedente						Agência/Código Cedente					
Americanas.com - B2W - CIA Global do Varejo						3070-8/15300-1					
Data Documento	Numero do Documento	Especie Doc.	Acerto	Data Processamento	Nosso Número						
11/09/2014	577222583	Outro	N	11/09/2014	25977310577222583						
Uso do Banco	Carteira	Especie	Quantidade	Valor	Valor do Documento						

Boleto falso: campo "Nosso número" diferente no código de barras

Se precisar reemitir um boleto bancário ou recalculá-lo, **use o site do Banco, jamais use um site desconhecido.**

Caso o código de barras esteja ilegível na hora do pagamento, **desconfie** do boleto e **NÃO PAGUE**, busque certificar-se de que o mesmo não tenha sido alterado.

ROOTKIT (BUSCA ALTERAR A AÇÃO DO SISTEMA OPERACIONAL!)

Tipo de *malware* cuja **principal intenção é se camuflar, para assegurar a sua presença no computador comprometido, impedindo que seu código seja encontrado por qualquer antivírus**. Isto é possível porque tem a capacidade de interceptar as solicitações feitas ao sistema operacional, podendo alterar o seu resultado.

O invasor, após instalar o *rootkit*, terá acesso privilegiado ao computador previamente comprometido, sem precisar recorrer novamente aos métodos utilizados na realização da invasão e suas atividades serão escondidas do responsável e/ou dos usuários do computador.

Um *rootkit* pode fornecer programas com as mais diversas **funcionalidades**. Dentre eles, merecem destaque:

- **programas para esconder atividades e informações** deixadas pelo invasor, tais como arquivos, diretórios, processos etc.;
- ***backdoors***, para assegurar o acesso futuro do invasor ao computador comprometido;
- **programas para remoção de evidências em arquivos de logs**;
- ***sniffers***, para capturar informações na rede onde o computador está localizado, como por exemplo senhas que estejam trafegando em claro, ou seja, sem qualquer método de criptografia;
- ***scanners***, para mapear potenciais vulnerabilidades em outros computadores.

A tabela seguinte apresenta um comparativo interessante relacionado aos *malwares*:

Resumo comparativo entre códigos maliciosos

	Vírus	Worm	Bot	Trojan	Spyware	Backdoor	Rootkit
Como é obtido:							
Recebido automaticamente pela rede		✓	✓				
Recebido por e-mail	✓	✓	✓	✓	✓		
Baixado de sites na Internet	✓	✓	✓	✓	✓		
Compartilhamento de arquivos	✓	✓	✓	✓	✓		
Uso de mídias removíveis infectadas	✓	✓	✓	✓	✓		
Redes sociais	✓	✓	✓	✓	✓		
Mensagens instantâneas	✓	✓	✓	✓	✓		
Inserido por um invasor		✓	✓	✓	✓	✓	✓
Ação de outro código malicioso		✓	✓	✓	✓	✓	✓
Como ocorre a instalação:							
Execução de um arquivo infectado	✓						
Execução explícita do código malicioso		✓	✓	✓	✓		
Via execução de outro código malicioso						✓	✓
Exploração de vulnerabilidades		✓	✓			✓	✓
Como se propaga:							
Insere cópia de si próprio em arquivos	✓						
Envia cópia de si próprio automaticamente pela rede		✓	✓				
Envia cópia de si próprio automaticamente por e-mail		✓	✓				
Não se propaga				✓	✓	✓	✓
Ações maliciosas mais comuns:							
Altera e/ou remove arquivos	✓			✓			✓
Consome grande quantidade de recursos		✓	✓				
Furta informações sensíveis			✓	✓	✓		
Instala outros códigos maliciosos		✓	✓	✓			✓
Possibilita o retorno do invasor						✓	✓
Envia spam e phishing			✓				
Desfere ataques na Internet		✓	✓				
Procura se manter escondido	✓				✓	✓	✓

Fonte: CertBr. Disponível em: <http://cartilha.cert.br/malware/>.

CRACK (QUEBRA SENHAS E LICENÇAS DE SOFTWARES)

Programas utilizados para **quebrar senhas e licenças de softwares**. São encontrados facilmente na Internet, mas em sites que não são merecedores de confiança.

SNIFFERS (FAREJADORES OU CAPTURADORES DE PACOTES)

Por padrão, os computadores (pertencentes à mesma rede) escutam e respondem somente pacotes endereçados a eles. Entretanto, é possível utilizar um software que coloca a interface num estado chamado de **modo promíscuo**. Nessa condição **o computador pode monitorar e capturar os dados trafegados através da rede, não importando o seu destino legítimo. Os programas responsáveis por capturar os pacotes de rede são chamados Sniffers, Farejadores ou ainda Capturadores de Pacote**. Eles exploram o fato do tráfego dos pacotes das aplicações TCP/IP não utilizar nenhum tipo de cifragem nos dados.

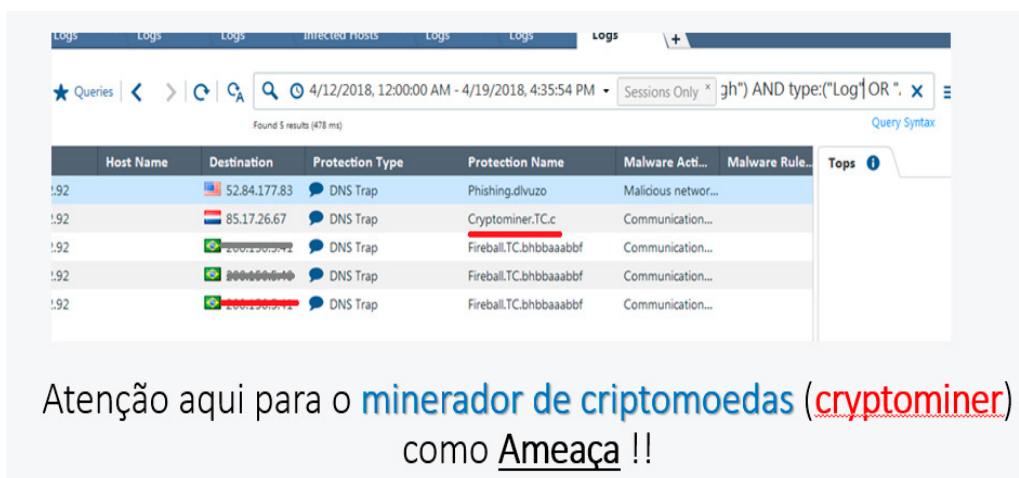
Dessa maneira um *sniffer* atua na rede “farejando pacotes” na tentativa de encontrar certas informações (trata-se de um malware quando fareja pacotes da rede em busca de informações **não autorizadas**), como nomes de usuários, senhas ou qualquer outra informação transmitida que não esteja criptografada.

A dificuldade no uso de um *sniffer* é que o atacante precisa instalar o programa em algum ponto estratégico da rede, como entre duas máquinas, (com o tráfego entre elas passando pela máquina com o farejador) ou em uma rede local com a interface de rede em modo promíscuo.

APT (ADVANCED PERSISTENT THREAT – AMEAÇA PERSISTENTE AVANÇADA)

Comumente usada para se referir a ameaças cibernéticas, em particular a prática de espionagem via internet por intermédio de uma variedade de técnicas de coleta de informações que são consideradas valiosas o suficiente para que o agente espião despenda tempo e recursos para obtê-las.

Anti-bots/Anti-apt: novas ferramentas de proteção contra ameaças desse tipo!



Atenção aqui para o **minerador de criptomoedas (cryptominer)** como **Ameaça !!**

Criptojacking é um tipo de ataque que consiste no roubo do processamento de computadores para minerar criptomoedas ilegalmente.

DIRETO DO CONCURSO



001. (CESPE/PM-MA/2018/ADAPTADA) A seguir são apresentadas três situações hipotéticas.

I – Um usuário, após sequestro de seus dados, recebeu a informação de que, para reavê-los, seria necessário realizar um pagamento ao sequestrador.

II – Um usuário recebeu informação, por meio do setor de segurança da informação do seu órgão, de que seu computador, sem seu conhecimento, havia sido usado em um ataque a uma rede de outro órgão.

III – Em um dado momento do dia, um usuário notou que sua máquina estava consumindo mais recursos de memória do que o habitual e, ao executar no computador um programa de proteção, obteve a seguinte mensagem: “arquivo xpto infectado com o worm xyz”.

Com referência a essas situações hipotéticas e à segurança da informação, julgue o item subsequente.

A situação III caracteriza-se mais como vírus do que como um worm, pois os vírus são responsáveis por consumir muitos recursos, ao passo que os *worms* permitem o retorno de um invasor ao computador comprometido.



O **backdoor** (porta dos fundos) é um programa que, colocado no micro da vítima, cria uma ou mais falhas de segurança, para permitir que o invasor que o colocou possa facilmente “voltar” àquele computador em um momento seguinte.

Worms são programas parecidos com vírus, mas que na verdade são capazes de se propagarem automaticamente através de redes, enviando cópias de si mesmo de computador para computador (observe que os *worms* apenas se copiam, não infectam outros arquivos, eles mesmos são os arquivos!).

Diferentemente do vírus, o *worm* não embute cópias de si mesmo em outros programas ou arquivos e não necessita ser explicitamente executado para se propagar. Sua propagação se dá através da exploração de vulnerabilidades existentes ou falhas na configuração de softwares instalados em computadores. Os *worms* são responsáveis por consumir muitos recursos, ao passo que os *backdoors* permitem o retorno de um invasor ao computador comprometido. Assim, conforme visto, a banca trocou a definição de *worms* pela de *backdoors* nessa assertiva.

Errado.

002. (CESPE/TCE-PB/2018) Entre os vários tipos de programas utilizados para realizar ataques a computadores, aquele capaz de se propagar automaticamente pelas redes, enviando cópias de si mesmo entre computadores, é conhecido como

- a) botnet.
- b) spyware.
- c) backdoor.
- d) trojan.
- e) worm.



O **Worm** (“verme” autorreplicante) é um tipo de praga virtual (*malware*) **que se propaga automaticamente pelas redes de computadores, explorando vulnerabilidades** existentes nessas redes ou falhas na configuração de softwares instalados nos computadores dessas redes e enviando cópias de si mesmo de computador para computador.

Após realizado o envio da cópia, o *worm* necessita ser executado para que a infecção ocorra, o que pode acontecer de uma ou mais das seguintes maneiras:

- imediatamente após ter sido transmitido, pela exploração **automática** de vulnerabilidades em programas sendo executados no computador alvo no momento do recebimento da cópia. Observe que nesse caso, não é necessária uma ação do usuário;
- diretamente pelo usuário, pela execução de uma das cópias enviadas ao seu computador;
- pela realização de uma ação específica do usuário, a qual o *worm* está condicionado como, por exemplo, a inserção de uma mídia removível.

Letra e.

003. (CESPE/PC-MA/ESCRIVÃO DE POLÍCIA/2018) Determinado tipo de vírus eletrônico é ativado quando um documento por ele infectado é aberto, podendo então, nesse momento, infectar não apenas outros documentos, mas também um gabarito padrão de documento, de modo que cada novo documento criado sob esse gabarito seja infectado. Tal vírus, cuja propagação ocorre quando documentos por ele infectados são remetidos por correio eletrônico para outros usuários, é conhecido como

- a) vírus de setor de carga (*boot sector*).
- b) vírus de programa.
- c) vírus de macro.
- d) backdoor.
- e) hoax.



a) Errada. **Vírus de Setor de Carga (Boot Setor) ou Vírus de Boot infecta o setor de boot** (ou MBR – *Master Boot Record* – Registro Mestre de Inicialização) **dos discos rígidos.**

Obs.: O Setor de Boot do disco rígido é a primeira parte do disco rígido que é lida quando o computador é ligado. Essa área é lida pelo BIOS (programa responsável por “acordar” o computador) a fim de que seja encontrado o Sistema Operacional (o programa que vai controlar o computador durante seu uso).

b) Errada. **Infectam arquivos de programa** (de inúmeras extensões, como.exe,.com,.vbs,.pif).

c) Certa. **Um vírus de macro** é parte de um arquivo normalmente manipulado por algum aplicativo que utiliza macros e que, para ser executado, necessita que o arquivo que o contém esteja aberto para que ele execute uma série de comandos automaticamente e infecte outros arquivos no computador (Cespe/2010).

Macro: conjunto de comandos que são armazenados em alguns aplicativos e utilizados para automatizar tarefas repetitivas.

Existem alguns aplicativos que possuem arquivos base (**modelos – gabarito padrão de documentos**) que são abertos sempre que o aplicativo é executado. Caso este arquivo base seja infectado pelo vírus de macro, toda vez que o aplicativo for executado, o vírus também será. **Arquivos nos formatos gerados por programas da Microsoft, como o Word, Excel, Powerpoint e Access são os mais suscetíveis a este tipo de vírus.** Arquivos nos formatos RTF, PDF e PostScript são menos suscetíveis, mas isso não significa que não possam conter vírus.



Normal.dot=Principal alvo de vírus de macro p/Word

d) Errada. O **backdoor (porta dos fundos)** é um programa que, colocado no micro da vítima, cria uma ou mais falhas de segurança, para permitir que o invasor que o colocou possa facilmente “voltar” àquele computador em um momento seguinte.

e) Errada. **Hoaxes (boatos)** são as **histórias falsas recebidas por e-mail**, sites de relacionamentos e na Internet em geral, cujo conteúdo, além das conhecidas correntes, consiste em apelos dramáticos de cunho sentimental ou religioso, supostas campanhas filantrópicas, humanitárias ou de socorro pessoal ou, ainda, falsos vírus que ameaçam destruir, contaminar ou formatar o disco rígido do computador.

Letra c.

PRINCIPAIS GOLPES APLICADOS NA INTERNET

HOAXES (BOATOS)

São as **histórias falsas recebidas por e-mail, sites de relacionamentos, whatsapp e na Internet em geral**, cujo conteúdo, além das conhecidas correntes, consiste em apelos dramáticos de cunho sentimental ou religioso, supostas campanhas filantrópicas, humanitárias ou de socorro pessoal ou, ainda, falsos vírus que ameaçam destruir, contaminar ou formatar o disco rígido do computador.

Exemplos de hoax (boato)

Riqueza de Lulinha vai ser publicada na Veja neste final de semana #boato



Apesar dos holofotes voltados... [Read More »](#)

Boato – Em São Paulo, revista Veja lança neste final de semana matéria sobre a riqueza de Lulinha. Repasse! Hoje em dia, o mundo da boataria está cheio de gente que vive a filosofia do “nada se cria, tudo se copia”. Os boatos se transformam e cada vez com menos criatividade.

ENGENHARIA SOCIAL

Técnica de ataque utilizada para se obter informações sigilosas ou importantes de empresas e sistemas, enganando e **explorando a confiança dos usuários**.

PHISHING, SCAM OU PHISHING SCAM

Tipo de fraude que se dá por meio do **envio de mensagem não solicitada**, que se passa por comunicação de uma instituição conhecida, e que procura induzir o acesso a páginas fraudulentas (falsificadas), projetadas para furtar dados pessoais e financeiros de usuários desavisados.

Utilizando de pretextos falsos, tenta enganar o receptor da mensagem e induzi-lo a fornecer informações sensíveis (números de cartões de crédito, senhas, dados de contas bancárias etc.).

Atualmente, o termo vem sendo utilizado também para se referir aos seguintes casos:

- **páginas falsas de comércio eletrônico ou Internet Banking;**
- **páginas falsas de redes sociais** ou de companhias aéreas;

- **mensagem que, no próprio conteúdo, apresenta formulários** para o preenchimento e envio de dados pessoais e financeiros de usuários;
- **mensagens contendo links para instalação de códigos maliciosos;**
- **solicitação de recadastramentos** em que o usuário recebe uma mensagem, supostamente enviada pelo grupo de suporte da instituição de ensino que frequenta ou da empresa em que trabalha, informando que o serviço de *e-mail* está passando por manutenção e que é necessário o recadastramento. Para isto, é preciso que você forneça seus dados pessoais, como nome de usuário e senha.

SPEAR PHISHING

É um **golpe de e-mail direcionado com o objetivo único de obter acesso não autorizado aos dados sigilosos.**

Diferente dos golpes de *phishing*, que realizam ataques amplos e dispersos, o **spear phishing foca em um grupo ou organização específicos.** A intenção é roubar propriedade intelectual, dados financeiros, segredos comerciais ou militares e outros dados confidenciais.

Ele funciona da seguinte maneira: um *e-mail* é recebido, aparentemente de uma fonte confiável, no entanto ele leva o destinatário a um *site* falso cheio de *malware*. Esses *e-mails* costumam usar táticas inteligentes para chamar a atenção das vítimas. Por exemplo, o FBI alertou sobre golpes de *spear phishing*, nos quais os *e-mails* pareciam ser do National Center for Missing and Exploited Children.

Obs.: O ataque de spear phishing, que é uma tentativa de fraude por falsificação de e-mail, tem como alvo uma organização específica e objetiva, normalmente, conseguir acesso não autorizado a dados sigilosos (CESPE/2014/ANATEL).

PHARMING

É uma **técnica que utiliza o sequestro ou a “contaminação” do servidor DNS (Domain Name Server) para levar os usuários a um site falso, alterando o DNS do site de destino.** O sistema também pode redirecionar os usuários para sites autênticos através de *proxies* controlados, que podem ser usados para monitorar e interceptar a digitação.

Os *sites* falsificados coletam números de cartões de crédito, nomes de contas, senhas e números de documentos. Isso é feito através da exibição de um *pop-up* para roubar a informação antes de levar o usuário ao *site* real. O programa mal-intencionado usa um certificado auto-assinado para fingir a autenticação e induzir o usuário a acreditar nele o bastante para inserir seus dados pessoais no *site* falsificado. Outra forma de enganar o usuário é sobrepor a barra de endereço e status de navegador para induzi-lo a pensar que está no *site* legítimo e inserir suas informações.

Nesse contexto, **programas criminosos podem ser instalados nos PCs dos consumidores para roubar diretamente as suas informações**. Na maioria dos casos, o usuário não sabe que está infectado, percebendo apenas uma ligeira redução na velocidade do computador ou falhas de funcionamento atribuídas a vulnerabilidades normais de software.

GOLPE DE SEXTORSÃO

e) *mails* em que os criminosos alegam possuir um vídeo da vítima, que foi gravado enquanto ela estaria assistindo a um site pornô.

A mensagem é mentirosa, mas inclui uma senha *hackeada* **real** do usuário, o que aumenta sua veracidade. O propósito é chantagear a vítima, coagida a pagar por exemplo US\$ 1.400 (cerca de R\$ 5.380, em conversão direta) em **Bitcoins**.

A mensagem ameaça divulgar o suposto vídeo para todos os contatos do **Facebook**, **Messenger** e da própria conta de *e-mail* caso o depósito em criptomoedas não seja realizado dentro de 24 horas.

ATAQUES NA INTERNET

Ataque, segundo a norma ISO/IEC 27000 (2009) é a tentativa de destruir, expor, alterar, inutilizar, roubar ou obter acesso não autorizado, ou fazer uso não autorizado de um ativo.

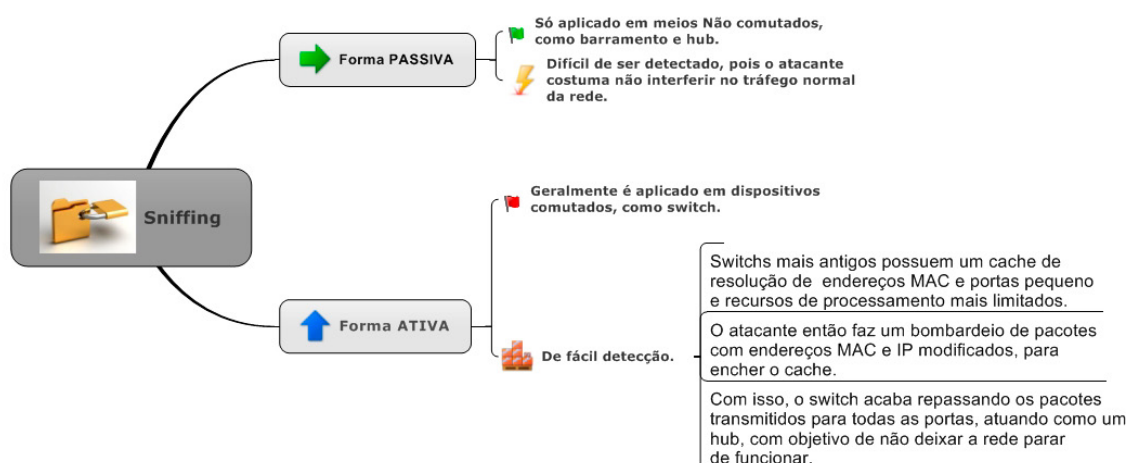
Os ataques costumam ocorrer na Internet com diversas motivações (financeiras, ideológicas, comerciais etc.), tendo-se em vista diferentes alvos e usando variadas técnicas. “Qualquer serviço, computador ou rede que seja acessível via Internet pode ser alvo de um ataque, assim como qualquer computador com acesso à Internet pode participar de um ataque” (CertBr,2012).

Veja algumas das técnicas utilizadas nos ataques, que podem ser cobradas na prova.

INTERCEPTAÇÃO DE TRÁFEGO (SNIFFING)

Processo de captura das informações da rede por meio de um software de escuta de rede (**sniffer**, *farejador ou ainda capturador de pacote*), **capaz de interpretar as informações transmitidas no meio físico**.

Ataque sniffing



Fonte: Elaboração própria (2024).

Segundo o CertBr (2012), essa técnica pode ser utilizada de forma:

- **legítima:** por **administradores de redes**, para **detectar problemas**, **analisar desempenho** e **monitorar atividades maliciosas** relativas aos computadores ou redes por eles administrados;
- **maliciosa:** por **atacantes**, para **capturar informações sensíveis**, como senhas, números de cartão de crédito e o conteúdo de arquivos confidenciais que estejam trafegando por meio de conexões inseguras, ou seja, sem criptografia.

Note que “as informações capturadas por esta técnica são armazenadas na forma como trafegam, ou seja, informações que trafegam criptografadas apenas serão úteis ao atacante se ele conseguir decodificá-las” (CertBr,2012).

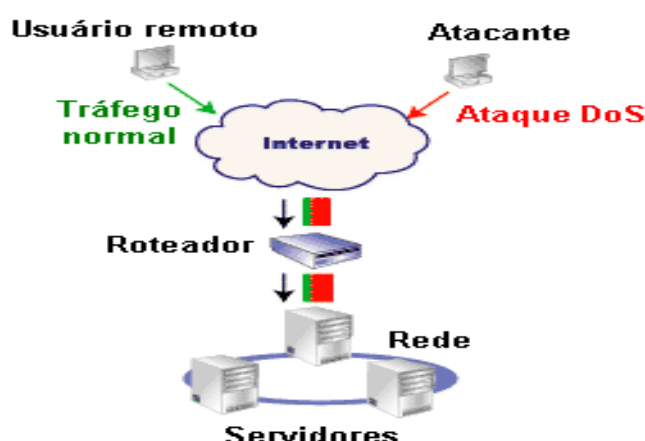
DENIAL OF SERVICE (DOS)

Os **ataques de negação de serviço (denial of service – DoS)** consistem em impedir o funcionamento de uma máquina ou de um serviço específico. No caso de ataques a redes, geralmente ocorre que os usuários legítimos de uma rede não consigam mais acessar seus recursos.

O DoS acontece quando um atacante envia vários pacotes ou requisições de serviço de uma vez, com objetivo de sobrecarregar um servidor e, como consequência, impedir o fornecimento de um serviço para os demais usuários, causando prejuízos.

Obs.: No **DoS** o atacante utiliza um computador para tirar de operação um serviço ou computador(es) conectado(s) à Internet!

Cabe ressaltar que se uma rede ou computador sofrer um **DoS**, isto não significa que houve uma invasão, pois o objetivo de tais ataques é indisponibilizar o uso de um ou mais computadores, e não invadi-los.



DISTRIBUTED DENIAL OF SERVICE (DDOS) – SÃO OS ATAQUES COORDENADOS!

Para isso, o atacante faz o uso de uma **botnet** (rede de computadores zumbis sob comando do atacante) para bombardear o servidor com requisições, fazendo com que o ataque seja feito de forma distribuída (*Distributed Denial of Service* – DDoS).

Obs.: No **DDoS** – ataque de negação de serviço distribuído –, um conjunto de computadores é utilizado para tirar de operação um ou mais serviços ou computadores conectados à Internet.

SMURF

É uma forma de ataque de negação de serviço distribuído (*Distributed Denial of Service* ou DDoS) que deixa as redes de computadores inoperáveis (KASPERSKY, 2020). Para isso, o programa Smurf explora vulnerabilidades dos protocolos IP e ICMP (KASPERSKY, 2020).

Um ataque Smurf apresenta as seguintes etapas (KASPERSKY, 2020):

- Primeiro, o **malware** cria um pacote de rede anexado a um endereço IP falso, uma técnica conhecida como **spoofing**, ou falsificação;
- Dentro do pacote, há uma mensagem de ping por ICMP solicitando que os nós de rede que receberem o pacote enviem uma resposta de volta;
- Essas respostas, ou “ecos”, são retornadas a endereços IP da rede, entrando em um **loop infinito**;

- Quando combinado com uma transmissão de IP, que envia o pacote malicioso para todos os endereços IP na rede, o ataque Smurf é capaz de causar rapidamente uma negação de serviço completa.

ATAQUES DE AMPLIFICAÇÃO

Utilizam características específicas de protocolos de rede para multiplicar o poder de ataque, sendo necessários relativamente poucos recursos para que sejam **nocivos** ao alvo (UPX, 2021).

Por meio de **técnicas de spoofing de IP**, o **atacante falsifica o endereço de origem e faz requisições a vários servidores ao mesmo tempo**. **Como os servidores acham que o alvo foi o requisitante da informação, todos respondem ao endereço de origem da requisição, congestionando a rede do alvo do ataque** (UPX, 2021).

ATAQUES FILELESS, OU “SEM ARQUIVO”

São um tipo de ataque cibernético que não depende da instalação de software malicioso no disco rígido da vítima.

Em vez disso, o código malicioso **executa diretamente na memória RAM** do computador, frequentemente **reaproveitando ferramentas legítimas** já presentes no sistema operacional (como PowerShell, WMI ou outros utilitários) para realizar suas ações maliciosas.

Por não deixarem rastro persistente em arquivos no disco, são **notoriamente difíceis de serem detectados** por soluções antivírus tradicionais baseadas em assinaturas, tornando-os uma ameaça mais furtiva.

ATAQUE DE FORÇA BRUTA (BRUTE FORCE)

Força bruta consiste em adivinhar, por tentativa e erro, um nome de usuário e senha e, assim, executar processos e acessar sites, computadores e serviços em nome e com os mesmos privilégios deste usuário (Certbr, 2012).

Qualquer computador, equipamento de rede ou serviço que seja acessível via Internet, com um nome de usuário e uma senha, pode ser alvo de um ataque de força bruta. Dispositivos móveis, que estejam protegidos por senha, além de poderem ser atacados pela rede, também podem ser alvo deste tipo de ataque caso o atacante tenha acesso físico a eles (Certbr, 2012).

Apesar dos **ataques de força bruta** poderem ser realizados manualmente, na grande maioria dos casos, eles são realizados com o uso de ferramentas automatizadas facilmente obtidas na Internet e que permitem tornar o ataque bem mais efetivo (Certbr, 2012).

As tentativas de adivinhação costumam ser baseadas em (Certbr, 2012):

- **dicionários de diferentes idiomas** e que podem ser facilmente obtidos na Internet;
- **listas de palavras comumente usadas**, como personagens de filmes e nomes de times de futebol;
- **substituições óbvias de caracteres**, como trocar “a” por “@” e “o” por “0”;
- **sequências numéricas e de teclado**, como “123456”, “qwert” e “1qaz2wsx”;
- **informações pessoais**, de conhecimento prévio do atacante ou coletadas na Internet em redes sociais e *blogs*, como nome, sobrenome, datas e números de documentos.

Um ataque de força bruta, dependendo de como é realizado, pode resultar em um ataque de negação de serviço, devido à sobrecarga produzida pela grande quantidade de tentativas realizadas em um pequeno período de tempo (Certbr, 2012).

PICHAÇÃO OU DESFIGURAÇÃO DE PÁGINA (DEFACEMENT)

É uma técnica que consiste em alterar o conteúdo da página Web de um site. Dentre as vulnerabilidades (falhas de segurança) que podem ser exploradas nesse tipo de ataque, podemos citar: erros da aplicação Web ou no servidor de aplicação Web etc.

SPOOFING

É uma prática em que um computador envia comandos a outro se fazendo passar por um terceiro.

VARREDURA EM REDES, OU SCAN

Permite efetuar buscas minuciosas em redes, com o objetivo de identificar computadores ativos e coletar informações sobre eles como, por exemplo, serviços disponibilizados e programas instalados. Com base nas informações coletadas é possível associar possíveis vulnerabilidades aos serviços disponibilizados e aos programas instalados nos computadores ativos detectados.

SESSION HIJACKING (SEQUESTRO DE SESSÃO)

É um ataque que permite que um atacante obtenha acesso às informações se passando por outro host em uma rede. O atacante obtém informações de uma sessão aberta pela vítima, e, a partir dessas informações, obtém informações de autenticação que fazem com que o atacante consiga se passar pelo host atacado, fazendo operações em nome dele.

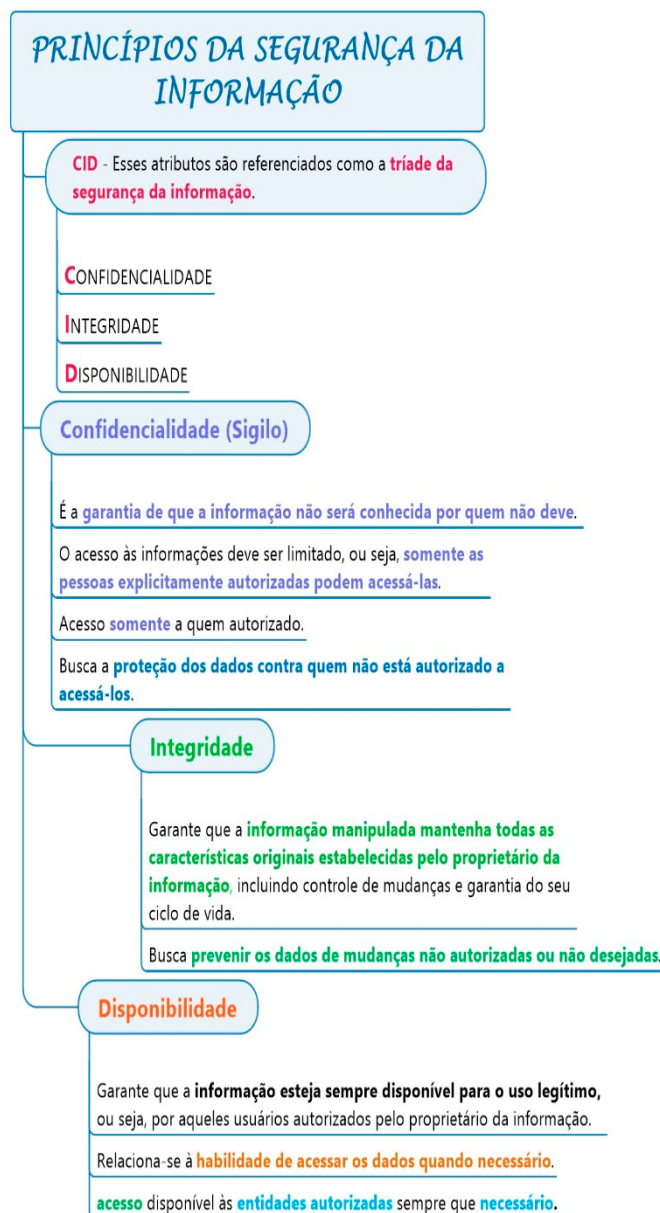
CROSS SITE REQUEST FORGERY (XSRF)

Um ataque de *Cross Site Request Forgery* (XSRF) **consiste em inserir requisições em uma sessão já aberta pelo usuário**. O processo básico é:

1. o usuário se autentica em uma aplicação web alvo;
2. o usuário utiliza a mesma instância de *browser* para navegar em um site malévolo;
3. o site malévolo manipula o *browser* para que seja feita uma requisição à aplicação alvo;
4. como há uma sessão autenticada aberta para o usuário, a aplicação alvo executa a operação conforme a requisição recebida. Ou seja, o site malévolo consegue manipular a situação de forma a executar uma ação em nome do usuário.

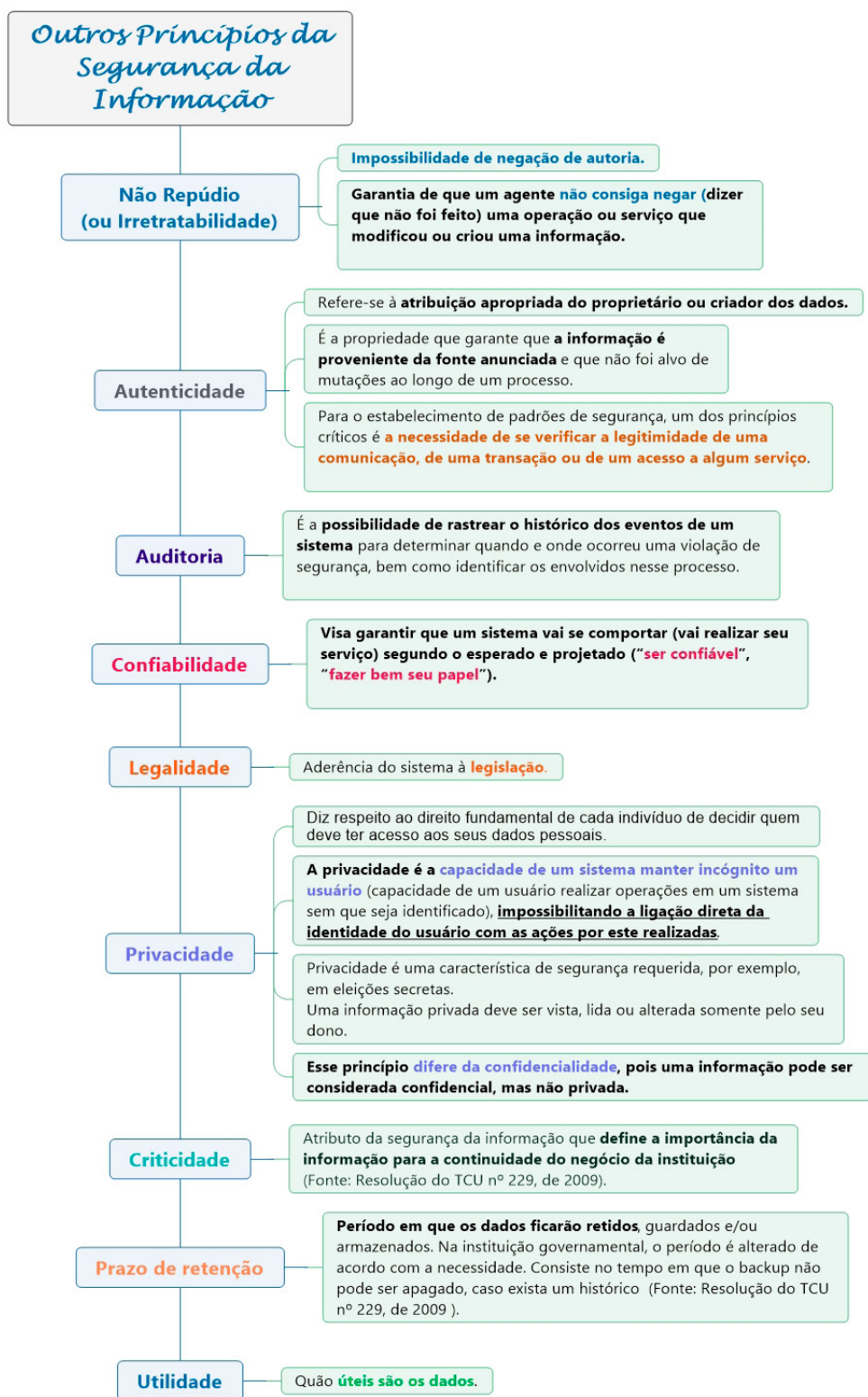
RESUMO

Princípios da segurança da informação



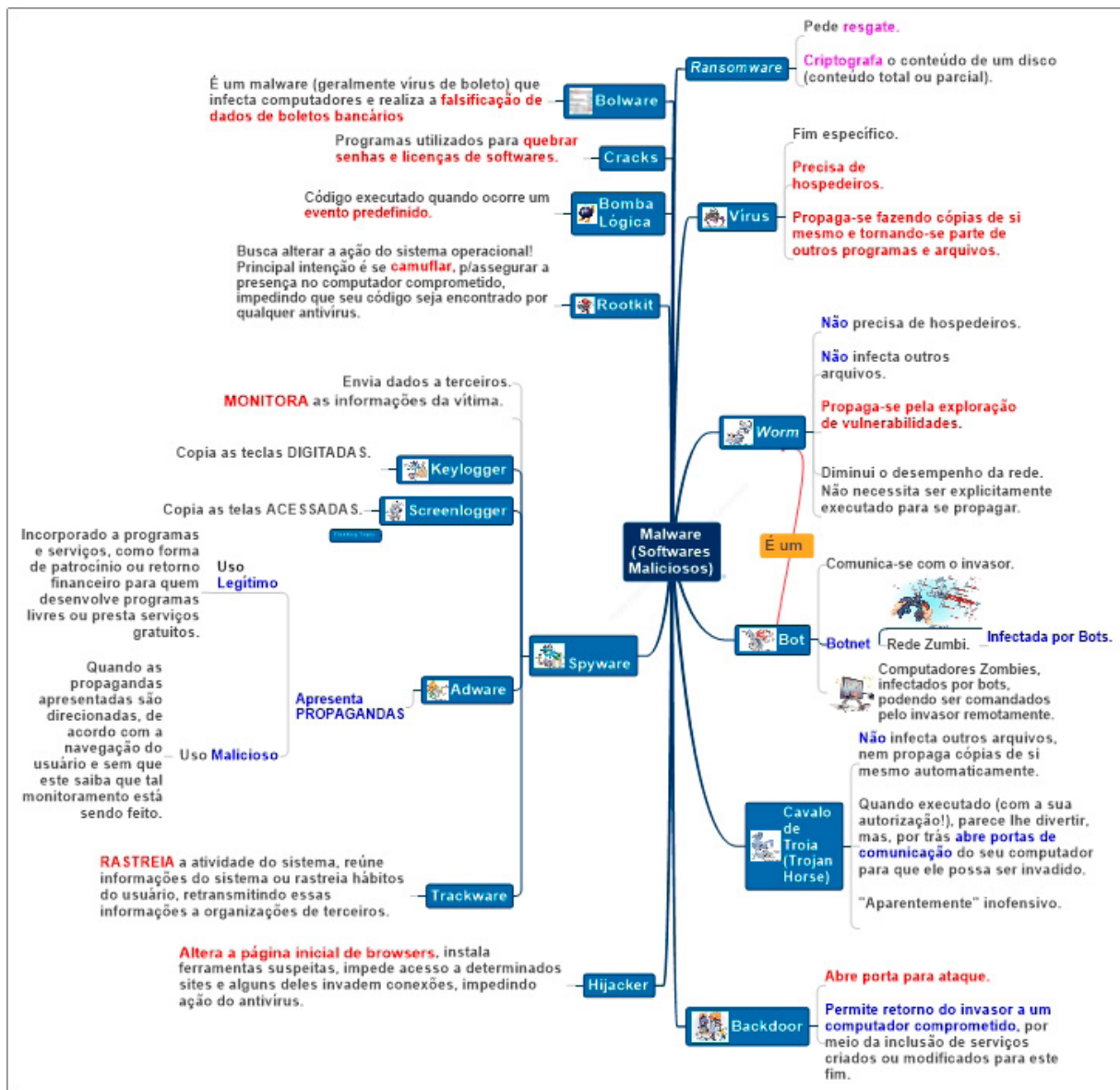
Fonte: Elaboração própria (2020).

Outros princípios da segurança da informação



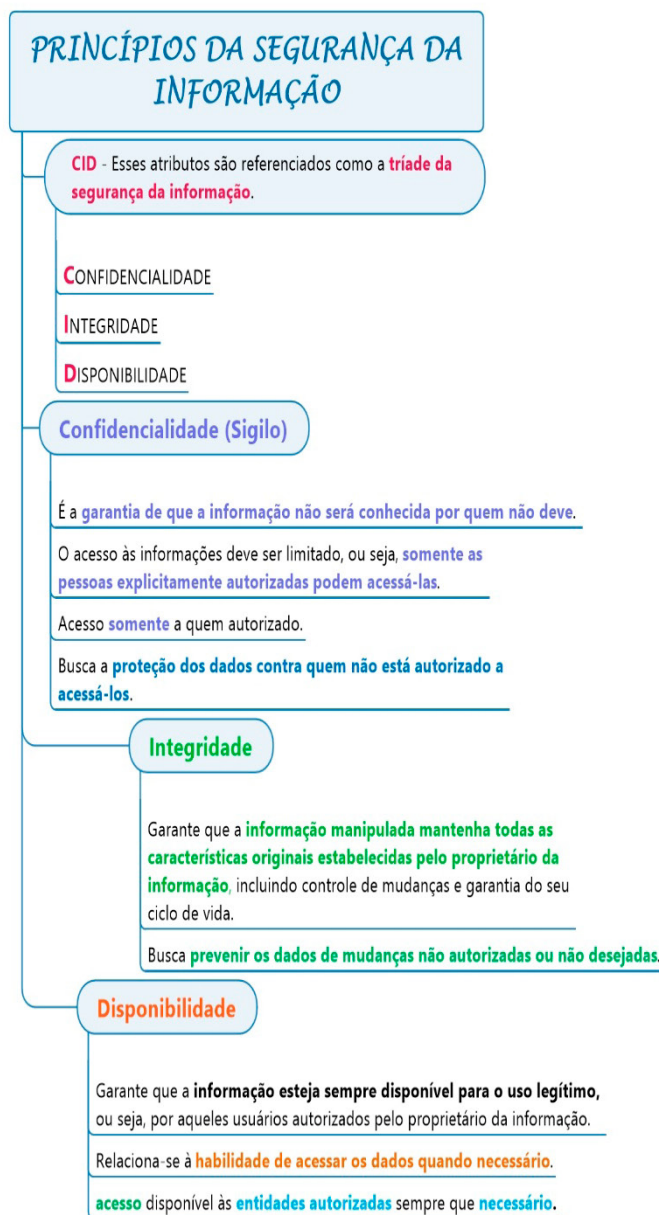
Fonte: Elaboração própria (2020).

Malware



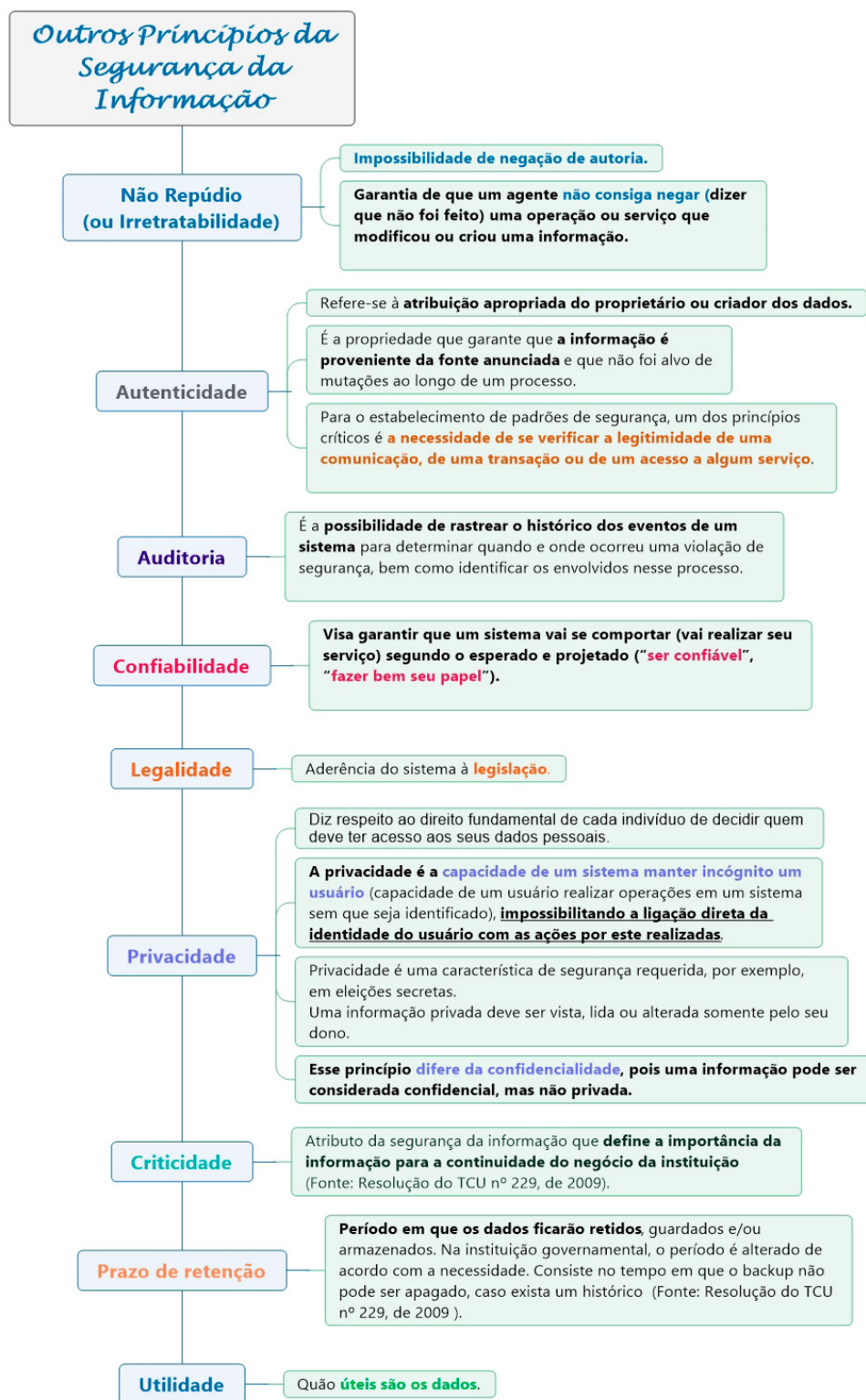
Fonte: Elaboração própria (2020).

Princípios da segurança da informação



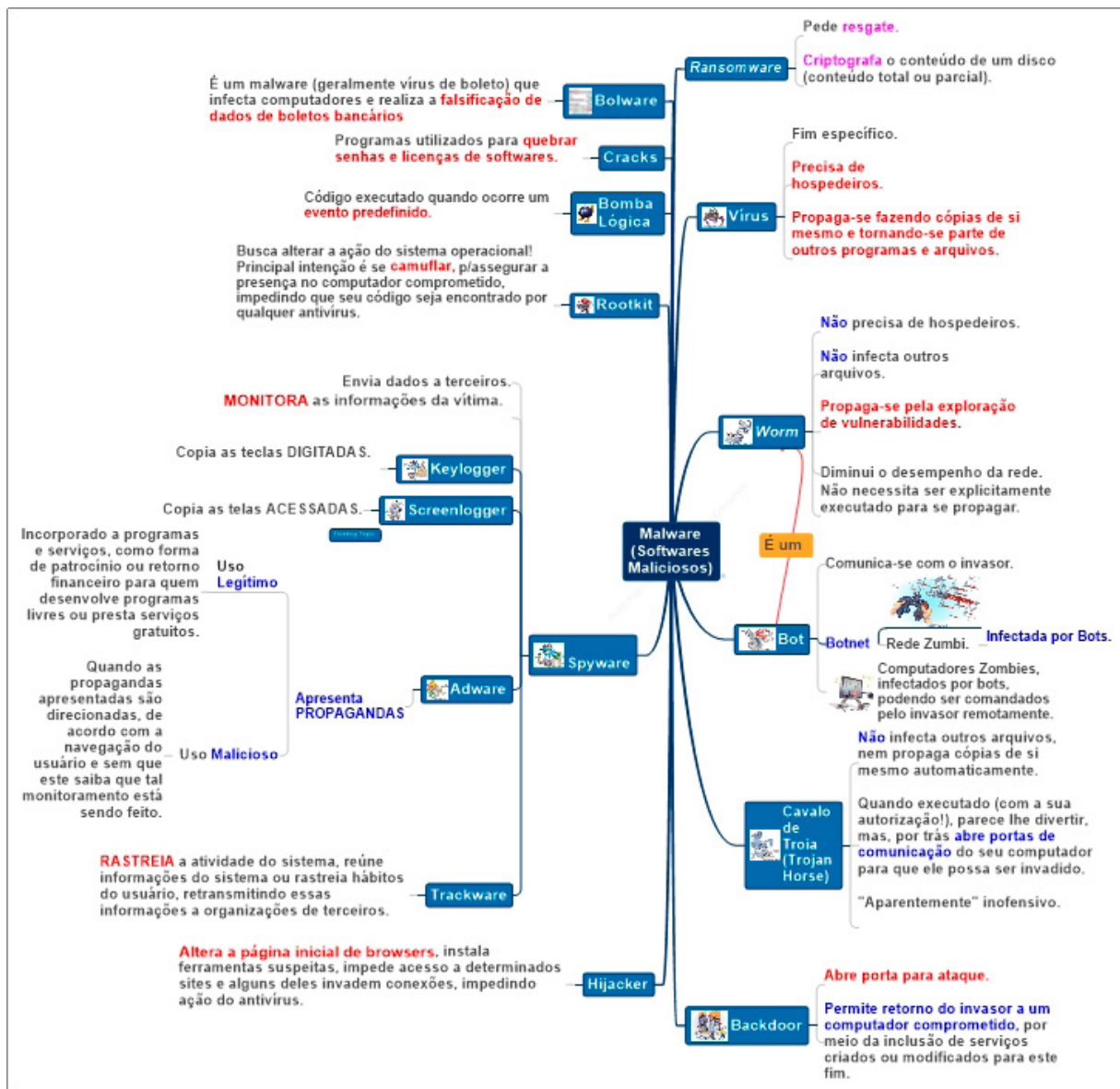
Fonte: Elaboração própria (2025).

Outros princípios da segurança da informação



Fonte: Elaboração própria (2025).

Malware



Fonte: Elaboração própria (2025).

QUESTÕES COMENTADAS EM AULA

001. (CESPE/PM-MA/2018/ADAPTADA) A seguir são apresentadas três situações hipotéticas.

I – Um usuário, após sequestro de seus dados, recebeu a informação de que, para reavê-los, seria necessário realizar um pagamento ao sequestrador.

II – Um usuário recebeu informação, por meio do setor de segurança da informação do seu órgão, de que seu computador, sem seu conhecimento, havia sido usado em um ataque a uma rede de outro órgão.

III – Em um dado momento do dia, um usuário notou que sua máquina estava consumindo mais recursos de memória do que o habitual e, ao executar no computador um programa de proteção, obteve a seguinte mensagem: “arquivo xpto infectado com o worm xyz”.

Com referência a essas situações hipotéticas e à segurança da informação, julgue o item subsequente.

A situação III caracteriza-se mais como vírus do que como um worm, pois os vírus são responsáveis por consumir muitos recursos, ao passo que os *worms* permitem o retorno de um invasor ao computador comprometido.

002. (CESPE/TCE-PB/2018) Entre os vários tipos de programas utilizados para realizar ataques a computadores, aquele capaz de se propagar automaticamente pelas redes, enviando cópias de si mesmo entre computadores, é conhecido como

- a) botnet.
- b) spyware.
- c) backdoor.
- d) trojan.
- e) worm.

003. (CESPE/PC-MA/ESCRIVÃO DE POLÍCIA/2018) Determinado tipo de vírus eletrônico é ativado quando um documento por ele infectado é aberto, podendo então, nesse momento, infectar não apenas outros documentos, mas também um gabarito padrão de documento, de modo que cada novo documento criado sob esse gabarito seja infectado. Tal vírus, cuja propagação ocorre quando documentos por ele infectados são remetidos por correio eletrônico para outros usuários, é conhecido como

- a) vírus de setor de carga (*boot sector*).
- b) vírus de programa.
- c) vírus de macro.
- d) backdoor.
- e) hoax.

EXERCÍCIOS

MALWARES (SOFTWARES MALICIOSOS)

004. (CEBRASPE/CESPE/ANM/ANALISTA ADMINISTRATIVO/2025) Julgue o item a seguir, referente ao Microsoft Office 365, a redes de computadores, à segurança da informação e à inteligência artificial.

Spyware é um golpe em que criminosos se passam por organizações confiáveis para obter informações sensíveis, como senhas e dados bancários, por meio de e-mails ou sites falsos.

005. (CEBRASPE/CESPE/AEB/ANALISTA EM CIÊNCIA E TECNOLOGIA/2025) Um malware projetado para monitorar as atividades de um sistema e enviar as informações coletadas para terceiros é do tipo

- a) trojan.
- b) ransomware.
- c) adware.
- d) rootkit.
- e) spyware.

006. (CEBRASPE/CESPE/ICMBIO/ANALISTA AMBIENTAL/2025) Acerca do sistema operacional Windows, de edição de textos e de segurança da informação, julgue o próximo item.

Considere que, em certa organização, tenha ocorrido um ataque que criptografou, por meio de malware, os arquivos dos usuários gravados no servidor de arquivos instalado na rede local da organização. Considere, ainda, que, após o ataque, tenham sido enviadas informações aos gestores da organização, a fim de forçá-los a pagar o resgate para reaver o acesso aos arquivos. Nesse caso, a organização foi vítima de um ransomware, tipo de ataque cujo impacto pode ser reduzido por meio da implementação prévia de backups para a proteção de dados.

007. (CEBRASPE/CESPE/INPI/ANALISTA DE PLANEJAMENTO, GESTÃO E INFRAESTRUTURA EM PROPRIEDADE INDUSTRIAL/2024) Julgue o próximo item, relativo a conceitos de ameaça, vulnerabilidade e impacto em sistemas de informação.

São exemplos de vulnerabilidade em segurança da informação nas empresas públicas brasileiras: falhas humanas; malware; ransomware e spyware.

008. (FGV/CM SP/CONSULTOR TÉCNICO LEGISLATIVO/2024) Relacione os termos da área de segurança para internet às respectivas definições.

1. MALWARE
2. RANSOMWARE
3. SCREENLOGGER
4. STALKERWARE

- () Código que observa os cliques do mouse e registra a posição do cursor e a tela apresentada no monitor, ou a região que circunda determinada posição.
- () Código para tornar inacessíveis os dados armazenados no equipamento, geralmente empregando criptografia, e que exige valor de resgate para não divulgar os dados e devolver acesso ao usuário.
- () Código que realiza a espionagem do dono do equipamento, sendo executado de forma furtiva, não autorizada e sem a ciência da vítima.
- () Código usado como intermediário para envio de spam, realização de ataques e prática de golpes.

Assinale a opção que indica a relação correta, na ordem apresentada.

- a) 2 – 1 – 4 – 3.
- b) 3 – 2 – 4 – 1.
- c) 2 – 3 – 1 – 4.
- d) 1 – 4 – 2 – 3.
- e) 4 – 2 – 1 – 3.

009. (IBFC/TRF 5ª REGIÃO/TÉCNICO JUDICIÁRIO/TECNOLOGIA DA INFORMAÇÃO/2024) _____ é um tipo de golpe de engenharia social que usa o medo para enganar as pessoas para que elas façam download de um malware. No exemplo clássico ele alerta a vítima de um vírus em seu dispositivo através de uma mensagem pop-up. Assinale a alternativa que preencha corretamente a lacuna.

- a) Scareware
- b) Rootkit
- c) Ransowere
- d) Spideware

010. (CEBRASPE/CESPE/CAU BR/ANALISTA/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Acerca de keyloggers e suas características, julgue o item subsequente. De maneira geral, keyloggers são códigos maliciosos usados para capturar informações à medida que existe alguma interação do usuário com o teclado; esses códigos podem estar inseridos em software ou até mesmo hardware específico.

011. (INSTITUTO VERBENA/CM ANÁPOLIS/ASSISTENTE ADMINISTRATIVO/TÉCNICO DE INFORMÁTICA/2024) Os vírus de computador são capazes de infectar arquivos com extensões bem conhecidas. Sabendo que não há regras e qualquer tipo de arquivo pode conter vírus, quais são as duas extensões das quais deve-se desconfiar por contaminação de vírus?

- a) .EXE e.BAT.
- b) .XLS e EXE.
- c) .DOC e.BAT.
- d) .PDF e.EXE.

012. (CEBRASPE/CESPE/CNPQ/ANALISTA EM CIÊNCIA E TECNOLOGIA I/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Com relação a malwares, julgue o item que se segue. Adware é um tipo de ataque em que os alvos são contatados por e-mail, telefone ou mensagem de texto por alguém que se faz passar por uma instituição legítima para induzir indivíduos a fornecerem dados confidenciais, como informações de identificação pessoal, detalhes bancários, dados de cartões de crédito e senhas.

013. (CEBRASPE/CESPE/CNPQ/ANALISTA EM CIÊNCIA E TECNOLOGIA I/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Com relação a malwares, julgue o item que se segue. Cavalo de Troia de acesso remoto é um programa que permite ao atacante acessar remotamente o equipamento da vítima e executar ações como se fosse o usuário legítimo, combinando, assim, as características de cavalo de Troia e backdoor.

014. (CEBRASPE/CESPE/PGDF/TÉCNICO JURÍDICO/TECNOLOGIA E INFORMAÇÃO/2021) No que se refere à segurança de sistemas, em particular os malwares e os sistemas de proteção contra vírus, julgue o item subsequente.

Um programa malicioso do tipo worm não pode ser considerado um vírus, uma vez que os worms não se replicam automaticamente.

015. (CONSULPLAN/TRF 2ª REGIÃO/ANALISTA JUDICIÁRIO/INFORMÁTICA DESENVOLVIMENTO/2017) *Malware* é a combinação das palavras inglesas *malicious* e *software*, ou seja, programas maliciosos. É um termo genérico que abrange todos os tipos de programa desenvolvidos com o intuito de executar ações danosas e atividades maliciosas em um computador. Os códigos maliciosos podem causar danos como alterações e roubo de informações do usuário infectado; são muitas vezes usados como intermediários para a prática de golpes aos usuários desavisados. De acordo com o exposto, relacione adequadamente as definições ao respectivo malware.

I – Não se replica ao infectar computadores, executa as funções para as quais foi aparentemente projetado, ficando oculto do usuário, executando funções maliciosas como: furto de senhas, modificação e destruição de arquivos. Necessita ser executado para infectar o computador.

II – Utiliza-se de uma rede para propagar-se por vários computadores sem que o usuário realize qualquer ação, sua propagação acontece pela exploração de vulnerabilidades existentes na configuração de softwares instalados, tornando o computador infectado vulnerável a outros ataques.

III – É um programa malicioso que infecta a máquina hospedeira anexando uma cópia de si mesmo aos arquivos ou programas, para que o computador seja infectado é necessário que um dos programas infectados seja previamente executado, de modo que o usuário ao utilizar o arquivo ou aplicativo execute o malware dando continuidade ao processo de infecção.

IV – Esta técnica consiste na troca do endereço de IP original por um outro, utilizando endereços de remetentes falsificados, podendo, assim, se passar por um outro host. O ataque ocorre quando é feito um pedido de conexão para o servidor da vítima com pacotes que carregam endereços falsificados de IP da fonte, o que representa uma séria ameaça para os sistemas baseados em autenticação pelo endereço IP.

A sequência está correta em

- a) I. *Worms* II. Vírus III. Cavalo de Troia IV. *Spoofing*.
- b) I. Cavalo de Troia II. *Worms* III. Vírus IV. *Spoofing*.
- c) I. *Worms* II. Vírus III. *Spoofing* IV. Cavalo de Troia.
- d) I. Vírus II. Cavalo de Troia III. *Worms* IV. *Spoofing*.

016. (CONSULPLAN/TRF 2ª REGIÃO/TÉCNICO JUDICIÁRIO/INFORMÁTICA/2017) Malware são programas criados com o intuito de prejudicar usuários e sistemas de informação.

Sobre os vários tipos de malware, relacione adequadamente as colunas a seguir.

- () Hijacker.
- () Key logger.
- () Vírus.
- () Worm.
- () Cavalo de Troia (Trojan).
- () Sniffer.
- () Backdoor.

1. É um programa de computador do tipo spyware cuja finalidade é monitorar tudo o que a vítima digita, a fim de descobrir dados pessoais ou sigilosos.
2. Não infectam outros arquivos. Normalmente é um arquivo executável, recebido de forma inofensiva, que executa suas próprias funções, bem como outras operações sem o conhecimento do usuário.

3. São cavalos de Troia que modificam a página inicial do navegador.
4. São programas que capturam quadros nas comunicações em uma rede local, armazenando tais quadros para que possam ser analisados posteriormente por quem o instalou.
5. É um programa que induz uma “brecha” de segurança intencionalmente colocada no micro da vítima para permitir que tenha sempre uma porta aberta para o invasor poder voltar àquele micro.
6. É um programa (ou parte de um programa) de computador, normalmente com intenções prejudiciais, que insere cópias de si mesmo em outros programas e/ou arquivos de um computador, se tornando parte destes.
7. É um programa capaz de se propagar automaticamente através de várias estruturas de redes (como e-mail, web, bate-papo, compartilhamento de arquivos em redes locais etc.), enviando cópias de si mesmo de computador para computador.

A sequência está correta em

- a) 3, 1, 6, 7, 2, 4, 5.
- b) 1, 6, 7, 2, 4, 5, 3.
- c) 6, 7, 2, 4, 5, 3, 1.
- d) 3, 4, 2, 5, 1, 7, 6.

017. (CESPE/SEFAZ-RS/AUDITOR-FISCAL DA RECEITA ESTADUAL/2019) Julgue os itens a seguir, acerca de segurança da informação.

I – São exemplos de ameaças as contas sem senhas ou configurações erradas em serviços DNS, FTP e SMTP.

II – Não repúdio indica que o remetente de uma mensagem não deve ser capaz de negar que enviou a mensagem.

III – Vulnerabilidade é a fragilidade de um ativo ou de um grupo de ativos que pode ser explorada.

IV – Pessoas não são consideradas ativos de segurança da informação.

Estão certos apenas os itens

- a) I e III.
- b) I e IV.
- c) II e III.
- d) I, II e IV.
- e) II, III e IV.

018. (CESPE/PRF/2019) No acesso a uma página web que contenha o código de um vírus de script pode ocorrer a execução automática desse vírus, conforme as configurações do navegador.

019. (CESPE/SEFAZ-RS/AUDITOR-FISCAL DA RECEITA ESTADUAL/2019) Para o estabelecimento de padrões de segurança, um dos princípios críticos é a necessidade de se verificar a legitimidade de uma comunicação, de uma transação ou de um acesso a algum serviço.

Esse princípio refere-se à

- a) confidencialidade.
- b) autenticidade.
- c) integridade.
- d) conformidade.
- e) disponibilidade.

020. (CESPE/BNB/ANALISTA BANCÁRIO/2018) Acerca de pesquisas na Web e de vírus e ataques a computadores, julgue o item subsequente.

Entre as categorias de antivírus disponíveis gratuitamente, a mais confiável e eficiente é o scareware, pois os antivírus dessa categoria fazem uma varredura nos arquivos e são capazes de remover 99% dos vírus existentes

021. (CESPE/BNB/ANALISTA BANCÁRIO/2018) Acerca de pesquisas na Web e de vírus e ataques a computadores, julgue o item subsequente.

Se um rootkit for removido de um sistema operacional, esse sistema não voltará à sua condição original, pois as mudanças nele implementadas pelo rootkit permanecerão ativas.

022. (CESPE/POLÍCIA FEDERAL/PAPILOSCOPISTA POLICIAL FEDERAL/2018) No que se refere à segurança de computadores, julgue o item subsecutivo.

Cavalos de Troia são exemplos de vírus contidos em programas aparentemente inofensivos e sua ação danosa é mascarada pelas funcionalidades do hospedeiro.

023. (CESPE/POLÍCIA FEDERAL/AGENTE DA POLÍCIA FEDERAL/2018) Julgue o próximo item, a respeito de proteção e segurança, e noções de vírus, worms e pragas virtuais.

A infecção de um sistema por códigos maliciosos pode ocorrer por meio da execução de arquivos infectados obtidos de anexos de mensagens eletrônicas, de mídias removíveis, de páginas web comprometidas, de redes sociais ou diretamente de outros equipamentos.

024. (CESPE/POLÍCIA FEDERAL/ESCRIVÃO DE POLÍCIA FEDERAL/2018) Acerca de redes de computadores e segurança, julgue o item que segue.

Os aplicativos de antivírus com escaneamento de segunda geração utilizam técnicas heurísticas para identificar códigos maliciosos.

025. (CESPE/PC-MA/2018) Julgue o item subsequente, relativo a software para o ambiente de microinformática e a proteção e segurança da informação.

Fazer becape regularmente é uma conduta que permite minimizar os danos decorrentes de um ataque do tipo ransomware locker, que impede o acesso ao equipamento infectado, visto que o pagamento do resgate não garante acesso aos dados.

026. (CESPE/ANVISA/2016) Códigos maliciosos podem ter acesso aos dados armazenados no computador e executar ações em nome dos usuários, de acordo com as permissões de operação de cada um destes.

027. (CESPE/DPU/ANALISTA/2016) A respeito da Internet e suas ferramentas, julgue o item a seguir.

Malwares são mecanismos utilizados para evitar que técnicas invasivas, como phishing e spams, sejam instaladas nas máquinas de usuários da Internet.

028. (CESPE/TRE-RS/TÉCNICO JUDICIÁRIO/2015) Em relação a vírus, worms e pragas virtuais, assinale a opção correta.

a) Para garantir a segurança da informação, é suficiente instalar e manter atualizados antivírus.

b) Não há diferença — seja conceitual, seja prática — entre worms e vírus; ambos são arquivos maliciosos que utilizam a mesma forma para infectar outros computadores.

c) Rootkits é um arquivo que infecta o computador sem causar maiores danos, ainda que implique a pichação da tela inicial do navegador.

d) A segurança da informação em uma organização depende integralmente de a sua área de tecnologia optar pela adoção de recursos de segurança atualizados, como firewall e antivírus.

e) Em segurança da informação, denominam-se engenharia social as práticas utilizadas para obter acesso a informações importantes ou sigilosas sem necessariamente utilizar falhas no software, mas, sim, mediante ações para ludibriar ou explorar a confiança das pessoas.

029. (CESPE/TELEBRÁS/ANALISTA SUPERIOR/COMERCIAL/2015) A respeito de segurança da informação, julgue o item subsecutivo.

Worms, assim como os vírus, são autorreplicáveis e necessitam ser executados pelos usuários para se propagarem e infectarem os computadores de uma rede.

030. (CESPE/TCE-RN/CONHECIMENTOS BÁSICOS PARA OS CARGOS 2 E 3/2015) Julgue o item subsequente, a respeito de organização e gerenciamento de arquivos, pastas e programas, bem como de segurança da informação.

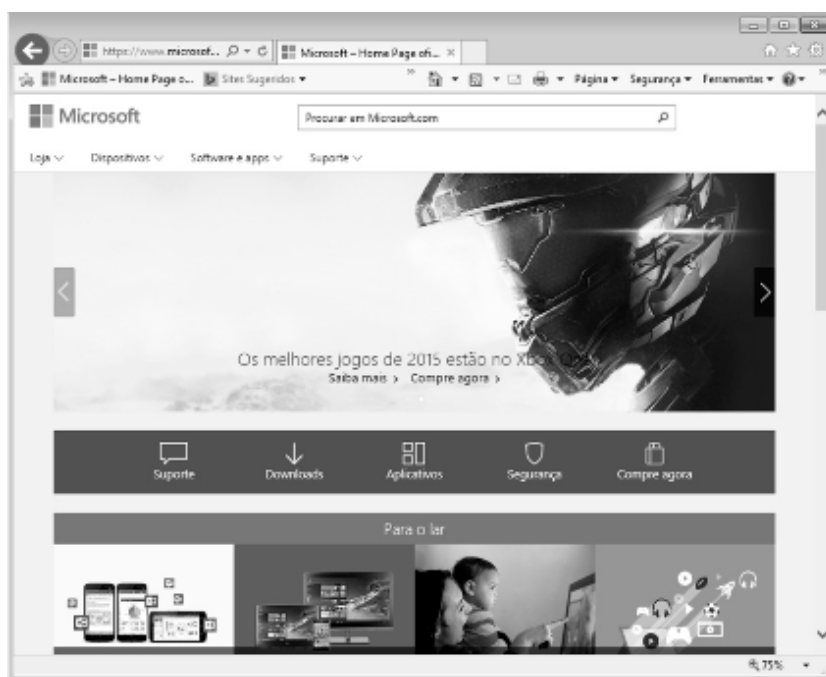
A principal diferença entre crackers e hackers refere-se ao modo como esses malfeitores da área de segurança da informação atacam: os crackers são mais experientes e realizam ataques sem utilizar softwares, ao passo que os hackers utilizam códigos maliciosos associados aos softwares para realizar ataques ao ciberespaço.

031. (CESPE/TJ-DFT/ANALISTA JUDICIÁRIO/2015) A respeito de sistemas operacionais e aplicativos para edição de texto, julgue o item que se segue.

Vírus do tipo boot, quando instalado na máquina do usuário, impede que o sistema operacional seja executado corretamente.

032. (CESPE/TELEBRÁS/ANALISTA ADMINISTRADOR/2015) No que se refere à segurança da informação, julgue o seguinte item.

Sniffers são programas aparentemente inofensivos cuja principal característica é utilizar a técnica de mascaramento. A técnica em questão permite, por exemplo, que um sniffer seja anexado a um jogo, que, por sua vez, ao ser instalado em um computador, coletará informações bancárias do usuário.



033. (CESPE/CEBRASPE/MP-ENAP/ADMINISTRADOR/2015) A respeito da figura acima apresentada, do Internet Explorer 11 e de segurança da informação, julgue o item a seguir. Trackwares são programas que rastreiam a atividade do sistema, reúnem informações do sistema ou rastreiam os hábitos do usuário, retransmitindo essas informações a organizações de terceiros.

034. (CESPE/TRE-GO/ANALISTA JUDICIÁRIO/2015) Acerca de procedimentos de segurança e de ensino a distância, julgue o item subsecutivo.

Botnet é uma rede formada por inúmeros computadores zumbis e que permite potencializar as ações danosas executadas pelos bots, os quais são programas similares ao worm e que possuem mecanismos de controle remoto.

035. (CESPE/CADE/NÍVEL INTERMEDIÁRIO/NÍVEL MÉDIO/2014) Acerca dos conceitos de gerenciamento de arquivos e de segurança da informação, julgue o item subsequente.

O computador utilizado pelo usuário que acessa salas de bate-papo não está vulnerável à infecção por worms, visto que esse tipo de ameaça não se propaga por meio de programas de chat.

036. (FCC/SEGEP-MA/2018) Em uma situação hipotética, um funcionário da Secretaria de Estado da Gestão e Assistência dos Servidores (SEGEP) verificou que um tipo de código malicioso (malware) havia invadido e tornado inacessíveis os dados armazenados em seu equipamento porque tudo havia sido criptografado. O invasor exigiu pagamento de resgate para restabelecer o acesso.

Essa situação mostra a ocorrência do ataque cibernético de um malware conhecido por:

- a) Spam.
- b) Ransomware.
- c) Trojan Spy.
- d) Cookie.
- e) Worm.

037. (FCC/AGED-MA/2018) Não importa se um usuário utiliza Microsoft, MacOS, Android ou outro tipo de sistema operacional, pois ao se conectar na internet com um deles, já fica vulnerável a uma infinidade de ataques digitais e pode sofrer com um tipo de malware cuja invasão é realizada com o intuito de causar algum dano ou roubar informações.

(Adaptado de: <http://tecnologia.ig.com.br/2017-04-04/malware-cimes-ciberneticos.html>)

O malware referenciado no texto é um programa que, além de executar as funções para as quais foi aparentemente projetado, também executa outras funções maliciosas sem o conhecimento do usuário. Ataca através de programas que necessitam ser explicitamente executados para que sejam instalados, mas também pode ser instalado por atacantes que, após invadirem o computador, alteram programas já existentes para que também executem ações maliciosas. Este malware é denominado:

- a) worm.
- b) rootkit.

- c) trojan.
- d) wanna cry.
- e) ransomware

PRINCÍPIOS OU ATRIBUTOS BÁSICOS DE SEGURANÇA DA INFORMAÇÃO

038. (INSTITUTO AOCP/DPE MS/ANALISTA DE DEFENSORIA/SUPORTE TÉCNICO DE REDES/2024)

Como analista de Suporte Técnico de Redes, você está liderando uma sessão de treinamento para sua equipe de TI sobre os princípios fundamentais da segurança da informação. Durante a sessão, você explica os principais princípios da segurança da informação. Ao explicar o princípio de “Integridade”, você dirá corretamente que

- a) se trata da garantia de que informações sensíveis e dados críticos só sejam acessíveis por pessoas autorizadas. Isso envolve implementação de controles de acesso, criptografia e políticas de privacidade para prevenir o acesso não autorizado.
- b) se trata da garantia de que os recursos de TI e os dados estejam disponíveis e acessíveis quando necessário. Isso inclui medidas para evitar interrupções não planejadas, como falhas de hardware, ataques cibernéticos ou desastres naturais. São comuns práticas como backups regulares e redundância de sistemas.
- c) se trata da garantia de que as informações não sejam alteradas de forma não autorizada ou acidental. Para garantir esse princípio, são implementados controles de proteção contra modificações não autorizadas, como assinaturas digitais e verificação de hash.
- d) se refere à capacidade de provar que uma ação foi realizada por uma parte específica e não pode ser negada posteriormente. Isso é importante, por exemplo, em transações financeiras ou contratos eletrônicos. A assinatura digital é um exemplo de mecanismo para garantir esse princípio.
- e) envolve a garantia de que as informações e ações são genuínas e originárias de fontes legítimas. Isso significa que os dados e as transações não foram falsificados, e as identidades das partes envolvidas são verificadas e confiáveis. É frequentemente alcançada por meio de técnicas de autenticação, como senhas, certificados digitais, tokens de segurança e biometria.

039. (FGV/SECRETARIA MUNICIPAL DE FAZENDA DE NITERÓI/2015) A Segurança da Informação (SI) está associada a um conjunto de atributos básicos que devem ser respeitados na análise e planejamento de mecanismos e procedimentos para proteção. Considere uma suposta lista desses atributos, mostrada a seguir.

- I – Autenticidade
- II – Confidencialidade
- III – Conformidade

IV – Disponibilidade

V – Integridade

VI – Irretratabilidade

VII – Presteza

Dessa lista, um item que NÃO é usualmente reconhecido como um dos atributos básicos da SI é:

- a) Presteza;
- b) Integridade;
- c) Disponibilidade;
- d) Confidencialidade;
- e) Autenticidade.

040. (INÉDITA/2024) Confidencialidade, integridade e disponibilidade são considerados os três pilares principais da segurança da informação.

041. (INÉDITA/2024) Manter o sigilo de informações em uma organização não é necessário se todos os dados forem criptografados, já que a criptografia por si só garante a proteção completa dos dados.

042. (IBFC/SESACRE/AGENTE ADMINISTRATIVO/2019) A Segurança da Informação (SI) está relacionada com proteção de um conjunto de informações a fim de preservar o valor que possuem para um indivíduo ou uma organização. Sobre as propriedades básicas da segurança da informação, assinale a alternativa correta.

- a) Rastreabilidade, usabilidade, notoriedade
- b) Confidencialidade, integridade, disponibilidade
- c) Integridade, usabilidade, simplicidade
- d) Disponibilidade, rastreabilidade, simplicidade

043. (CESPE/DPU/ANALISTA/2016) A respeito da Internet e suas ferramentas, julgue o item a seguir.

Integridade, confidencialidade e disponibilidade da informação, conceitos fundamentais de segurança da informação, são adotados na prática, nos ambientes tecnológicos, a partir de um conjunto de tecnologias como, por exemplo, criptografia, autenticação de usuários e equipamentos redundantes.

044. (FCC/TRE-RR/ANALISTA JUDICIÁRIO/MEDICINA/2015) O processo de proteção da informação das ameaças caracteriza-se como Segurança da Informação. O resultado de uma gestão de segurança da informação adequada deve oferecer suporte a cinco aspectos principais:

- I – Somente as pessoas autorizadas terão acesso às informações.
- II – As informações serão confiáveis e exatas. Pessoas não autorizadas não podem alterar os dados.
- III – Garante o acesso às informações, sempre que for necessário, por pessoas autorizadas.
- IV – Garante que em um processo de comunicação os remetentes não se passem por terceiros e nem que a mensagem sofra alterações durante o envio.
- V – Garante que as informações foram produzidas respeitando a legislação vigente.
- Os aspectos elencados de I a V correspondem, correta e respectivamente, a:
- a) integridade – disponibilidade – confidencialidade – autenticidade – legalidade.
 - b) disponibilidade – confidencialidade – integridade – legalidade – autenticidade.
 - c) confidencialidade – integridade – disponibilidade – autenticidade – legalidade.
 - d) autenticidade – integridade – disponibilidade – legalidade – confidencialidade.
 - e) autenticidade – confidencialidade – integridade – disponibilidade – legalidade.

PRINCIPAIS GOLPES APLICADOS NA INTERNET

045. (CESGRANRIO/IPEA/TÉCNICO DE PLANEJAMENTO E PESQUISA/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Mensagens não solicitadas em forma de e-mails, conhecidas como spam, são muito utilizadas para enganar os usuários de sistemas de informação. As soluções antispam possuem um papel crucial para evitar ataques de engenharia social executados por meio de spams que representam verdadeiras ameaças aos usuários. Nesse contexto, considere que um indivíduo recebeu um e-mail contendo um spam com um link malicioso que o direcionará para uma página web falsa de um banco de investimentos, com o objetivo de coletar as suas credenciais de acesso a esse sistema. Essa ação maliciosa é conhecida como

- a) vishing
- b) phishing
- c) skimming
- d) tailgating
- e) water-holing

046. (CESGRANRIO/IPEA/TÉCNICO DE PLANEJAMENTO E PESQUISA/DESENVOLVIMENTO DE SISTEMA/2024) Uma empresa sofreu um ataque que provocou a interrupção dos serviços de rede para os seus funcionários, usuários legítimos do sistema dessa empresa. Esse ataque foi feito utilizando uma técnica de negação que forçou os servidores de serviços de rede publicamente acessíveis a produzirem uma inundação de mensagens de controle do tipo SYN/ACK do protocolo TCP para cima do alvo. Esse tipo de ataque é o de

- a) DDoS
- b) DRDoS

- c) PoD
- d) Smurf
- e) Teardrop

047. (FCC/ALESE/TÉCNICO LEGISLATIVO/2018) Uma ação que NÃO potencializa o risco de golpes (scam) na Internet e de infecção de computador por malware é

- a) baixar atualizações ou softwares em sites de acesso mais rápido que o do fabricante.
- b) entrar em sites para baixar uma faixa musical, álbum ou filmes sem pagar.
- c) utilizar a mesma senha complexa em todos os sites que possui cadastro.
- d) utilizar Virtual Private Network confiável para acessar a Internet em locais públicos.
- e) abrir arquivos anexos no webmail, quando o assunto indicar alta prioridade.

ATAQUES NA INTERNET

048. (FGV/CGM DE BELO HORIZONTE/AUDITOR DE CONTROLE INTERNO/2024) O ataque do tipo ransomware, em que o invasor ameaça publicar informações privadas sobre a vítima na Internet, por meio do uso de malwares que capturam telas e outras informações privadas, para humilhá-la e fazê-la pagar um resgate, é denominado

- a) mobileware.
- b) adware.
- c) doxware.
- d) hoax.

Ataques cibernéticos causaram prejuízo de US\$ 280 bilhões às corporações

A extorsão virtual, quando servidores de empresas são bloqueados e seus gestores só recebem acesso novamente mediante pagamento para os criminosos, também é um dos maiores problemas na América Latina, 28,1%, ficando atrás apenas do bloco de países Asiáticos, 35,1%. Os setores mais suscetíveis a essa modalidade de ataques cibernéticos são serviços financeiros (45,8%); cuidados da saúde (23,7%); energia (23,3%); bens de consumo (22,4%); educação (22,1%); viagem, turismo e lazer (19,8%); agricultura (17,9%); setor produtivo (16,3%); tecnologia, meios de comunicação e telecomunicações (13,0%); transporte (11,3%); imobiliário e construção (6,2%) e serviços profissionais (4,8%).

(Disponível em: <http://www.convergenciadigital.com.br>)

049. (FCC/SEGEF-MA/AUXILIAR DE FISCALIZAÇÃO AGROPECUÁRIA/2018) O texto se refere à “extorsão virtual, quando servidores de empresas são bloqueados e seus gestores só recebem acesso novamente mediante pagamento para os criminosos” e quase 18% deste tipo de ataque atinge o setor de agricultura. A denominação deste tipo de ataque é

- a) bot.
- b) spyware.
- c) backdoor.
- d) ransomware.
- e) rootkit.

050. (FCC/TRE-SP/ANALISTA JUDICIÁRIO/2017) Considere o texto abaixo.

Com efeito, nesse tipo específico de delito, o agente obtém, para ele ou outrem, vantagem ilícita (numerário subtraído de conta bancária), em prejuízo de alguém (a vítima, cliente de banco) mediante o emprego do artifício da construção de uma página eletrônica falsa ou envio de mensagem eletrônica (e-mail) de conteúdo fraudulento. Não haveria, como se disse, qualquer dificuldade de enquadramento do praticante do “ato ilícito” no art. 171 do CPC, impondo-lhe as sanções previstas nesse dispositivo (reclusão, de um a cinco anos, e multa). Além do mais, quando o criminoso implementa o último estágio da execução ilícita, que é a subtração não autorizada dos fundos existentes na conta da vítima, a jurisprudência tem entendido que aí está caracterizado o crime de furto qualificado, previsto no art. 155, § 4º, II.

(Adaptado de: REINALDO FILHO, Democrito. Disponível em: <http://www.teleco.com.br/pdfs/tutorialintbank.pdf>)

Hipoteticamente, um Analista Judiciário do TRE-SP identificou, corretamente, o ato ilícito referido entre aspas no texto como um tipo de fraude por meio da qual um golpista tenta obter dados pessoais e financeiros de um usuário, pela utilização combinada de meios técnicos e engenharia social. Comumente realizado por meio da internet, esse golpe é caracterizado como

- a) *identity theft*.
- b) *fielding*.
- c) *phishing*.
- d) *hacker*.
- e) *worming*.

GABARITO

- | | |
|-------|-------|
| 1. E | 35. E |
| 2. e | 36. b |
| 3. c | 37. c |
| 4. E | 38. c |
| 5. e | 39. a |
| 6. C | 40. C |
| 7. E | 41. E |
| 8. b | 42. b |
| 9. a | 43. C |
| 10. C | 44. c |
| 11. a | 45. b |
| 12. E | 46. b |
| 13. C | 47. d |
| 14. E | 48. c |
| 15. b | 49. d |
| 16. a | 50. c |
| 17. c | |
| 18. C | |
| 19. b | |
| 20. E | |
| 21. C | |
| 22. C | |
| 23. C | |
| 24. C | |
| 25. C | |
| 26. C | |
| 27. E | |
| 28. e | |
| 29. E | |
| 30. E | |
| 31. C | |
| 32. E | |
| 33. C | |
| 34. C | |

GABARITO COMENTADO

MALWARES (SOFTWARES MALICIOSOS)

004. (CEBRASPE/CESPE/ANM/ANALISTA ADMINISTRATIVO/2025) Julgue o item a seguir, referente ao Microsoft Office 365, a redes de computadores, à segurança da informação e à inteligência artificial.

Spyware é um golpe em que criminosos se passam por organizações confiáveis para obter informações sensíveis, como senhas e dados bancários, por meio de e-mails ou sites falsos.



A afirmação descreve, na verdade, a prática de *phishing*, e não *spyware*. O *phishing* é um tipo de fraude online em que criminosos se utilizam da representação de organizações confiáveis para enganar usuários e obter informações confidenciais, como senhas e dados bancários, frequentemente por meio de e-mails ou sites fraudulentos. *Spyware*, por outro lado, é um *malware* instalado secretamente para monitorar a atividade do usuário e coletar dados sem seu consentimento.

Errado.

005. (CEBRASPE/CESPE/AEB/ANALISTA EM CIÊNCIA E TECNOLOGIA/2025) Um malware projetado para monitorar as atividades de um sistema e enviar as informações coletadas para terceiros é do tipo

- a) trojan.
- b) ransomware.
- c) adware.
- d) rootkit.
- e) spyware.



a) Errada. Um cavalo de Troia (*trojan*) é um tipo de *malware* que se disfarça como um software legítimo ou útil para enganar o usuário e ser instalado no sistema. Sua finalidade principal é permitir acesso não autorizado ou realizar ações maliciosas, não necessariamente o monitoramento contínuo de atividades.

b) Errada. *Ransomware* é um tipo de *malware* que criptografa os arquivos da vítima ou bloqueia o acesso ao sistema, exigindo um pagamento de resgate para a restauração. Seu objetivo principal é extorquir dinheiro, não monitorar as atividades do sistema e enviar informações para terceiros.

c) Errada. *Adware* é um software que exibe anúncios indesejados para o usuário, muitas vezes de forma intrusiva. Embora possa coletar algumas informações para direcionar os anúncios, sua finalidade primária não é o monitoramento abrangente das atividades do sistema para envio a terceiros.

d) Errada. Um *rootkit* é um conjunto de ferramentas que permite a um invasor manter o acesso a um sistema e ocultar sua presença e a de outros programas maliciosos. Ele foca em garantir a persistência e a invisibilidade, e não no monitoramento detalhado das atividades do usuário para envio a terceiros.

e) Certa. *Spyware* é precisamente o *malware* projetado para monitorar as atividades do usuário em um computador ou dispositivo, coletando informações como histórico de navegação, teclas digitadas, credenciais de login e outros dados, e enviando essas informações para um terceiro sem o consentimento ou conhecimento do usuário.

Letra e.

006. (CEBRASPE/CESPE/ICMBIO/ANALISTA AMBIENTAL/2025) Acerca do sistema operacional Windows, de edição de textos e de segurança da informação, julgue o próximo item.

Considere que, em certa organização, tenha ocorrido um ataque que criptografou, por meio de malware, os arquivos dos usuários gravados no servidor de arquivos instalado na rede local da organização. Considere, ainda, que, após o ataque, tenham sido enviadas informações aos gestores da organização, a fim de forçá-los a pagar o resgate para reaver o acesso aos arquivos. Nesse caso, a organização foi vítima de um ransomware, tipo de ataque cujo impacto pode ser reduzido por meio da implementação prévia de backups para a proteção de dados.



A situação descrita caracteriza um ataque de *ransomware* do tipo *crypto*, em que os arquivos são criptografados por um *malware* e um resgate é exigido para a sua decifração e acesso. Fazer *backups* regularmente é uma conduta que permite minimizar os danos decorrentes de um ataque do tipo ransomware, pois ter cópias de segurança atualizadas e acessíveis é a forma mais efetiva de recuperar os dados sem a necessidade de pagar o resgate, reduzindo significativamente o impacto do ataque.

Certo.

007. (CEBRASPE/CESPE/INPI/ANALISTA DE PLANEJAMENTO, GESTÃO E INFRAESTRUTURA EM PROPRIEDADE INDUSTRIAL/2024) Julgue o próximo item, relativo a conceitos de ameaça, vulnerabilidade e impacto em sistemas de informação.

São exemplos de vulnerabilidade em segurança da informação nas empresas públicas brasileiras: falhas humanas; malware; ransomware e spyware.



A assertiva apresentada contém uma mistura de conceitos que não se enquadram corretamente na categoria de vulnerabilidades. Vamos analisar cada termo mencionado:

- **Falhas Humanas:** sim, estas podem ser consideradas vulnerabilidades. Falhas humanas, como erros de configuração, falta de atualização de sistemas ou descuido na proteção de senhas, são vulnerabilidades porque podem ser exploradas por ameaças para comprometer a segurança de um sistema;
- **Malware:** não é uma vulnerabilidade. Malware é uma ameaça, pois representa software malicioso que pode explorar vulnerabilidades para causar danos;
- **Ransomware:** similar ao *malware*, *ransomware* é um tipo específico de ameaça que cifra os dados e exige um resgate para restaurar o acesso. Não é uma vulnerabilidade;
- **Spyware:** também é uma ameaça. *Spyware* é um tipo de software que coleta informações sem o conhecimento do usuário. Ele pode explorar vulnerabilidades, mas em si não é uma vulnerabilidade.

Portanto, a afirmação está incorreta ao classificar *malware*, *ransomware* e *spyware* como vulnerabilidades. Eles são, na verdade, exemplos de ameaças. A única correta em termos de vulnerabilidades são as falhas humanas. Vulnerabilidades referem-se às fraquezas que podem ser exploradas por ameaças para causar impacto em um sistema de informação.

Errado.

008. (FGV/CM SP/CONSULTOR TÉCNICO LEGISLATIVO/2024) Relacione os termos da área de segurança para internet às respectivas definições.

1. MALWARE
2. RANSOMWARE
3. SCREENLOGGER
4. STALKERWARE

- () Código que observa os cliques do mouse e registra a posição do cursor e a tela apresentada no monitor, ou a região que circunda determinada posição.
- () Código para tornar inacessíveis os dados armazenados no equipamento, geralmente empregando criptografia, e que exige valor de resgate para não divulgar os dados e devolver acesso ao usuário.
- () Código que realiza a espionagem do dono do equipamento, sendo executado de forma furtiva, não autorizada e sem a ciência da vítima.
- () Código usado como intermediário para envio de spam, realização de ataques e prática de golpes.

Assinale a opção que indica a relação correta, na ordem apresentada.

- a) 2 – 1 – 4 – 3.
- b) 3 – 2 – 4 – 1.
- c) 2 – 3 – 1 – 4.
- d) 1 – 4 – 2 – 3.
- e) 4 – 2 – 1 – 3.



Vamos analisar cada definição e relacioná-las corretamente aos termos apresentados:

- **MALWARE:** código usado como intermediário para envio de spam, realização de ataques e prática de golpes;
- **RANSOMWARE:** código para tornar inacessíveis os dados armazenados no equipamento, geralmente empregando criptografia, e que exige valor de resgate para não divulgar os dados e devolver acesso ao usuário;
- **SCREENLOGGER:** código que observa os cliques do mouse e registra a posição do cursor e a tela apresentada no monitor, ou a região que circunda determinada posição;
- **STALKERWARE:** código que realiza a espionagem do dono do equipamento, sendo executado de forma furtiva, não autorizada e sem a ciência da vítima.

Com base nessas definições, a relação correta na ordem apresentada na questão seria:

(3. SCREENLOGGER) Código que observa os cliques do mouse e registra a posição do cursor e a tela apresentada no monitor, ou a região que circunda determinada posição.

(2. RANSOMWARE) Código para tornar inacessíveis os dados armazenados no equipamento, geralmente empregando criptografia, e que exige valor de resgate para não divulgar os dados e devolver acesso ao usuário.

(4. STALKERWARE) Código que realiza a espionagem do dono do equipamento, sendo executado de forma furtiva, não autorizada e sem a ciência da vítima.

(1. MALWARE) Código usado como intermediário para envio de spam, realização de ataques e prática de golpes.

Letra b.

009. (IBFC/TRF 5ª REGIÃO/TÉCNICO JUDICIÁRIO/TECNOLOGIA DA INFORMAÇÃO/2024) _____ é um tipo de golpe de engenharia social que usa o medo para enganar as pessoas para que elas façam download de um malware. No exemplo clássico ele alerta a vítima de um vírus em seu dispositivo através de uma mensagem pop-up. Assinale a alternativa que preencha corretamente a lacuna.

- a) Scareware
- b) Rootkit

- c) Ransowere
- d) Spideware



- a) Certa. **Scareware** é um tipo de golpe de engenharia social que manipula o medo das vítimas, levando-as a acreditar que seus dispositivos foram infectados por vírus ou estão em risco. Esta técnica geralmente se manifesta através de mensagens pop-up alarmantes que instigam o usuário a baixar um software malicioso, supostamente para remover a ameaça inexistente. A intenção é enganar a vítima para que instale malware, forneça informações pessoais ou compre softwares falsos.
- b) Errada. **Rootkit**: um rootkit é um tipo de software malicioso projetado para obter acesso administrativo ao sistema operacional do computador sem ser detectado. Não está diretamente relacionado ao uso do medo através de mensagens pop-up.
- c) Errada. **Ransowere**: provavelmente uma grafia incorreta para “Ransomware”, que é um tipo de malware que cifra os dados da vítima e exige um resgate para restaurar o acesso. Não usa pop-ups para alertar sobre vírus falsos.
- d) Errada. **Spideware**: não é um termo comum ou reconhecido em segurança cibernética. O termo pode ter sido digitado incorretamente para “Spyware”, que coleta informações do usuário sem permissão, mas também não se encaixa na descrição de usar o medo em mensagens pop-up.

Letra a.

010. (CEBRASPE/CESPE/CAU BR/ANALISTA/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Acerca de keyloggers e suas características, julgue o item subsequente. De maneira geral, keyloggers são códigos maliciosos usados para capturar informações à medida que existe alguma interação do usuário com o teclado; esses códigos podem estar inseridos em software ou até mesmo hardware específico.



Keyloggers são ferramentas, que podem ser maliciosas, utilizadas para registrar as teclas digitadas em um teclado, geralmente sem o conhecimento do usuário. Eles são frequentemente usados por atacantes para capturar informações sensíveis, como senhas e dados pessoais, à medida que o usuário interage com o dispositivo.

Existem dois tipos principais de keyloggers:

- **Keyloggers de Software**: programas que se instalam no sistema operacional e monitoram as entradas do teclado. Eles podem estar disfarçados como aplicativos legítimos ou serem parte de um malware mais abrangente;

- **Keyloggers de Hardware:** dispositivos físicos que se conectam entre o teclado e o computador. Eles podem ser pequenos e discretos, tornando-se difíceis de detectar, e são usados para interceptar e registrar as teclas pressionadas diretamente.

Portanto, a descrição apresentada na questão é precisa ao afirmar que keyloggers podem ser implementados tanto em software quanto em hardware para capturar informações digitadas pelo usuário.

Certo.

011. (INSTITUTO VERBENA/CM ANÁPOLIS/ASSISTENTE ADMINISTRATIVO/TÉCNICO DE INFORMÁTICA/2024) Os vírus de computador são capazes de infectar arquivos com extensões bem conhecidas. Sabendo que não há regras e qualquer tipo de arquivo pode conter vírus, quais são as duas extensões das quais deve-se desconfiar por contaminação de vírus?

- a) .EXE e.BAT.
- b) .XLS e EXE.
- c) .DOC e.BAT.
- d) .PDF e.EXE.



A resposta correta para as duas extensões de arquivos das quais deve-se desconfiar por contaminação de vírus é:

a) Certa.

- **.EXE (Executable):** arquivos com a extensão.EXE são arquivos executáveis no sistema operacional Windows. Eles podem conter códigos maliciosos que são executados ao serem abertos, portanto, são frequentemente usados para disseminar vírus e outros tipos de malware. É importante ser cauteloso ao executar arquivos.EXE de fontes desconhecidas ou não verificadas;
- **.BAT (Batch):** arquivos.BAT são scripts de lote usados para executar comandos no prompt de comando do Windows. Eles podem ser facilmente manipulados para executar comandos maliciosos que afetam o sistema, tornando-os perigosos se provenientes de fontes duvidosas.

Vamos comentar as outras opções para esclarecer por que elas são menos prováveis em relação ao contexto de infecção por vírus:

b) Errada. Enquanto arquivos.XLS (planilhas do Microsoft Excel) podem conter macros que executam códigos maliciosos, eles são menos frequentemente utilizados para infecção direta por vírus em comparação com arquivos.BAT.

c) Errada. Semelhante aos arquivos.XLS, arquivos.DOC (documentos do Microsoft Word) podem conter macros maliciosas, mas a extensão.EXE é mais típica e diretamente associada à execução de vírus.

d) Errada. Arquivos.PDF são geralmente seguros, mas podem conter scripts prejudiciais ou links para sites maliciosos. No entanto, quando se trata de arquivos que diretamente executam código malicioso,.BAT é mais comum que.PDF.

Por essas razões, as extensões.EXE e.BAT são aquelas das quais se deve desconfiar mais em relação à contaminação por vírus.

Letra a.

012. (CEBRASPE/CESPE/CNPQ/ANALISTA EM CIÊNCIA E TECNOLOGIA I/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Com relação a malwares, julgue o item que se segue. Adware é um tipo de ataque em que os alvos são contatados por e-mail, telefone ou mensagem de texto por alguém que se faz passar por uma instituição legítima para induzir indivíduos a fornecerem dados confidenciais, como informações de identificação pessoal, detalhes bancários, dados de cartões de crédito e senhas.



A descrição apresentada não corresponde ao que é conhecido como **adware**. A definição mencionada na assertiva refere-se, na verdade, a **phishing**.

Vamos esclarecer ambos os termos:

- **Adware:** é um tipo de software projetado para exibir anúncios em seu dispositivo, geralmente dentro de um navegador ou outros aplicativos. O objetivo principal do *adware* é gerar receita para seus criadores através da exibição ou clique em anúncios. O *adware*, embora muitas vezes considerado invasivo e irritante, não é necessariamente malicioso, mas pode ser combinado com outros tipos de *malware* para roubar informações ou comprometer a segurança de um sistema;
- **Phishing:** é um tipo de ataque cibernético em que os atacantes se passam por instituições ou fontes legítimas para enganar as vítimas e induzi-las a fornecer informações sensíveis, como dados de identificação pessoal, detalhes bancários, números de cartões de crédito e senhas. Normalmente, o phishing é realizado por meio de e-mails falsos, mensagens de texto ou chamadas telefônicas que parecem ser de fontes confiáveis.

Portanto, a definição que você forneceu descreve o **phishing** e não o adware.

Errado.

013. (CEBRASPE/CESPE/CNPQ/ANALISTA EM CIÊNCIA E TECNOLOGIA I/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Com relação a malwares, julgue o item que se segue. Cavalo de Troia de acesso remoto é um programa que permite ao atacante acessar remotamente o equipamento da vítima e executar ações como se fosse o usuário legítimo, combinando, assim, as características de cavalo de Troia e backdoor.



Um **Cavalo de Troia de acesso remoto** (também conhecido como **RAT – Remote Access Trojan**) é um tipo de malware que permite ao atacante acessar e controlar remotamente o dispositivo da vítima. Este tipo de malware engana o usuário para que ele o instale pensando ser um software legítimo, que é a característica típica de um cavalo de Troia. Depois de instalado, ele cria uma “backdoor” no sistema, que é uma via de acesso oculta, permitindo que o atacante realize várias ações, como se fosse o usuário legítimo do sistema. Essas ações podem incluir acessar arquivos, registrar teclas digitadas, ativar a câmera e o microfone, entre outras atividades maliciosas.

Portanto, a definição apresentada na assertiva corretamente descreve as funcionalidades e características de um cavalo de Troia de acesso remoto, que combina as funções de um cavalo de Troia com as de uma backdoor.

Certo.

014. (CEBRASPE/CESPE/PGDF/TÉCNICO JURÍDICO/TECNOLOGIA E INFORMAÇÃO/2021) No que se refere à segurança de sistemas, em particular os malwares e os sistemas de proteção contra vírus, julgue o item subsecutivo.

Um programa malicioso do tipo worm não pode ser considerado um vírus, uma vez que os worms não se replicam automaticamente.



Worms são programas **capazes de se propagarem automaticamente através de redes, enviando cópias de si mesmo de computador para computador** (observe que **os worms APENAS se copiam, não infectam outros arquivos, eles mesmos são os arquivos!**). Além disso, geralmente utilizam as redes de comunicação para infectar outros computadores (via e-mails, Web, FTP, redes das empresas etc.).

Os **Worms** podem se espalhar de diversas maneiras, mas a propagação via rede é a mais comum. Sua característica marcante é a replicação (cópia funcional de si mesmo) e infecção de outros computadores **SEM intervenção humana** e **SEM necessidade de um programa hospedeiro. (Atenção)**

Errado.

015. (CONSULPLAN/TRF 2ª REGIÃO/ANALISTA JUDICIÁRIO/INFORMÁTICA DESENVOLVIMENTO/2017) *Malware* é a combinação das palavras inglesas *malicious* e *software*, ou seja, programas maliciosos. É um termo genérico que abrange todos os tipos de programa desenvolvidos com o intuito de executar ações danosas e atividades maliciosas em um computador. Os códigos maliciosos podem causar danos como alterações e roubo de informações do usuário infectado; são muitas vezes usados como intermediários para a prática de golpes aos usuários desavisados. De acordo com o exposto, relacione adequadamente as definições ao respectivo malware.

I – Não se replica ao infectar computadores, executa as funções para as quais foi aparentemente projetado, ficando oculto do usuário, executando funções maliciosas como: furto de senhas, modificação e destruição de arquivos. Necessita ser executado para infectar o computador.

II – Utiliza-se de uma rede para propagar-se por vários computadores sem que o usuário realize qualquer ação, sua propagação acontece pela exploração de vulnerabilidades existentes na configuração de softwares instalados, tornando o computador infectado vulnerável a outros ataques.

III – É um programa malicioso que infecta a máquina hospedeira anexando uma cópia de si mesmo aos arquivos ou programas, para que o computador seja infectado é necessário que um dos programas infectados seja previamente executado, de modo que o usuário ao utilizar o arquivo ou aplicativo execute o malware dando continuidade ao processo de infecção.

IV – Esta técnica consiste na troca do endereço de IP original por um outro, utilizando endereços de remetentes falsificados, podendo, assim, se passar por um outro host. O ataque ocorre quando é feito um pedido de conexão para o servidor da vítima com pacotes que carregam endereços falsificados de IP da fonte, o que representa uma séria ameaça para os sistemas baseados em autenticação pelo endereço IP.

A sequência está correta em

- a) I. *Worms* II. Vírus III. Cavalo de Troia IV. *Spoofing*.
- b) I. Cavalo de Troia II. *Worms* III. Vírus IV. *Spoofing*.
- c) I. *Worms* II. Vírus III. *Spoofing* IV. Cavalo de Troia.
- d) I. Vírus II. Cavalo de Troia III. *Worms* IV. *Spoofing*.



Cavalo de Troia	I – Não se replica ao infectar computadores, executa as funções para as quais foi aparentemente projetado, ficando oculto do usuário, executando funções maliciosas como: furto de senhas, modificação e destruição de arquivos. Necessita ser executado para infectar o computador.
------------------------	--

Worms	II – Utiliza-se de uma rede para propagar-se por vários computadores sem que o usuário realize qualquer ação, sua propagação acontece pela exploração de vulnerabilidades existentes na configuração de softwares instalados, tornando o computador infectado vulnerável a outros ataques.
Vírus	III – É um programa malicioso que infecta a máquina hospedeira anexando uma cópia de si mesmo aos arquivos ou programas, para que o computador seja infectado é necessário que um dos programas infectados seja previamente executado, de modo que o usuário ao utilizar o arquivo ou aplicativo execute o malware dando continuidade ao processo de infecção.
Spoofing	IV – Esta técnica consiste na troca do endereço de IP original por um outro, utilizando endereços de remetentes falsificados, podendo, assim, se passar por um outro host. O ataque ocorre quando é feito um pedido de conexão para o servidor da vítima com pacotes que carregam endereços falsificados de IP da fonte, o que representa uma séria ameaça para os sistemas baseados em autenticação pelo endereço IP.

Letra b.

016. (CONSULPLAN/TRF 2ª REGIÃO/TÉCNICO JUDICIÁRIO/INFORMÁTICA/2017) Malware são programas criados com o intuito de prejudicar usuários e sistemas de informação. Sobre os vários tipos de malware, relacione adequadamente as colunas a seguir.

- () Hijacker.
- () Key logger.
- () Vírus.
- () Worm.
- () Cavalo de Troia (Trojan).
- () Sniffer.
- () Backdoor.

1. É um programa de computador do tipo spyware cuja finalidade é monitorar tudo o que a vítima digita, a fim de descobrir dados pessoais ou sigilosos.
2. Não infectam outros arquivos. Normalmente é um arquivo executável, recebido de forma inofensiva, que executa suas próprias funções, bem como outras operações sem o conhecimento do usuário.
3. São cavalos de Troia que modificam a página inicial do navegador.
4. São programas que capturam quadros nas comunicações em uma rede local, armazenando tais quadros para que possam ser analisados posteriormente por quem o instalou.
5. É um programa que induz uma “brecha” de segurança intencionalmente colocada no micro da vítima para permitir que tenha sempre uma porta aberta para o invasor poder voltar àquele micro.

6. É um programa (ou parte de um programa) de computador, normalmente com intenções prejudiciais, que insere cópias de si mesmo em outros programas e/ou arquivos de um computador, se tornando parte destes.

7. É um programa capaz de se propagar automaticamente através de várias estruturas de redes (como e-mail, web, bate-papo, compartilhamento de arquivos em redes locais etc.), enviando cópias de si mesmo de computador para computador.

A sequência está correta em

a) 3, 1, 6, 7, 2, 4, 5.

b) 1, 6, 7, 2, 4, 5, 3.

c) 6, 7, 2, 4, 5, 3, 1.

d) 3, 4, 2, 5, 1, 7, 6.



(3) Hijacker.	São cavalos de Troia que modificam a página inicial do navegador.
(1) Keylogger.	É um programa de computador do tipo spyware cuja finalidade é monitorar tudo o que a vítima digita, a fim de descobrir dados pessoais ou sigilosos.
(6) Vírus.	É um programa (ou parte de um programa) de computador, normalmente com intenções prejudiciais, que insere cópias de si mesmo em outros programas e/ou arquivos de um computador, se tornando parte destes.
(7) Worm.	É um programa capaz de se propagar automaticamente através de várias estruturas de redes (como e-mail, web, bate-papo, compartilhamento de arquivos em redes locais etc.), enviando cópias de si mesmo de computador para computador.
(2) Cavalo de Troia (Trojan).	Não infectam outros arquivos. Normalmente é um arquivo executável, recebido de forma inofensiva, que executa suas próprias funções, bem como outras operações sem o conhecimento do usuário.
(4) Sniffer.	São programas que capturam quadros nas comunicações em uma rede local, armazenando tais quadros para que possam ser analisados posteriormente por quem o instalou.
(5) Backdoor.	É um programa que induz uma “brecha” de segurança intencionalmente colocada no micro da vítima para permitir que tenha sempre uma porta aberta para o invasor poder voltar àquele micro.

Letra a.

017. (CESPE/SEFAZ-RS/AUDITOR-FISCAL DA RECEITA ESTADUAL/2019) Julgue os itens a seguir, acerca de segurança da informação.

I – São exemplos de ameaças as contas sem senhas ou configurações erradas em serviços DNS, FTP e SMTP.

II – Não repúdio indica que o remetente de uma mensagem não deve ser capaz de negar que enviou a mensagem.

III – Vulnerabilidade é a fragilidade de um ativo ou de um grupo de ativos que pode ser explorada.

IV – Pessoas não são consideradas ativos de segurança da informação.

Estão certos apenas os itens

- a) I e III.
- b) I e IV.
- c) II e III.
- d) I, II e IV.
- e) II, III e IV.



I – Errada. **Ameaça** (Ex.: vírus etc.) é algo que possa provocar **danos** à segurança da informação, prejudicar as ações da empresa e sua sustentação no negócio, mediante a exploração de uma determinada **vulnerabilidade**. São **exemplos** de vulnerabilidades as contas sem senhas ou configurações erradas em serviços DNS, FTP e SMTP.

Ameaças à segurança

Ameaças à Segurança

Agentes ou condições que causam incidentes
que comprometem os ativos
por meio da exploração de vulnerabilidades.



Os perigos internos e externos!



Fonte: Elaboração própria (2016).

II – Certa. **Não repúdio** (ou **irretratabilidade**): indica que o emissor (aquele que assinou digitalmente a mensagem) não pode negar que foi o autor da mensagem, ou seja, não pode dizer mais tarde que a sua assinatura foi falsificada.

III – Certa. **Vulnerabilidade** é a **fragilidade** de **um ativo ou de um grupo de ativos** que pode ser explorada por uma ameaça para concretizar um ataque. Não há uma receita ou lista padrão de vulnerabilidades. Esta deve ser levantada junto a cada organização ou ambiente. Sempre se deve ter em mente o que precisa ser protegido e de quem precisa ser protegido de acordo com as ameaças existentes. Podemos citar, como exemplo inicial, uma análise de ambiente em uma sala de servidores de conectividade e Internet com a seguinte descrição: **a sala dos servidores não possui controle de acesso físico. Eis a vulnerabilidade detectada nesse ambiente!**

IV – Errada. Segundo Technet (2006) um **ativo** é “todo elemento que compõe o processo da comunicação, partindo da informação, seu emissor, o meio pelo qual é transmitida, até chegar ao seu receptor”. Pessoas são consideradas ativos de segurança da informação. Aliás, são o elo mais fraco da segurança da informação!

Letra c.

018. (CESPE/PRF/2019) No acesso a uma página web que contenha o código de um vírus de script pode ocorrer a execução automática desse vírus, conforme as configurações do navegador.



Vírus de scripts propagam-se por meio de scripts¹. Dois tipos de *scripts* muito usados são os projetados com as linguagens Javascript (JS) e Visual Basic Script (VBS). Tanto um quanto o outro podem ser inseridos em páginas Web e interpretados por navegadores como Internet Explorer e outros. Assim, em virtude de ser interpretado pelo navegador Web, o vírus de scripts pode ser executado automaticamente pelo próprio navegador, dependendo de suas configurações.

Certo.

019. (CESPE/SEFAZ-RS/AUDITOR-FISCAL DA RECEITA ESTADUAL/2019) Para o estabelecimento de padrões de segurança, um dos princípios críticos é a necessidade de se verificar a legitimidade de uma comunicação, de uma transação ou de um acesso a algum serviço. Esse princípio refere-se à

- a) confidencialidade.
- b) autenticidade.
- c) integridade.

¹ **Scripts:** nome que designa uma sequência de comandos previamente estabelecidos e que são executados automaticamente em um sistema, sem necessidade de intervenção do usuário.

- d) conformidade.
- e) disponibilidade.



Autenticidade é a propriedade que garante que a informação é proveniente da fonte anunciada e que não foi alvo de mutações ao longo de um processo. Refere-se à **atribuição apropriada do proprietário ou criador dos dados**.

Letra b.

020. (CESPE/BNB/ANALISTA BANCÁRIO/2018) Acerca de pesquisas na Web e de vírus e ataques a computadores, julgue o item subsequente.

Entre as categorias de antivírus disponíveis gratuitamente, a mais confiável e eficiente é o scareware, pois os antivírus dessa categoria fazem uma varredura nos arquivos e são capazes de remover 99% dos vírus existentes



Scareware (também conhecido como *software* de engano, *software* de verificação desonesto ou *fraudware*) não é antivírus! Segundo Kaspersky Lab, trata-se de um *software* malicioso que faz com que os usuários de computadores acessem *sites* infestados por *malware*. O *scareware* pode vir na forma de caixas suspensas, que aparecem como avisos legítimos de empresas de *software* antivírus, alegando que os arquivos de seu computador foram infectados. São tão habilmente criados que os usuários ficam assustados e pagam uma taxa para adquirir rapidamente um *software* que irá resolver o suposto problema. Mas o que eles acabam baixando é um falso *software* antivírus que na verdade é um *malware* destinado a roubar os dados pessoais da vítima.

Errado.

021. (CESPE/BNB/ANALISTA BANCÁRIO/2018) Acerca de pesquisas na Web e de vírus e ataques a computadores, julgue o item subsequente.

Se um rootkit for removido de um sistema operacional, esse sistema não voltará à sua condição original, pois as mudanças nele implementadas pelo rootkit permanecerão ativas.



Rootkit é um tipo de *malware* cuja **principal intenção é se camuflar, para assegurar a sua presença no computador comprometido, impedindo que seu código seja encontrado por qualquer antivírus**. Isto é possível porque esta aplicação tem a capacidade de interceptar as solicitações feitas ao sistema operacional, podendo alterar o seu resultado.

O invasor, após instalar o *rootkit*, terá acesso privilegiado ao computador previamente comprometido, sem precisar recorrer novamente aos métodos utilizados na realização da invasão, e suas atividades serão escondidas do responsável e/ou dos usuários do computador. Assim, como poderá esconder processos, instalar outros programas, a retirada dessa ameaça não irá desfazer as mudanças já feitas!

Certo.

022. (CESPE/POLÍCIA FEDERAL/PAPILOSCOPISTA POLICIAL FEDERAL/2018) No que se refere à segurança de computadores, julgue o item subsecutivo.

Cavalos de Troia são exemplos de vírus contidos em programas aparentemente inofensivos e sua ação danosa é mascarada pelas funcionalidades do hospedeiro.



Questão MUITO POLÊMICA! Foi alvo de inúmeros recursos, mas o gabarito final foi considerado **correto** pela banca.

Cavalo de troia, trojan ou trojan-horse, é um programa que, além de executar as funções para as quais foi aparentemente projetado, também executa outras funções, normalmente maliciosas, e sem o conhecimento do usuário.

Exemplos de trojans são programas que você recebe ou obtém de sites na Internet e que parecem ser apenas cartões virtuais animados, álbuns de fotos, jogos e protetores de tela, entre outros. Estes programas, geralmente, consistem de um único arquivo e necessitam ser explicitamente executados para que sejam instalados no computador.

O cavalo de troia pode carregar dentro de si vírus e outros códigos maliciosos, no entanto, ele não é um vírus! A classificação mais adequada para malware é a que foi explicitada em <https://cartilha.cert.br/malware/>.

Certo.

023. (CESPE/POLÍCIA FEDERAL/AGENTE DA POLÍCIA FEDERAL/2018) Julgue o próximo item, a respeito de proteção e segurança, e noções de vírus, worms e pragas virtuais.

A infecção de um sistema por códigos maliciosos pode ocorrer por meio da execução de arquivos infectados obtidos de anexos de mensagens eletrônicas, de mídias removíveis, de páginas web comprometidas, de redes sociais ou diretamente de outros equipamentos.



A infecção de um sistema por códigos maliciosos pode ocorrer:

- pela **exploração de vulnerabilidades** existentes nos programas instalados;
- pela **auto-execução de mídias removíveis infectadas**, como *pen-drives*;

- pelo **acesso a páginas Web maliciosas**, utilizando navegadores vulneráveis;
- pela **ação direta de atacantes** que, após invadirem o computador, incluem arquivos contendo códigos maliciosos;
- pela **execução de arquivos previamente infectados**, obtidos em anexos de mensagens eletrônicas, via mídias removíveis, em páginas Web ou diretamente de outros computadores (através do compartilhamento de recursos).

Certo.

024. (CESPE/POLÍCIA FEDERAL/ESCRIVÃO DE POLÍCIA FEDERAL/2018) Acerca de redes de computadores e segurança, julgue o item que segue.

Os aplicativos de antivírus com escaneamento de segunda geração utilizam técnicas heurísticas para identificar códigos maliciosos.



Quanto ao **método de detecção**, os antivírus geralmente utilizam:

- **Assinatura:** uma lista de assinaturas é usada à procura de padrões;
- **Heurística:** baseia-se nas estruturas, instruções e características que o código malicioso possui; e
- **Comportamento:** baseia-se no comportamento apresentado pelo código malicioso quando executado.

Os aplicativos de **antivírus com escaneamento de segunda geração** utilizam técnicas heurísticas para identificar códigos maliciosos.

Certo.

025. (CESPE/PC-MA/2018) Julgue o item subsequente, relativo a software para o ambiente de microinformática e a proteção e segurança da informação.

Fazer becape regularmente é uma conduta que permite minimizar os danos decorrentes de um ataque do tipo ransomware locker, que impede o acesso ao equipamento infectado, visto que o pagamento do resgate não garante acesso aos dados.



Para se proteger de **ransomware** você deve tomar os mesmos cuidados que toma para evitar os outros códigos maliciosos, como ter um antivírus instalado e ser cuidadoso ao clicar em *links* ou abrir arquivos. Fazer *backups* regularmente também é essencial para proteger os seus dados pois, se seu equipamento for infectado, a única solução realmente efetiva para acessá-los novamente é buscá-los em seus *backups*.

Certo.

026. (CESPE/ANVISA/2016) Códigos maliciosos podem ter acesso aos dados armazenados no computador e executar ações em nome dos usuários, de acordo com as permissões de operação de cada um destes.



Os códigos maliciosos são programados com o intuito de prejudicar os sistemas de informação, alterar o funcionamento de programas, roubar informações do usuário da máquina, dentre outros. Esses códigos podem obter acesso aos dados que estão armazenados em um computador, e executar ações se passando por um determinado usuário, de acordo com os privilégios que o usuário tiver no sistema.

Geralmente, há **três tipos de contas** que podem ser utilizadas no computador, sendo que cada tipo oferece aos usuários um nível diferenciado de controle da máquina:

- a **conta de administrador**, com total privilégio sobre a máquina, fornece mais controle do computador e deve ser usada quando necessário;
- a **conta padrão**, sem privilégios administrativos, é a que deve ser usada para o dia a dia;
- a **conta de convidado**, também sem privilégios administrativos, destinase às pessoas que precisam usar temporariamente o computador.

Portanto, se um usuário que é um administrador da máquina e possui privilégios administrativos completos sobre o equipamento teve a máquina contaminada por um código malicioso, essa ameaça poderá executar quaisquer ações nesse sistema, colocando em risco a segurança do computador.

Certo.

027. (CESPE/DPU/ANALISTA/2016) A respeito da Internet e suas ferramentas, julgue o item a seguir.

Malwares são mecanismos utilizados para evitar que técnicas invasivas, como phishing e spams, sejam instaladas nas máquinas de usuários da Internet.



Spams são mensagens de correio eletrônico não autorizadas ou não solicitadas pelo destinatário, geralmente de conotação publicitária ou obscena.

Phishing (ou **scam**) não é um programa que pode ser instalado no computador do usuário, mas sim um nome dado a um tipo de golpe eletrônico que tem o objetivo de “pescar” (roubar) informações e dados pessoais importantes (como senhas, dados bancários, etc.) da vítima através da criação de um website falso e/ou do envio de uma mensagem eletrônica falsa.

Malwares (combinação de **malicious software** – **programa malicioso**) são **softwares maliciosos**, programados com o intuito de prejudicar os sistemas de informação, alterar o funcionamento de programas, roubar informações, causar lentidões de redes computacionais,

dentre outros. Em outras palavras, *malwares* são **programas que executam deliberadamente ações mal-intencionadas em um computador, comprometendo a segurança da informação**, ao contrário do que foi reportado na questão!

Errado.

028. (CESPE/TRE-RS/TÉCNICO JUDICIÁRIO/2015) Em relação a vírus, worms e pragas virtuais, assinale a opção correta.

- a) Para garantir a segurança da informação, é suficiente instalar e manter atualizados antivírus.
- b) Não há diferença — seja conceitual, seja prática — entre worms e vírus; ambos são arquivos maliciosos que utilizam a mesma forma para infectar outros computadores.
- c) Rootkits é um arquivo que infecta o computador sem causar maiores danos, ainda que implique a pichação da tela inicial do navegador.
- d) A segurança da informação em uma organização depende integralmente de a sua área de tecnologia optar pela adoção de recursos de segurança atualizados, como firewall e antivírus.
- e) Em segurança da informação, denominam-se engenharia social as práticas utilizadas para obter acesso a informações importantes ou sigilosas sem necessariamente utilizar falhas no software, mas, sim, mediante ações para ludibriar ou explorar a confiança das pessoas.



- a) Errada. O antivírus é uma das ferramentas de segurança que devem ser implementadas para resguardar a segurança dos ativos (o que tem valor para o indivíduo ou organização e que merece ser protegido). Outras práticas de segurança também são recomendadas, como: conscientização de usuários, utilização de *firewall* etc.
- b) Errada. **Worms** são programas parecidos com vírus, mas que na verdade são capazes de se propagarem **automaticamente** através de redes, enviando cópias de si mesmo de computador para computador (observe que **os worms apenas se copiam, não infectam outros arquivos**, eles mesmos são os arquivos!).

Veja as principais diferenças entre essas ameaças na tabela seguinte:

VÍRUS	WORM
É um programa (ou parte de um programa) que se anexa a um arquivo de programa qualquer.	Programa.
Propaga-se inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos.	Não embute cópias de si mesmo em outros programas ou arquivos. Propaga-se automaticamente pelas redes , enviando cópias de si mesmo de computador para computador.

VÍRUS	WORM
Depende da execução do programa ou arquivo hospedeiro para ser ativado.	Não necessita ser explicitamente executado para se propagar. Basta que se tenha execução direta de suas cópias ou a exploração automática de vulnerabilidades existentes em programas instalados em computadores.

c) Errada. **Rootkit** é um tipo de malware cuja **principal intenção é se camuflar, para assegurar a sua presença no computador comprometido, impedindo que seu código seja encontrado por qualquer antivírus**. Isto é possível porque esta aplicação tem a capacidade de interceptar as solicitações feitas ao sistema operacional, podendo alterar o seu resultado. O invasor, após instalar o *rootkit*, terá **acesso privilegiado ao computador** previamente comprometido, sem precisar recorrer novamente aos métodos utilizados na realização da invasão, e suas atividades serão escondidas do responsável e/ou dos usuários do computador. Um *rootkit* pode fornecer programas com as mais diversas funcionalidades. Dentre eles, merecem destaque:

- programas para esconder atividades e informações deixadas pelo invasor, tais como arquivos, diretórios, processos etc.;
- *backdoors*, para assegurar o acesso futuro do invasor ao computador comprometido;
- programas para remoção de evidências em arquivos de *logs*;
- *sniffers*, para capturar informações na rede onde o computador está localizado, como por exemplo senhas que estejam trafegando em claro, ou seja, sem qualquer método de criptografia;
- *scanners*, para mapear potenciais vulnerabilidades em outros computadores.

Rootkit é um tipo de praga virtual de difícil detecção, visto que é ativado antes que o sistema operacional tenha sido completamente inicializado (CESPE/2013/PCDF).

d) Errada. Todas as áreas da organização devem estar envolvidas! Não adianta ter a melhor tecnologia se as pessoas não estão envolvidas com a temática de segurança e não colocam em ação no seu dia a dia as boas práticas de segurança.

e) Certa. **Engenharia Social** é a técnica de ataque utilizada para se obter informações sigilosas ou importantes de empresas e sistemas, **enganando e explorando a confiança dos usuários**.

Letra e.

029. (CESPE/TELEBRÁS/ANALISTA SUPERIOR/COMERCIAL/2015) A respeito de segurança da informação, julgue o item subsecutivo.

Worms, assim como os vírus, são autorreplicáveis e necessitam ser executados pelos usuários para se propagarem e infectarem os computadores de uma rede.



Worms são programas parecidos com vírus, mas que na verdade **são capazes de se propagarem automaticamente através de redes**, enviando cópias de si mesmo de computador para computador (observe que **os worms apenas se copiam, não infectam outros arquivos**, eles mesmos são os arquivos!). Diferentemente do vírus, **o worm** não embute cópias de si mesmo em outros programas ou arquivos e não necessita ser explicitamente executado para se propagar. Sua propagação se dá através da **exploração de vulnerabilidades** existentes ou falhas na configuração de softwares instalados em computadores.

Errado.

030. (CESPE/TCE-RN/CONHECIMENTOS BÁSICOS PARA OS CARGOS 2 E 3/2015) Julgue o item subsequente, a respeito de organização e gerenciamento de arquivos, pastas e programas, bem como de segurança da informação.

A principal diferença entre crackers e hackers refere-se ao modo como esses malfeitores da área de segurança da informação atacam: os crackers são mais experientes e realizam ataques sem utilizar softwares, ao passo que os hackers utilizam códigos maliciosos associados aos softwares para realizar ataques ao ciberespaço.



Os **hackers**, por sua definição geral, são **aqueles que utilizam seus conhecimentos para invadir sistemas, não com o intuito de causar danos às vítimas, mas sim como um desafio às suas habilidades**. Eles invadem os sistemas, capturam ou modificam arquivos para provar sua capacidade e depois compartilham suas proezas com os colegas. Não têm a intenção de prejudicar, mas sim de apenas demonstrar que conhecimento é poder.

Os **crackers** são elementos que **invadem sistemas para roubar informações e causar danos às vítimas**. O termo *crackers* também é uma denominação utilizada para aqueles que decifram códigos e destroem proteções de software.

Atualmente, a imprensa mundial atribui qualquer incidente de segurança a *hackers*, em seu **sentido genérico**. A palavra *cracker* não é vista nas reportagens, a não ser como *cracker* de senhas, que é um *software* utilizado para descobrir senhas ou decifrar mensagens cifradas. Assim, não existe a diferença reportada na questão!

Obs.: Para a prova, guarde o seguinte:

Hackers ("Do bem"): invadem sistemas no intuito de demonstrar as suas habilidades e as vulnerabilidades do seu alvo.

Crackers ("Do mal"): invadem sistemas com a finalidade de obter vantagem/dinheiro. Lembre-se da droga Crack para memorizar que Cracker é ruim, do mal! #FicaaDica

Errado.

031. (CESPE/TJ-DFT/ANALISTA JUDICIÁRIO/2015) A respeito de sistemas operacionais e aplicativos para edição de texto, julgue o item que se segue.

Vírus do tipo boot, quando instalado na máquina do usuário, impede que o sistema operacional seja executado corretamente.



Vírus de boot é um tipo de ameaça que infecta o setor de *boot* (ou **MBR – Master Boot Record – Registro Mestre de Inicialização**) dos discos rígidos. Com o vírus de *boot*, por afetar os arquivos de inicialização, o funcionamento do sistema operacional é prejudicado. O sistema operacional já será iniciado infectado e sistematicamente não funcionará corretamente.

Certo.

032. (CESPE/TELEBRÁS/ANALISTA ADMINISTRADOR/2015) No que se refere à segurança da informação, julgue o seguinte item.

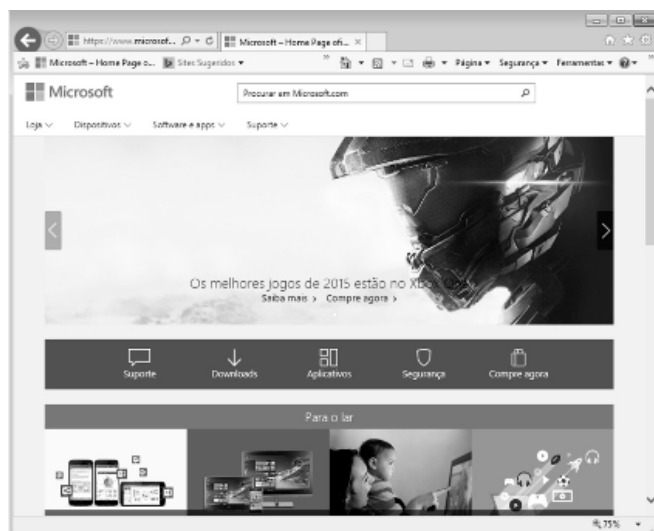
Sniffers são programas aparentemente inofensivos cuja principal característica é utilizar a técnica de mascaramento. A técnica em questão permite, por exemplo, que um sniffer seja anexado a um jogo, que, por sua vez, ao ser instalado em um computador, coletará informações bancárias do usuário.



Cavalo de Troia (ou Trojan Horse) é um programa, normalmente recebido como um “presente” (por exemplo cartão virtual, álbum de fotos, protetor de tela, jogo etc.), que além de executar funções para as quais foi aparentemente projetado, também executa outras funções normalmente maliciosas e sem o conhecimento do usuário. Assim, esse programa aparentemente inofensivo, que utiliza a técnica de mascaramento, é o cavalo de troia.

Um **sniffer atua na rede farejando pacotes** na tentativa de encontrar certas informações (**trata-se de um malware quando fareja pacotes da rede em busca de informações não autorizadas**, como nomes de usuários, senhas ou qualquer outra informação transmitida que não esteja criptografada).

Errado.



033. (CESPE/CEBRASPE/MP-ENAP/ADMINISTRADOR/2015) A respeito da figura acima apresentada, do Internet Explorer 11 e de segurança da informação, julgue o item a seguir. Trackwares são programas que rastreiam a atividade do sistema, reúnem informações do sistema ou rastreiam os hábitos do usuário, retransmitindo essas informações a organizações de terceiros.



Conforme destaca Norton Security (2014), **“trackwares são programas que rastreiam a atividade do sistema, reúnem informações do sistema ou rastreiam os hábitos do usuário, retransmitindo essas informações a organizações de terceiros”**.

As informações reunidas por esses programas não são confidenciais nem identificáveis. Os programas de *trackware* são instalados **com o consentimento do usuário** e também podem estar contidos em pacotes de outro *software* instalado pelo usuário.

Certo.

034. (CESPE/TRE-GO/ANALISTA JUDICIÁRIO/2015) Acerca de procedimentos de segurança e de ensino a distância, julgue o item subsequente.

Botnet é uma rede formada por inúmeros computadores zumbis e que permite potencializar as ações danosas executadas pelos bots, os quais são programas similares ao worm e que possuem mecanismos de controle remoto.



De modo similar ao *worm*, **bot (“robô”) é um programa capaz de se propagar automaticamente, explorando vulnerabilidades existentes ou falhas na configuração de software instalado em um computador**. Adicionalmente ao *worm*, dispõe de mecanismos

de comunicação com o invasor, permitindo que o *bot* seja controlado remotamente. Os *bots* esperam por comandos de um *hacker*, podendo manipular os sistemas infectados, sem o conhecimento do usuário.

Botnet (também conhecida como **rede zumbi**) é uma rede infectada por *bots*, sendo composta geralmente por milhares desses elementos maliciosos, que ficam residentes nas máquinas, aguardando o comando de um **invasor**. Quanto mais zumbis (*Zombie Computers*) participarem da botnet, mais potente ela será. **Um invasor que tenha controle sobre uma botnet pode utilizá-la para:**

- coletar informações de um grande número de computadores;
- “clicar” em anúncios e gerar receitas fraudulentas;
- enviar spam em grande escala;
- hospedar sites de *phishing*;
- iniciar ataques de negação de serviço que impedem o uso de serviços *online* etc.

Certo.

035. (CESPE/CADE/NÍVEL INTERMEDIÁRIO/NÍVEL MÉDIO/2014) Acerca dos conceitos de gerenciamento de arquivos e de segurança da informação, julgue o item subsequente. O computador utilizado pelo usuário que acessa salas de bate-papo não está vulnerável à infecção por worms, visto que esse tipo de ameaça não se propaga por meio de programas de chat.



O **malware (código malicioso)** do tipo **Worm** pode infectar máquinas desprotegidas, a partir da utilização de programas de *chat*. A contaminação pode acontecer, por exemplo, através de textos e fotografias enviados através do programa de chat, com o auxílio de encurtadores de URL. Caso uma pessoa clique em um dos endereços falsos, a máquina é contaminada automaticamente pelo *malware*, que em seguida pode se espalhar pela rede de contatos do usuário.

Bate-papo



Para prevenção contra *worms*, mantenha o sistema operacional e demais *softwares* do equipamento sempre atualizados; aplique todas as correções de segurança (**patches**) disponibilizadas pelos fabricantes, para corrigir eventuais vulnerabilidades existentes nos *softwares* utilizados; instale um *firewall* pessoal, que **em alguns casos** pode evitar que uma vulnerabilidade existente seja explorada (**observe que o firewall não corrige as vulnerabilidades!**) ou que um *worm* se propague.

Errado.

036. (FCC/SEGEP-MA/2018) Em uma situação hipotética, um funcionário da Secretaria de Estado da Gestão e Assistência dos Servidores (SEGEP) verificou que um tipo de código malicioso (*malware*) havia invadido e tornado inacessíveis os dados armazenados em seu equipamento porque tudo havia sido criptografado. O invasor exigiu pagamento de resgate para restabelecer o acesso.

Essa situação mostra a ocorrência do ataque cibernético de um *malware* conhecido por:

- a) Spam.
- b) Ransomware.
- c) Trojan Spy.
- d) Cookie.
- e) Worm.



Ransomware é um tipo de *malware* **que torna inacessíveis os dados armazenados em um equipamento**, geralmente usando **criptografia**, e que **exige pagamento de resgate (*ransom*)** para restabelecer o acesso ao usuário.

Existem dois tipos de *ransomware*:

- **Ransomware Locker:** impede que você acesse o equipamento infectado;
- **Ransomware Crypto:** impede que você acesse aos dados armazenados no equipamento infectado, geralmente usando criptografia, para impedir que o usuário tenha acesso aos dados.

Para se proteger de *ransomware* você deve tomar os mesmos cuidados que toma para evitar os outros códigos maliciosos, como ter um antivírus instalado e ser cuidadoso ao clicar em *links* ou abrir arquivos. Fazer *backups* regularmente também é essencial para proteger os seus dados pois, se seu equipamento for infectado, a única solução realmente efetiva para acessá-los novamente é buscá-los em seus *backups*.

Como exemplo, a ameaça conhecida como Wannacry é um tipo de ransomware que atacou uma enorme quantidade de computadores em diversas partes do mundo em 2017 e conseguiu se infiltrar nesses equipamentos graças a uma vulnerabilidade no Windows.

Letra b.

037. (FCC/AGED-MA/2018) Não importa se um usuário utiliza Microsoft, MacOS, Android ou outro tipo de sistema operacional, pois ao se conectar na internet com um deles, já fica vulnerável a uma infinidade de ataques digitais e pode sofrer com um tipo de malware cuja invasão é realizada com o intuito de causar algum dano ou roubar informações.

(Adaptado de: <http://tecnologia.ig.com.br/2017-04-04/malware-cimes-ciberneticos.html>)

O malware referenciado no texto é um programa que, além de executar as funções para as quais foi aparentemente projetado, também executa outras funções maliciosas sem o conhecimento do usuário. Ataca através de programas que necessitam ser explicitamente executados para que sejam instalados, mas também pode ser instalado por atacantes que, após invadirem o computador, alteram programas já existentes para que também executem ações maliciosas. Este malware é denominado:

- a) worm.
- b) rootkit.
- c) trojan.
- d) wanna cry.
- e) ransomware



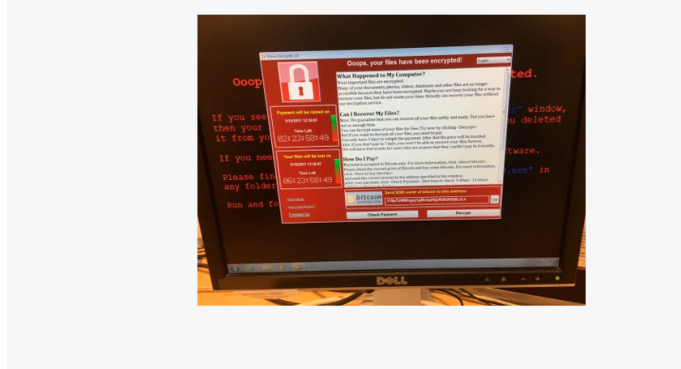
a) Errada. **Worms** são programas parecidos com vírus, mas que na verdade são capazes de se propagarem automaticamente através de redes, enviando cópias de si mesmo de computador para computador (observe que os worms apenas se copiam, não infectam outros arquivos, eles mesmos são os arquivos!).

b) Errada. **Rootkit** é um conjunto de programas e técnicas que permite esconder e assegurar a presença de um invasor ou de outro código malicioso em um computador comprometido. O conjunto de programas e técnicas fornecido pelos *rootkits* pode ser usado para: remover evidências em arquivos de logs; instalar outros códigos maliciosos, como *backdoors*, para assegurar o acesso futuro ao computador infectado; esconder atividades e informações, como arquivos, diretórios, processos, chaves de registro, conexões de rede, etc.; mapear potenciais vulnerabilidades em outros computadores, por meio de varreduras na rede; capturar informações da rede onde o computador comprometido está localizado, pela interceptação de tráfego (CertBr, 2013).

c) Certa. **Trojan Horse (Cavalo de Troia)** é um programa **aparentemente inofensivo** que entra em seu computador na forma de cartão virtual, álbum de fotos, protetor de tela, jogo etc., e que, quando executado (com a sua autorização), parece lhe divertir, mas, por trás possui funcionalidades maliciosas escondidas, que permitem, por exemplo, abrir portas de comunicação do seu computador para que ele possa ser invadido ou monitorado etc. Por definição, o Cavalo de Troia distingue-se de um vírus ou de um *worm* por **NÃO infectar outros arquivos, NEM propagar cópias de si mesmo automaticamente**.

d) Errada. Conforme foi noticiado pela imprensa, um **ataque cibernético** de grandes proporções iniciou-se em **12/05/17**, afetando diversas empresas ao redor do mundo. A ameaça principal detectada neste cenário é um *ransomware*, conhecido pelas variantes de **WannaCry** ou **HydraCrypt**, que infecta computadores utilizando o sistema operacional **Microsoft Windows** através de uma vulnerabilidade no serviço **SMB**, utilizado para o compartilhamento de arquivos via rede.

Wanna Cry 2.0: Ransomware + Worm



Resumindo, **trata-se de uma infecção por malware do tipo “ransomware”, que se caracteriza por criptografar os arquivos dos usuários e exigir um “resgate” em dinheiro eletrônico, conhecido como Bitcoin (moeda virtual), para que seja fornecida a senha de recuperação desses dados**. Além de *ransomware*, atua como um **worm**, propagando-se automaticamente pelas redes com máquinas desatualizadas (uma vez que um computador seja infectado, ele tentará propagar essa infecção para os demais computadores conectados na mesma rede).

e) Errada. **Ransomware** é um tipo de *malware* que torna inacessíveis os dados armazenados em um equipamento, geralmente usando **criptografia**, e que exige pagamento de **resgate (ransom)** para restabelecer o acesso ao usuário.

Letra c.

PRINCÍPIOS OU ATRIBUTOS BÁSICOS DE SEGURANÇA DA INFORMAÇÃO

038. (INSTITUTO AOCP/DPE MS/ANALISTA DE DEFENSORIA/SUPORTE TÉCNICO DE REDES/2024)

Como analista de Suporte Técnico de Redes, você está liderando uma sessão de treinamento para sua equipe de TI sobre os princípios fundamentais da segurança da informação. Durante a sessão, você explica os principais princípios da segurança da informação. Ao explicar o princípio de “Integridade”, você dirá corretamente que

a) se trata da garantia de que informações sensíveis e dados críticos só sejam acessíveis por pessoas autorizadas. Isso envolve implementação de controles de acesso, criptografia e políticas de privacidade para prevenir o acesso não autorizado.

b) se trata da garantia de que os recursos de TI e os dados estejam disponíveis e acessíveis quando necessário. Isso inclui medidas para evitar interrupções não planejadas, como falhas de hardware, ataques cibernéticos ou desastres naturais. São comuns práticas como backups regulares e redundância de sistemas.

c) se trata da garantia de que as informações não sejam alteradas de forma não autorizada ou acidental. Para garantir esse princípio, são implementados controles de proteção contra modificações não autorizadas, como assinaturas digitais e verificação de hash.

d) se refere à capacidade de provar que uma ação foi realizada por uma parte específica e não pode ser negada posteriormente. Isso é importante, por exemplo, em transações financeiras ou contratos eletrônicos. A assinatura digital é um exemplo de mecanismo para garantir esse princípio.

e) envolve a garantia de que as informações e ações são genuínas e originárias de fontes legítimas. Isso significa que os dados e as transações não foram falsificados, e as identidades das partes envolvidas são verificadas e confiáveis. É frequentemente alcançada por meio de técnicas de autenticação, como senhas, certificados digitais, tokens de segurança e biometria.



a) Errada. Essa assertiva descreve o princípio de **confidencialidade**, não de Integridade. Confidencialidade é sobre proteger os dados contra acessos não autorizados, garantindo que apenas indivíduos devidamente autorizados possam acessar informações sensíveis. Utiliza-se controles de acesso, criptografia e rigorosas políticas de privacidade para manter a confidencialidade dos dados.

b) Errada. Refere-se ao princípio da **disponibilidade**. Disponibilidade assegura que os sistemas e dados estejam acessíveis e operacionais sempre que necessário. Isso envolve a implementação de medidas contra interrupções imprevistas, como backups, redundância de sistemas e robustez contra falhas.

c) Certa. Essa assertiva corretamente descreve o princípio da **integridade**, o qual visa garantir que os dados não sejam modificados sem autorização e permaneçam precisos e confiáveis. Ferramentas como verificações de *hash* e assinaturas digitais ajudam a assegurar que as informações não foram alteradas de forma indevida.

d) Errada. Essa assertiva descreve o princípio de **não repúdio**, não de Integridade. Não repúdio garante que uma parte em uma transação não possa negar a sua participação ou a execução de uma ação. Isso é crucial em contextos legais, como transações financeiras e contratos eletrônicos, onde a prova de autoria e intenção é necessária.

e) Errada. Essa assertiva refere-se ao princípio de **autenticidade**, não de Integridade. Autenticidade assegura que as informações e ações são verdadeiras e originam-se de fontes confiáveis, garantindo que as entidades envolvidas são realmente quem dizem ser. Métodos de autenticação, como senhas e biometria, ajudam a verificar a identidade das partes envolvidas.

Esses comentários visam esclarecer o foco de cada princípio e a importância de entender suas diferenças para uma aplicação eficaz em segurança da informação.

Letra c.

039. (FGV/SECRETARIA MUNICIPAL DE FAZENDA DE NITERÓI/2015) A Segurança da Informação (SI) está associada a um conjunto de atributos básicos que devem ser respeitados na análise e planejamento de mecanismos e procedimentos para proteção. Considere uma suposta lista desses atributos, mostrada a seguir.

I – Autenticidade

II – Confidencialidade

III – Conformidade

IV – Disponibilidade

V – Integridade

VI – Irretratabilidade

VII – Presteza

Dessa lista, um item que NÃO é usualmente reconhecido como um dos atributos básicos da SI é:

a) Presteza;

b) Integridade;

c) Disponibilidade;

d) Confidencialidade;

e) Autenticidade.



Dentre as opções, a única que não apresenta um atributo básico da segurança da informação é a letra A (Presteza).

Confiabilidade, integridade, disponibilidade e autenticidade são conceitos tão arraigados que qualquer pessoa que já estudou segurança da informação alguma vez certamente já ouviu falar do assunto. Veja a descrição desses itens:

Integridade	Salvaguarda da exatidão e completeza da informação e dos métodos de processamento.
Disponibilidade	Garantia de que os usuários autorizados obtenham acesso à informação e aos ativos correspondentes sempre que necessário.
Confidencialidade	Garantia de que o acesso à informação seja obtido somente por pessoas autorizadas.
Autenticidade	É a capacidade de garantir a identidade de uma pessoa (física ou jurídica) que acessa as informações do sistema ou de um servidor (computador) com quem se estabelece uma transação (de comunicação, como um e-mail, ou comercial, como uma venda on-line).

Letra a.

040. (INÉDITA/2024) Confidencialidade, integridade e disponibilidade são considerados os três pilares principais da segurança da informação.



Esses são os três atributos básicos conhecidos como o modelo CIA, que formam a base da segurança da informação: confidencialidade (protegendo o acesso a informações), integridade (assegurando que as informações não sejam alteradas indevidamente) e disponibilidade (garantindo que as informações estejam acessíveis quando necessário).

Certo.

041. (INÉDITA/2024) Manter o sigilo de informações em uma organização não é necessário se todos os dados forem criptografados, já que a criptografia por si só garante a proteção completa dos dados.



Embora a criptografia aumente significativamente a segurança dos dados, o sigilo das informações também depende de políticas de acesso, práticas de gerenciamento de chaves e outros controles para garantir que apenas usuários autorizados possam acessar e decifrar os dados.

Errado.

042. (IBFC/SESACRE/AGENTE ADMINISTRATIVO/2019) A Segurança da Informação (SI) está relacionada com proteção de um conjunto de informações a fim de preservar o valor que possuem para um indivíduo ou uma organização. Sobre as propriedades básicas da segurança da informação, assinale a alternativa correta.

- a) Rastreabilidade, usabilidade, notoriedade
- b) Confidencialidade, integridade, disponibilidade
- c) Integridade, usabilidade, simplicidade
- d) Disponibilidade, rastreabilidade, simplicidade



A segurança da informação possui o objetivo de garantir alguns **princípios ou propriedades básicas**, quais sejam:

Letra b.

043. (CESPE/DPU/ANALISTA/2016) A respeito da Internet e suas ferramentas, julgue o item a seguir.

Integridade, confidencialidade e disponibilidade da informação, conceitos fundamentais de segurança da informação, são adotados na prática, nos ambientes tecnológicos, a partir de um conjunto de tecnologias como, por exemplo, criptografia, autenticação de usuários e equipamentos redundantes.



A **Confidencialidade**, a **Integridade** e a **Disponibilidade** são três conceitos fundamentais de segurança da informação.

Eles formam aquilo que chamamos de **pirâmide** ou **tríade** da Segurança da Informação (É possível encontrar a sigla **CID**, para fazer menção às iniciais desses 3 princípios!).

Princípio	Característica	Dica Complementar
Confidencialidade (ou sigilo)	É a garantia de que a informação não será conhecida por quem não deve. O acesso às informações deve ser limitado, ou seja, somente as pessoas explicitamente autorizadas podem acessá-las.	Manter a confidencialidade pressupõe assegurar que as pessoas não tomem conhecimento de informações, de forma acidental ou proposital, sem que possuam autorização para tal procedimento.
Integridade	É a garantia de que a informação que foi armazenada é a que será recuperada. A integridade busca proteção contra codificação não autorizada. Modificação deve ser realizada somente pelas partes devidamente autorizadas.	A manutenção da integridade pressupõe a garantia de não violação dos dados com intuito de alteração, gravação ou exclusão, seja ela acidental ou proposital.

Disponibilidade	Busca acesso disponível às entidades autorizadas sempre que necessário .	Manter a disponibilidade pressupõe garantir a prestação contínua do serviço, sem interrupções no fornecimento de informações para quem é de direito.
------------------------	---	---

Esses **princípios** são aplicados na prática, nos ambientes tecnológicos, a partir de um **conjunto de controles** como, por exemplo, **criptografia, autenticação de usuários e equipamentos redundantes** (um sistema redundante possui um segundo dispositivo que está imediatamente disponível para uso quando da falha do dispositivo principal).

Aspecto	Descrição	Medidas de Controle
<u>Confidencialidade</u>	Garantia que a informação não será conhecida por quem não deve	Classificação da informação, criptografia.
<u>Integridade</u>	Garantia que a informação que foi armazenada é a que será recuperada	Autenticação de usuários e implementação de controle de acesso.
<u>Disponibilidade</u>	Garantia que a informação sempre poderá ser acessada	Plano de contingência Uso de equipamentos redundantes, etc.

Certo.

044. (FCC/TRE-RR/ANALISTA JUDICIÁRIO/MEDICINA/2015) O processo de proteção da informação das ameaças caracteriza-se como Segurança da Informação. O resultado de uma gestão de segurança da informação adequada deve oferecer suporte a cinco aspectos principais:

- I – Somente as pessoas autorizadas terão acesso às informações.
 - II – As informações serão confiáveis e exatas. Pessoas não autorizadas não podem alterar os dados.
 - III – Garante o acesso às informações, sempre que for necessário, por pessoas autorizadas.
 - IV – Garante que em um processo de comunicação os remetentes não se passem por terceiros e nem que a mensagem sofra alterações durante o envio.
 - V – Garante que as informações foram produzidas respeitando a legislação vigente.
- Os aspectos elencados de I a V correspondem, correta e respectivamente, a:
- a) integridade – disponibilidade – confidencialidade – autenticidade – legalidade.
 - b) disponibilidade – confidencialidade – integridade – legalidade – autenticidade.

- c) confidencialidade – integridade – disponibilidade – autenticidade – legalidade.
d) autenticidade – integridade – disponibilidade – legalidade – confidencialidade.
e) autenticidade – confidencialidade – integridade – disponibilidade – legalidade.



Aspectos de segurança	Descrição
confidencialidade	I – Somente as pessoas autorizadas terão acesso às informações.
integridade	II – As informações serão confiáveis e exatas. Pessoas não autorizadas não podem alterar os dados.
disponibilidade	III – Garante o acesso às informações, sempre que for necessário, por pessoas autorizadas.
autenticidade	IV – Garante que em um processo de comunicação os remetentes não se passem por terceiros e nem que a mensagem sofra alterações durante o envio.
legalidade	V – Garante que as informações foram produzidas respeitando a legislação vigente.

Letra c.

PRINCIPAIS GOLPES APLICADOS NA INTERNET

045. (CESGRANRIO/IPEA/TÉCNICO DE PLANEJAMENTO E PESQUISA/INFRAESTRUTURA DE TECNOLOGIA DA INFORMAÇÃO/2024) Mensagens não solicitadas em forma de e-mails, conhecidas como spam, são muito utilizadas para enganar os usuários de sistemas de informação. As soluções antispam possuem um papel crucial para evitar ataques de engenharia social executados por meio de spams que representam verdadeiras ameaças aos usuários. Nesse contexto, considere que um indivíduo recebeu um e-mail contendo um spam com um link malicioso que o direcionará para uma página web falsa de um banco de investimentos, com o objetivo de coletar as suas credenciais de acesso a esse sistema. Essa ação maliciosa é conhecida como

- a) vishing
b) phishing
c) skimming
d) tailgating
e) water-holing



a) Errada. **Vishing** é uma forma de *phishing* que envolve o uso de chamadas telefônicas ou mensagens de voz para enganar as vítimas e levá-las a divulgar informações pessoais ou

financeiras. Embora relacionado à engenharia social, o *vishing* não envolve e-mails ou *links* maliciosos, mas sim contatos telefônicos.

b) Certa. **Phishing** é o envio de e-mails fraudulentos que imitam comunicações legítimas de instituições de confiança para enganar os destinatários, induzindo-os a revelar dados sensíveis, como credenciais de login ou informações bancárias. No contexto da questão, o e-mail com um link para uma página falsa de um banco de investimentos é um exemplo clássico de phishing.

c) Errada. **Skimming** refere-se à captura ilegal de dados de cartões de crédito ou débito durante transações físicas, geralmente através da instalação de dispositivos em terminais de pagamento. Não é relevante para ataques via e-mail ou na coleta de dados online.

d) Errada. **Tailgating** é uma técnica de engenharia social que envolve seguir alguém autorizado em uma área restrita para obter acesso físico a um local seguro. Esta prática é exclusivamente física e não tem relação com e-mails ou links maliciosos.

e) Errada. **Water-holing** é uma técnica em que os atacantes comprometem *sites* legítimos e frequentemente visitados por um alvo específico, explorando vulnerabilidades nos visitantes do site. Não se trata de e-mails ou links falsos enviados diretamente às vítimas, mas sim de infectar sites legítimos para atingir um público-alvo.

A ação maliciosa descrita na questão, que envolve um e-mail com um link para uma página falsa criada para roubar credenciais, é conhecida como **b) phishing**.

Letra b.

046. (CESGRANRIO/IPEA/TÉCNICO DE PLANEJAMENTO E PESQUISA/DESENVOLVIMENTO DE SISTEMA/2024) Uma empresa sofreu um ataque que provocou a interrupção dos serviços de rede para os seus funcionários, usuários legítimos do sistema dessa empresa. Esse ataque foi feito utilizando uma técnica de negação que forçou os servidores de serviços de rede publicamente acessíveis a produzirem uma inundação de mensagens de controle do tipo SYN/ACK do protocolo TCP para cima do alvo. Esse tipo de ataque é o de

- a) DDoS
- b) DRDoS
- c) PoD
- d) Smurf
- e) Teardrop



a) Errada. **DDoS (Distributed Denial of Service)** é um ataque de negação de serviço distribuído, que envolve múltiplos sistemas atacando um único alvo para sobrecarregá-lo e tornar seus

serviços indisponíveis. Embora relacionado à negação de serviço, a descrição do ataque específico de inundação de mensagens SYN/ACK não é o foco principal de DDoS em geral.

b) Certa. **DRDoS (Distributed Reflective Denial of Service)** é uma variante de DDoS em que o ataque é amplificado ao fazer o uso de servidores intermediários (ou seja, refletidos) para enviar respostas volumosas ao alvo. A técnica descrita de inundação de mensagens SYN/ACK é compatível com um ataque DRDoS, onde o atacante usa servidores públicos para refletir pacotes ao alvo.

c) Errada. **PoD (Ping of Death)** é um ataque onde pacotes ICMP malformados ou excessivamente grandes são enviados para um sistema, causando falhas. Não está relacionado com a inundação de mensagens SYN/ACK do protocolo TCP descrita.

d) Errada. O **ataque Smurf** envolve enviar pacotes ICMP (ping) a uma rede com um endereço de broadcast, fazendo com que muitos dispositivos respondam ao alvo com pacotes eco. Isso resulta em uma negação de serviço, mas usa ICMP, não TCP SYN/ACK.

e) Errada. O ataque Teardrop envolve o envio de pacotes IP fragmentados que os sistemas alvo não conseguem remontar corretamente, causando falhas ou travamentos. Este ataque não utiliza mensagens SYN/ACK do protocolo TCP.

Com base na descrição de um ataque que causa uma inundação de mensagens SYN/ACK, a opção mais correta é **b) DRDoS**, pois descreve um cenário em que servidores legítimos refletidores são usados para amplificar o ataque com mensagens de controle, como SYN/ACK, sobrecarregando o alvo.

Letra b.

047. (FCC/ALESE/TÉCNICO LEGISLATIVO/2018) Uma ação que NÃO potencializa o risco de golpes (scam) na Internet e de infecção de computador por malware é

- a) baixar atualizações ou softwares em sites de acesso mais rápido que o do fabricante.
- b) entrar em sites para baixar uma faixa musical, álbum ou filmes sem pagar.
- c) utilizar a mesma senha complexa em todos os sites que possui cadastro.
- d) utilizar Virtual Private Network confiável para acessar a Internet em locais públicos.
- e) abrir arquivos anexos no webmail, quando o assunto indicar alta prioridade.



A questão quer que listemos **uma boa prática de segurança que pode ser utilizada no combate a golpes de Phishing (scam), evitando também infecção de computador por malware (códigos maliciosos)**. Nesse contexto, a letra D é a resposta.

a) Errada. Seja cuidadoso ao acessar links para baixar atualizações ou softwares, e procure acessar o site do fabricante diretamente. Por exemplo, atualizações de segurança do

Windows serão feitas a partir do site da Microsoft. Ao baixar atualizações ou softwares de sites desconhecidos o seu risco é alto!

b) Errada. Com essa ação você poderá contaminar o computador com produtos de origem desconhecida, piratas e com códigos maliciosos.

c) Errada. **Senhas** são utilizadas no processo de **verificação da identidade do usuário (login)**, assegurando que este é realmente quem diz ser. Utilize uma senha diferente para cada sistema utilizado. Uma vez descoberta a sua senha, se ela for a mesma em todos os sites, todos os acessos a esses ambientes ficarão comprometidos.

d) Certa. **Virtual Private Network (VPN) ou Rede Virtual Privada** é uma rede **privada** (rede com acesso restrito) **construída sobre a estrutura de uma rede pública**, normalmente a Internet. Cria "túneis" virtuais de transmissão de dados utilizando **criptografia**, mais segura que a rede pública (internet).

e) Errada. Os anexos dos *e-mails* podem estar contaminados, mesmo em mensagens de alta prioridade.

Letra d.

ATAQUES NA INTERNET

048. (FGV/CGM DE BELO HORIZONTE/AUDITOR DE CONTROLE INTERNO/2024) O ataque do tipo ransomware, em que o invasor ameaça publicar informações privadas sobre a vítima na Internet, por meio do uso de malwares que capturam telas e outras informações privadas, para humilhá-la e fazê-la pagar um resgate, é denominado

- a) mobileware.
- b) adware.
- c) doxware.
- d) hoax.



a) Errada. **Mobileware** não é um termo amplamente reconhecido no contexto de segurança cibernética. Entretanto, pode ser uma referência a software ou aplicações desenvolvidas especificamente para dispositivos móveis. Não tem relação com ameaças ou ataques de ransomware.

b) Errada. Adware é um tipo de software que automaticamente exibe ou baixa anúncios para gerar receita. Embora possa ser considerado invasivo, adware não se encaixa na definição de ransomware, especialmente na forma de extorsão através da publicação de dados privados.

c) Certa. **Doxware** é um tipo de ransomware em que o atacante ameaça divulgar informações confidenciais da vítima (*doxing*), a menos que um resgate seja pago. O ataque combina o

conceito de *ransomware* com *doxing*, que é a prática de coletar e publicar informações privadas sobre uma pessoa sem o seu consentimento.

d) Errada. Um *hoax* é um boato ou notícia falsa, geralmente criada para enganar as pessoas. Em tecnologia, pode se referir a alertas de vírus falsos ou notificações enganosas que não representam uma ameaça real. Não está relacionado a *ransomware* ou extorsão de dados. Portanto, a resposta correta é **c) doxware**, pois descreve precisamente o ataque em que o invasor ameaça publicar informações privadas como forma de extorsão.

Veja mais: <https://lazarusalliance.com/pt/doxware/>

Letra c.

Ataques cibernéticos causaram prejuízo de US\$ 280 bilhões às corporações

A extorsão virtual, quando servidores de empresas são bloqueados e seus gestores só recebem acesso novamente mediante pagamento para os criminosos, também é um dos maiores problemas na América Latina, 28,1%, ficando atrás apenas do bloco de países Asiáticos, 35,1%. Os setores mais suscetíveis a essa modalidade de ataques cibernéticos são serviços financeiros (45,8%); cuidados da saúde (23,7%); energia (23,3%); bens de consumo (22,4%); educação (22,1%); viagem, turismo e lazer (19,8%); agricultura (17,9%); setor produtivo (16,3%); tecnologia, meios de comunicação e telecomunicações (13,0%); transporte (11,3%); imobiliário e construção (6,2%) e serviços profissionais (4,8%).

(Disponível em: <http://www.convergenciadigital.com.br>)

049. (FCC/SEGEF-MA/AUXILIAR DE FISCALIZAÇÃO AGROPECUÁRIA/2018) O texto se refere à “extorsão virtual, quando servidores de empresas são bloqueados e seus gestores só recebem acesso novamente mediante pagamento para os criminosos” e quase 18% deste tipo de ataque atinge o setor de agricultura. A denominação deste tipo de ataque é

- a) bot.
- b) spyware.
- c) backdoor.
- d) ransomware.
- e) rootkit.



a) Errada. **Bots (“Robôs”)**, de modo similar ao *worm*, é um programa capaz de se propagar **automaticamente, explorando vulnerabilidades** existentes ou falhas na configuração de software instalado em um computador. Adicionalmente ao *worm*, **dispõe de mecanismos de comunicação com o invasor**, permitindo que o *bot* seja **controlado remotamente**. Os *bots* esperam por comandos de um *hacker*, podendo manipular os sistemas infectados, sem o conhecimento do usuário.

- b) Errada. **Spyware** é um **programa espião (spy em inglês = espião)**, que tem por finalidade monitorar as atividades de um sistema e enviar as informações coletadas para terceiros, sem o consentimento da parte envolvida.
- c) Errada. **Backdoor** é um programa que permite o retorno de um invasor a um computador comprometido, por meio da inclusão de serviços criados ou modificados para este fim.
- d) Certa. **Ransomware** é um tipo de *malware* **que torna inacessíveis os dados armazenados em um equipamento**, geralmente usando **criptografia**, e que **exige pagamento de resgate (ransom)** para restabelecer o acesso ao usuário.
- e) Errada. **Rootkit** é um conjunto de programas e técnicas que permite esconder e assegurar a presença de um invasor ou de outro código malicioso, sendo ativado antes que o sistema operacional esteja totalmente inicializado.

Letra d.

050. (FCC/TRE-SP/ANALISTA JUDICIÁRIO/2017) Considere o texto abaixo.

Com efeito, nesse tipo específico de delito, o agente obtém, para ele ou outrem, vantagem ilícita (numerário subtraído de conta bancária), em prejuízo de alguém (a vítima, cliente de banco) mediante o emprego do artifício da construção de uma página eletrônica falsa ou envio de mensagem eletrônica (e-mail) de conteúdo fraudulento. Não haveria, como se disse, qualquer dificuldade de enquadramento do praticante do “ato ilícito” no art. 171 do CPC, impondo-lhe as sanções previstas nesse dispositivo (reclusão, de um a cinco anos, e multa). Além do mais, quando o criminoso implementa o último estágio da execução ilícita, que é a subtração não autorizada dos fundos existentes na conta da vítima, a jurisprudência tem entendido que aí está caracterizado o crime de furto qualificado, previsto no art. 155, § 4º, II.

(Adaptado de: REINALDO FILHO, Democrito. Disponível em: <http://www.teleco.com.br/pdfs/tutorialin-tbank.pdf>)

Hipoteticamente, um Analista Judiciário do TRE-SP identificou, corretamente, o ato ilícito referido entre aspas no texto como um tipo de fraude por meio da qual um golpista tenta obter dados pessoais e financeiros de um usuário, pela utilização combinada de meios técnicos e engenharia social. Comumente realizado por meio da internet, esse golpe é caracterizado como

- a) *identity theft*.
- b) *fielding*.
- c) *phishing*.
- d) *hacker*.
- e) *worming*.



A questão aborda o **Phishing** (também conhecido como **Phishing scam**, ou apenas **scam**), que é **um tipo de fraude eletrônica** projetada para roubar informações particulares que sejam valiosas para cometer um roubo ou fraude posteriormente.

O golpe de *phishing* é realizado por uma pessoa mal-intencionada através da criação de um website falso e/ou do envio de uma mensagem eletrônica *de conteúdo fraudulento*. Utilizando de pretextos falsos, tenta enganar o receptor da mensagem e induzi-lo a fornecer informações sensíveis (números de cartões de crédito, senhas, dados de contas bancárias etc.).

Identity theft é o mesmo que falsa identidade.

Letra c.

REFERÊNCIAS

ALBUQUERQUE, R.; RIBEIRO, B. *Segurança no desenvolvimento de software*. Rio de Janeiro: Campus, 2002.

CERTBR. *Cartilha de segurança para internet*. Versão 4.0. Disponível em: <<http://cartilha.cert.br/livro/cartilha-seguranca-internet.pdf>>. 2012.

GARTNER. *Gartner lista 7 tendências para a cibersegurança em 2022*. Disponível em: <<https://proximonivel.embratel.com.br/gartner-lista-7-tendencias-para-a-ciberseguranca/>>. Acesso em: 10 set. 2022.

GARTNER. *Gartner unveils the top eight cybersecurity predictions for 2022-23*. Disponível em: <<https://www.gartner.com/en/newsroom/press-releases/2022-06-21-gartner-unveils-the-top-eight-cybersecurity-predictio>>.

GEUS, P. L.; NAKAMURA, E. T. *Segurança de redes em ambientes corporativos*. São Paulo: Novatec, 2007.

LAUDON, K. C.; LAUDON, J. P. *Sistemas de informações gerenciais*. São Paulo: Pearson Prentice Hall, 2007.

MAUSER, D.; DIÓGENES, Y. *Certificação security +*. 2. ed. 2013.

O'BRIEN, J. A. *Sistemas de informação e as decisões gerenciais na era da internet*. 2. ed. São Paulo: Saraiva, 2006.

QUINTÃO, P. L. *Notas de aula*. 2025.

_____. *1001 questões comentadas de informática Cespe*. 2. ed. Ed. Gen/Método, 2017.

_____. *Informática para concursos*. 2025.

_____. *Informática FCC questões comentadas e organizadas por assunto*. 3. ed. Ed. Gen/Método, 2014.

RAMOS, A.; BASTOS, A.; LAYRA, A. *Guia oficial para formação de gestores em segurança da informação*. 1. ed. Rio Grande do Sul: ZOUK, 2006.

SCHNEIER, B. *Applied cryptography: protocols, algorithms and source code in C*. 2. ed. John Wiley & Sons, 1996.

SIEMENS. *As diferenças entre cibersegurança e segurança da informação*. Disponível em: <<https://www.siemens.com/br/pt/empresa/stories/tecnologia/ciberseguranca-e-seguranca-da-informacao.html>>. Acesso em: 10 set. 2022.

STAIR, R. M.; REYNOLDS, G. W. *Princípios de sistemas de informação: uma abordagem gerencial*. 4. ed. Rio de Janeiro: Livros Técnicos e Científicos, 2002.

STALLINGS, W. *Criptografia e segurança de redes: princípios e práticas*. 4. ed. São Paulo: Pearson Prentice-Hall, 2008.

ANEXO

SIGLAS E ABREVIATURAS

TI – Tecnologia da Informação

SSL – Secure Sockets Layer

CIA – Confidencialidade, Integridade e Disponibilidade (Tríade da Segurança da Informação)

RAT – Remote Access Trojan

DoS – Denial of Service

DDoS – Distributed Denial of Service

WAF – Web Application Firewall

DMZ – Demilitarized Zone

IDS – Intrusion Detection System

IPS – Intrusion Prevention System

Abra



caminhos



crie

futuros

gran.com.br

